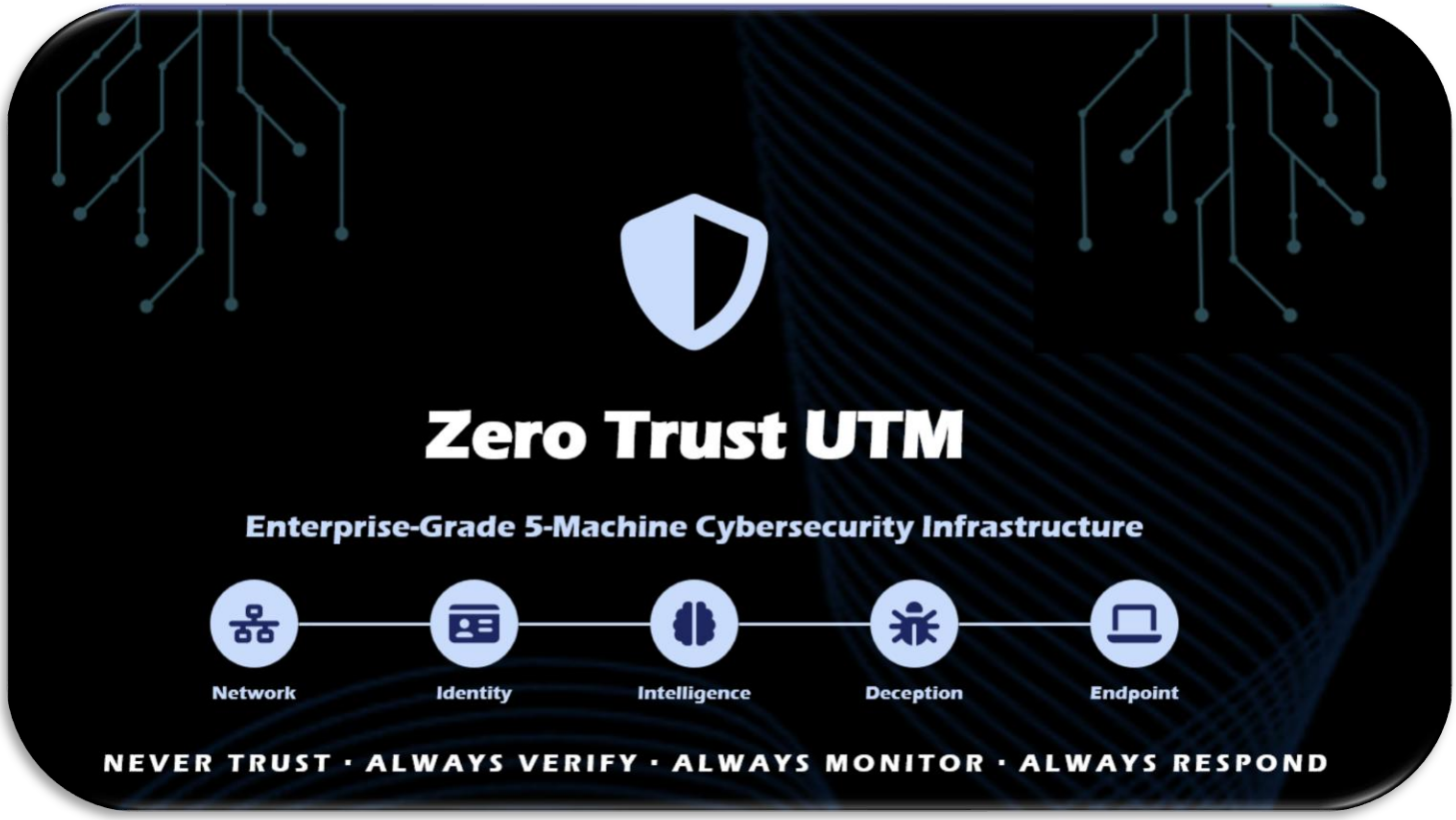


DIVISION
Abdul Rafay Aziz
Abdul Wahid
Usman
Hafsa

SUPERVISOR
Professor Muhammad Azam
Professor Naveed Naeem

Contents

1. Executive Summary 8
1.1 Design Philosophy 8
2. Cluster Overview 9
2.1 Hardware Specifications 9
2.2 Infrastructure Summary 9
3. Machine-1 10
3.1 Architecture Overview 10
3.2 Network Topology 11
3.4 Zone Summary 11
4. Network Layer Components 12
4.1 Edge Router — VyOS 12
4.1.1 Interface Configuration 12
4.1.2 Configuration Details 12
4.1.3 NAT & Routing + Verification 13
4.2 FortiGate VM — Next-Generation Firewall 14
4.2.1 System Settings 14
4.2.2 Network Interfaces 15
4.2.3 DNS Configuration 15
4.2.4 Static Routes 16
4.2.5 Administration Security Hardening 16
4.2.6 Network Zones 17
4.2.7 Virtual IPs (Port Forwarding) 18
4.2.8 IPS Profile 19
4.2.9 SSL/TLS Deep Inspection 20
4.2.10 Web Filter Profile 21
4.2.11 NTP Setup 23
4.2.12 Firewall Policies 24
4.3 Suricata Inline — IPS 25
4.3.1 Service Status 25
4.3.2 Build Capabilities 25
4.3.3 Log Verification 25
4.4 DMZ-Switch1 — Layer 2 Bridge 26
4.4.1 Bridge Configuration 26
4.5 Distribution Switch & Management Switch 27
4.5.1 Bridge Interface — br0 27

5. Security & Monitoring Layer 29
5.1 Pi-hole — DNS Security 29
5.1.1 Service Status 29
5.1.2 DNS Listener Status 29
5.1.3 API Verification 30
5.2 Zeek + RITA — Network Security Monitoring 31
5.2.1 Zeek Service Status 31
5.2.2 RITA Database 31
5.2.3 Supporting Services 31
5.3 Arkime — Full Packet Capture 32
5.3.1 Service Status 32
5.4 Traefik + Squid — Reverse & Forward Proxy 33
5.4.1 Traefik Logs 33
5.4.2 Port Listeners 33
5.4.3 Squid Logs 34
6. DMZ Services 35
6.1 NGINX Server — Web Server & Reverse Proxy 35
6.1.1 Service Status 35
6.1.2 Configuration Validation 35
6.1.3 Port Listeners 35
6.1.4 HTTP Response Verification 36
6.2 MailCow — Dockerized Email Solution 37
6.2.1 HTTPS Verification 37
6.2.2 Mail Ports 38
6.2.3 Docker Containers 38
7. Network Zones & Traffic Flow 39
7.1 Zone Definitions 39
7.2 Traffic Flow — WAN to DMZ 39
7.3 DNS Traffic Flow 39
7.4 Monitoring Traffic Flow 39
8. Firewall Policies Summary 40
8.1 Address Objects 40
9. Integration with Other Machines 41
9.1 M1 → M2 (Identity & PKI Plane) 41
9.2 M1 → M3 (Intelligence & SOAR Plane) 41
9.3 M1 → M4 (Deception & Honeypot Plane) 41

9.4 M1 → M5 (Endpoint Protection & Hardening Plane) 41
Machine-2 42
Architecture Overview 42
1. Executive Summary 43
1.1 Role of M2 in Zero Trust Architecture 43
1.2 How M2 Connects to All Other Machines 43
2. M2 Architecture Overview 44
2.1 M2 Identity & PKI Plane — System Architecture 44
2.2 Identity & Authentication Flow 45
2.3 PKI & Secrets Management Flow 46
3. Technology Stack Overview 47
4. VM 1 — Directory-M2 48
4.1 Role & Purpose 48
4.2 System Information 48
4.3 Consul Service Mesh — Members 49
5. VM 2 — PKI-Secrets-M2 50
5.1 Role & Purpose 50
5.2 Smallstep CA (Step-CA) — Service Status 50
5.3 HashiCorp Vault — Status 50
5.4 EJBCA & Conjur — Docker Containers 51
6. VM 3 — Identity-Core-M2 52
6.1 Role & Purpose 52
6.2 OpenLDAP (slapd) — Service Status 52
6.3 Keycloak Identity Provider — Service Status 52
6.4 Keycloak Admin UI — zerotrust Realm 53
6.5 Keycloak Users — zerotrust Realm 53
7. VM 4 — ZeroTrust-M2 (Teleport) 54
7.1 Role & Purpose 54
7.2 Teleport — Service Status 54
8. VM 5 — BloodHound-M2 55
8.1 Role & Purpose 55
8.2 BloodHound CE — Docker Containers & Service Status 55
8.3 Neo4j Browser — Graph Database 56
9. Consul Service Mesh — Full Overview 56
9.1 Consul Nodes Dashboard 56
9.2 Consul Services Dashboard 57

9.3 Consul Node Detail — BloodHound-M2 58
10. Hardening & Verification 59
10.1 Full Lab Connectivity Test 59
10.2 Hardening Measures Implemented 60
11. M2 Integration with Other Machines 61
11.1 M2 Integration Table 61
11.2 How M2 Feeds Into M3 (Intelligence & SOAR Plane) 61
11.3 How M2 Controls M1 Network Access 61
12. Data Flow Summary 62
12.1 Authentication Flow 62
12.2 PKI / Certificate Flow 62
12.3 Secrets Flow 62
13. Appendix — Quick Reference 63
13.1 All M2 Service Endpoints 63
13.2 VM IP Reference 63
Machine-3 64
Architecture Overview 64
1. Machine 3 — Executive Summary 65
1.1 Executive Summary 65
1.2 Why M3 Requires 32 GB RAM 65
1.3 Full Log Pipeline 66
1.4 Outcome 66
2. M3 Architecture Overview 67
2.1 M3 Intelligence Plane — Overall Architecture 67
2.2 SIEM Stack — Wazuh · Kafka · OpenSearch 68
2.3 CTI-M3 Components — TheHive · Cortex · Shuffle · OpenCTI · SpiderFoot 69
3. Log Ingestion Flow 70
3.1 Overview 70
3.2 Stage 1 — Raw Log Sources 70
3.3 Stage 2 — Kafka Stream Ingestion (48 Topics) 70
3.4 Stage 3 — Logstash Processing (3 Pipelines) 71
3.5 Stages 4 & 5 — OpenSearch Storage and Visualization 72
4. Virtual Machine Sections 73
4.1 SIEM-M3 — 192.168.35.133 73
4.1.1 Role & Purpose 73
4.1.2 Wazuh Agent Management 73

4.1.3 Custom Detection Rules 74
4.1.4 Alert Escalation Logic 75
4.2 MONITOR-M3 76
4.2.1 Role & Purpose 76
4.2.2 Components 76
4.3 CTI-M3 — 192.168.35.134 77
4.3.1 Role & Purpose 77
4.3.2 A. MISP — Threat Intelligence Sharing Platform 77
4.3.3 B. IntelOwl — Threat Intelligence Enrichment 82
4.3.4 C. SpiderFoot — Automated OSINT Engine 85
4.3.5 D. TheHive — Security Incident Response & Case Management 86
4.3.6 E. Cortex — Automated Analysis & Response Engine 89
4.3.7 F. Shuffle SOAR — Security Orchestration, Automation & Response 91
Shuffle SOAR PlayBook Workflow 94
4.3.8 G. Dark Web CTI Tool — Custom LLM-Powered OSINT 95
5. Threat Intelligence Pipeline 99
5.1 Stage 1 — Data Sources 99
5.2 Stage 2 — Enrichment 100
5.3 Stage 3 — Action & Response 100
6. Shuffle SOAR — Automated Playbook Workflows 101
6.1 Workflow 1 — Wazuh Critical Alert → FortiGate IP Block 101
6.2 Workflow 2 — Critical Alert → TheHive Case Auto-Creation 101
6.3 Workflow 3 — Honeypot Alert → Multi-Layer Block 101
6.4 Workflow 4 — MISP IOC → Pi-hole DNS Block 101
6.5 Response Performance 101
7. M3 Integration with Other Machines 102
7.1 Integration with M1 — Core Network & Security Plane 102
7.2 Integration with M2 — Identity & PKI Plane 102
7.3 Integration with M4 — Deception & Honeypot Plane 102
7.4 Integration with M5 — Endpoint Protection & Hardening Plane 102
8. Wazuh Custom Rules & Decoders 103
8.1 Custom Detection Rules 103
9. Technology Stack Summary 104
9.1 VM 1 — SIEM-M3 (192.168.35.133) 104
9.2 VM 2 — MONITOR-M3 (192.168.35.136) 104
9.3 VM 3 — CTI-M3 (192.168.35.134) 104

9.4 Cross-VM Networking 105
Machine-4 106
Architecture Overview 106
Why Deception Matters 106
1. Executive Summary 107
Integration with Other Machines 107
2. M4 Deception Plane Overview 107
Traffic Flow Explained 108
Key Architectural Properties 108
3. Honeypot Tools Overview (15+ Tools) 109
4. Virtual Machine Configurations 110
4.1 VM 1 — T-Pot (100.102.218.16) 110
4.2 VM 2 — OpenCanary-M4 (100.127.230.65) 110
Role & Purpose 110
Network Interface Configuration — ip a Output 111
Interface Details Extracted 112
4.3 VM 3 — Deception-M4 (100.105.107.37) 112
4.4 VM 4 — Tor-Honeypot-M4 (100.112.32.96) 112
Network Interface Configuration — ip a Output 113
Tor Honeypot — Live Capture Demonstration 114
Extracted Log Entries 115
5. Wazuh Integration — M4 Agents 116
Complete Agent Registry 116
Dashboard Summary Statistics 116
6. Honeypot Log Pipeline 117
Kafka Topics for Honeypot Logs 117
Wazuh Custom Rules for Honeypot Detection 117
7. Automated Response Integration 117
Shuffle SOAR Workflow — Honeypot Alert Triggered 117
8. M4 Integration with Other Machines 118
9. Deception Strategy & Key Achievements 118
Machine-4 119
Architecture Overview 119
1. Executive Summary 120
2. M5 Architecture Overview 121
Dual-Purpose Design Philosophy 121

3. Red Team — Kali Linux Attack Machine 122
Attack Tool Categories 122
4. Blue Team — Victim Endpoint Configuration 122
Key Security Controls Summary 122
5. Full Kill Chain Detection — Proof of Concept 123
Stage 1 — Reconnaissance (DETECTED) 123
Stage 2 — Initial Access (DETECTED) 123
Stage 3 — Credential Attack (DETECTED) 123
Stage 4 — Lateral Movement (DETECTED) 123
Stage 5 — Privilege Escalation (DETECTED) 123
Stage 6 — Exfiltration (DETECTED) 124
6. M5 Full Integration Map 125
M5 Integration Details 125
7. Zero Trust Principles in Practice 126
The Six Zero Trust Principles 127
Implementation Pillars 127
8. Zero Trust Principles Applied to M5 127
9. Final Zero Trust UTM Lab Summary 128
Complete Technology Stack 128
Cluster Hardware Summary 128

1. Executive Summary

The Zero Trust UTM project is an enterprise-grade, multi-machine cybersecurity infrastructure built on the Zero Trust principle: "Never Trust, Always Verify, Always Monitor, Always Respond." The project is deployed across a cluster of 5 physical laptops operating as a cohesive, segmented network with advanced threat detection, identity verification, deception technologies, and endpoint hardening.

1.1 Design Philosophy

- Zero Trust Architecture: No implicit trust for any host, user, or service regardless of network location.
- Defense in Depth: Multiple overlapping security layers — edge routing, NGFW, inline IPS, internal firewall, DNS filtering, and endpoint controls.
- Full Visibility: Every packet traversing the network is logged, captured, or inspected by at least one security tool.
- Automated Response: SOAR integration (M3) enables automated responses to detected threats.
- Segmentation: Strict zone-based segmentation with DMZ, internal LAN, and management VLANs.

2. Cluster Overview

The Zero Trust UTM cluster consists of 5 physical laptops interconnected via Tailscale VPN mesh, providing encrypted overlay networking between all machines regardless of physical topology.

2.1 Hardware Specifications

- Total Machines: 5 laptops
- Total RAM: 104 GB combined
- Total Physical Cores: 60 (12 per machine)
- Total Logical Processors: 30 (6 per machine)
- Interconnect: Tailscale VPN mesh — M1 acts as the hub

2.2 Infrastructure Summary

Machine	RAM	Role	Key Services
M1	24 GB	Core Network & Security Plane	VyOS, FortiGate, Suricata, Pi-hole, Zeek, Arkime
M2	16 GB	Identity & PKI Plane	Certificate Authority, LDAP/AD, Identity Provider
M3	32 GB	Intelligence & SOAR Plane	SIEM, SOAR, Threat Intelligence
M4	16 GB	Deception & Honeypot Plane	Honeypots, Deception Tokens, Canaries
M5	16 GB	Endpoint Protection & Hardening	EDR, Hardening Scripts, Compliance

M1

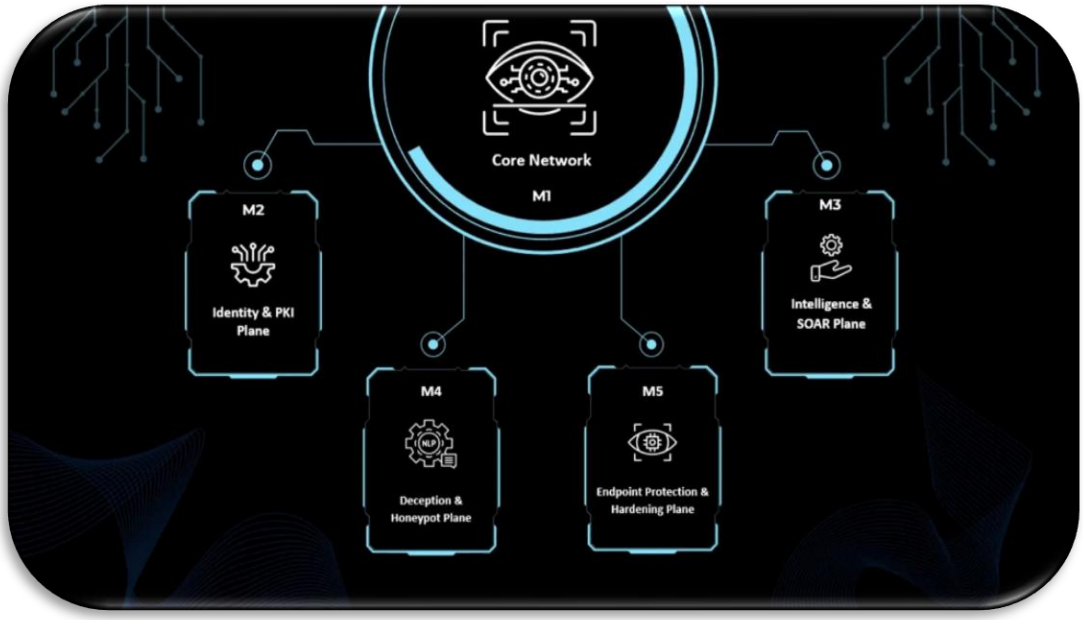
Core Network & Security Plane

3.Machine-1

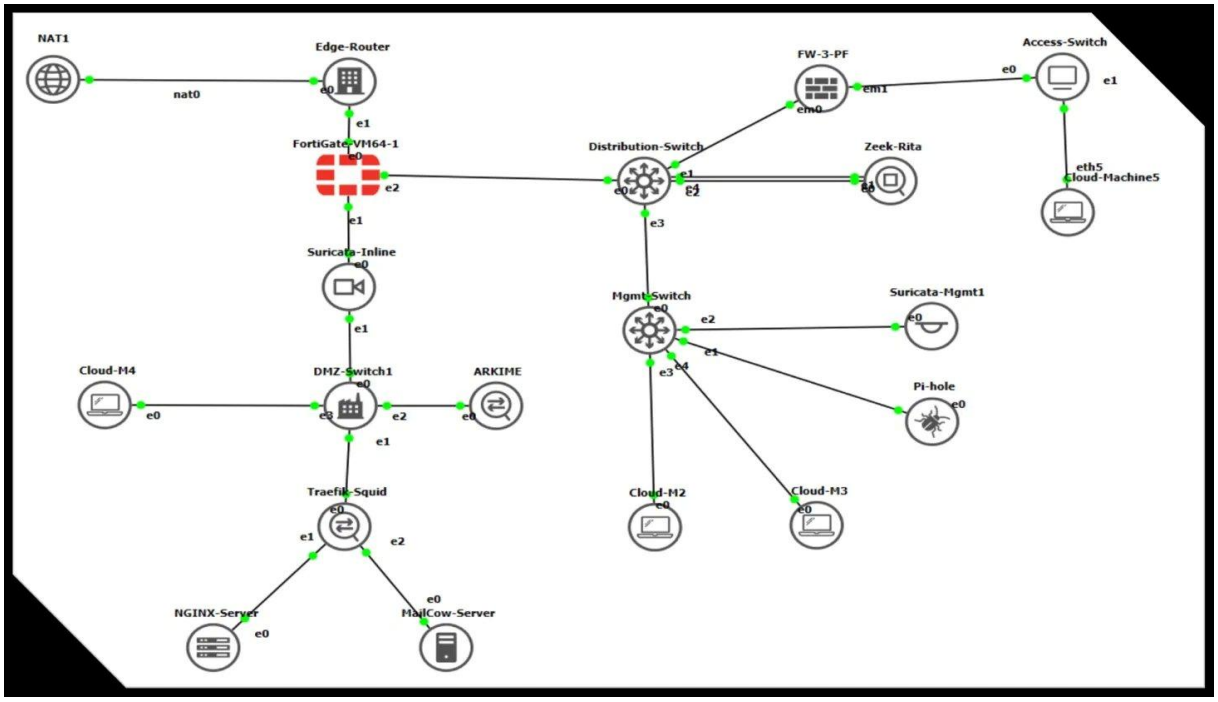
3.1 Architecture Overview

Machine 1 is the heart of the Zero Trust UTM infrastructure. It runs the complete network security stack: from edge routing and next-generation firewall capabilities through inline IPS, DNS filtering, full packet capture, and DMZ-hosted services. All other machines (M2–M5) depend on M1 for network connectivity, DNS resolution, and perimeter security enforcement.

Machine 1 (M1), which serves as the Core Network and Security Plane — the hub and backbone of the entire infrastructure. M1 hosts all perimeter security controls, network segmentation, traffic inspection, DNS security, full packet capture, and DMZ services.



3.2 Network Topology



3.4 Zone Summary

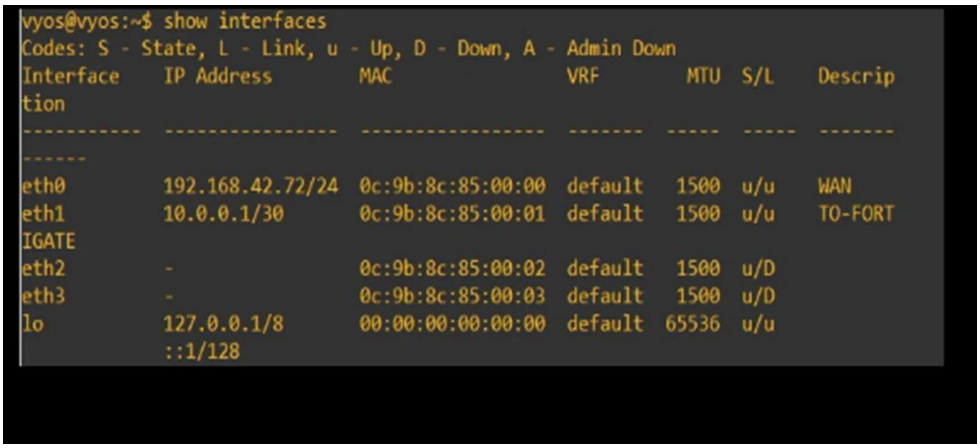
Zone	FortiGate Zone Name	Interface	Purpose
WAN	WAN-ZONE	port1 — 192.168.20.130/24	Internet-facing, block intra-zone
DMZ	DMZ-ZONE	port2 — 10.10.1.1/24	Suricata + public-facing servers
Internal LAN	INTERNAL-ZONE	port3 — 10.10.2.1/24	Internal infrastructure & segmentation

4. Network Layer Components

4.1 Edge Router — VyOS

The VyOS edge router serves as the WAN gateway for the entire Zero Trust UTM infrastructure. It handles NAT (Network Address Translation) for outbound internet access, static routing toward the FortiGate firewall, and acts as the first hop for all traffic entering and leaving the network. VyOS provides a Linux-based, production-grade routing platform deployed as a GNS3 virtual machine.

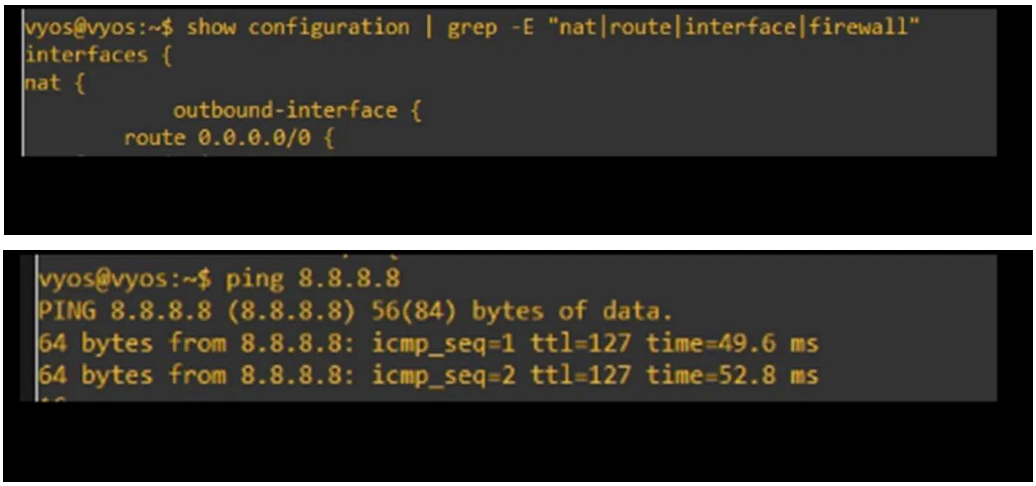
4.1.1 Interface Configuration



4.1.2 Configuration Details

WAN Interface: eth0 — IP: 192.168.42.72/24 — State: Up/Up
FortiGate Link: eth1 — IP: 10.0.0.1/30 — Description: TO-FORTIGATE — State: Up/Up
eth2: No IP assigned — State: Up/Down
eth3: No IP assigned — State: Up/Down
Loopback: 127.0.0.1/8 and ::1/128 — State: Up/Up
MTU: 1500 on all Ethernet interfaces; 65536 on loopback

4.1.3 NAT & Routing + Verification

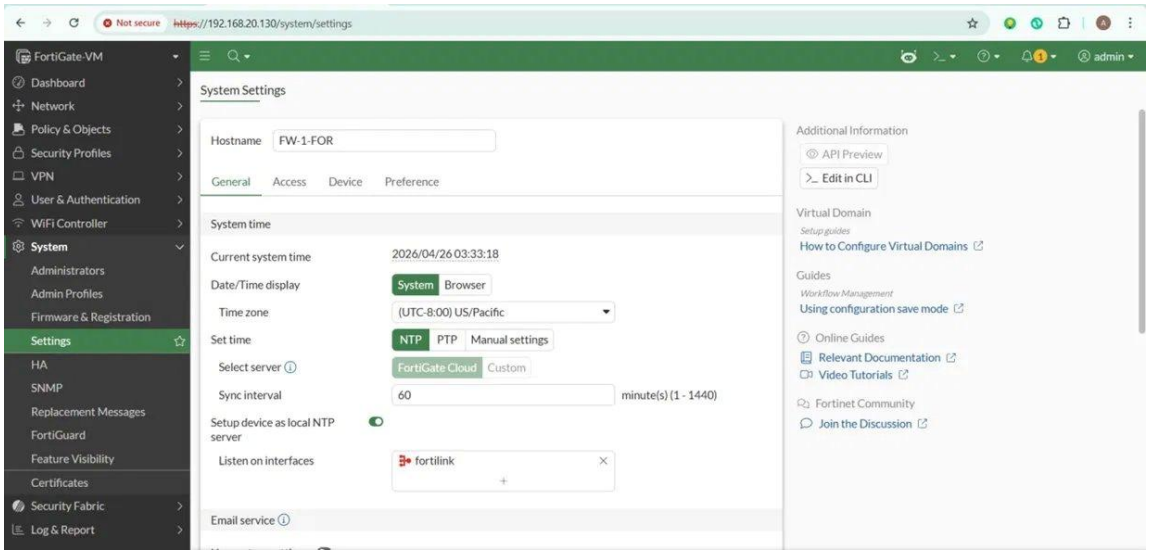


The VyOS router confirms successful NAT and outbound internet connectivity with round-trip times of approximately 49–53 ms to Google DNS (8.8.8.8), with TTL of 127 indicating one hop through the NAT device.

4.2 FortiGate VM — Next-Generation Firewall

FortiGate VM64 is the primary Next-Generation Firewall (NGFW) for the Zero Trust UTM lab. It provides stateful packet inspection, intrusion prevention, SSL/TLS deep inspection, web filtering, application control, VIP-based port forwarding, and zone-based policy enforcement. FortiGate is positioned between the VyOS edge router and the internal network/DMZ, providing the primary perimeter security layer.

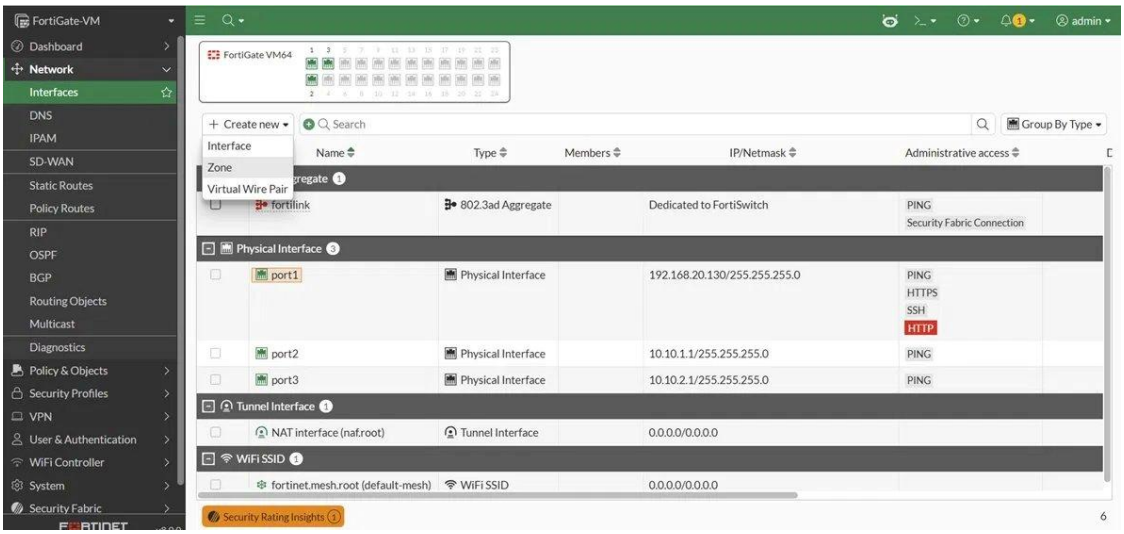
4.2.1 System Settings



KEY COMPONENTS:

Hostname: FW-1-FOR
System Time: 2026/04/26 03:33:18
Time Zone: (UTC-8:00) US/Pacific
NTP Source: FortiGate Cloud
NTP Sync Interval: 60 minutes
Local NTP Server: Enabled — listening on fortilink

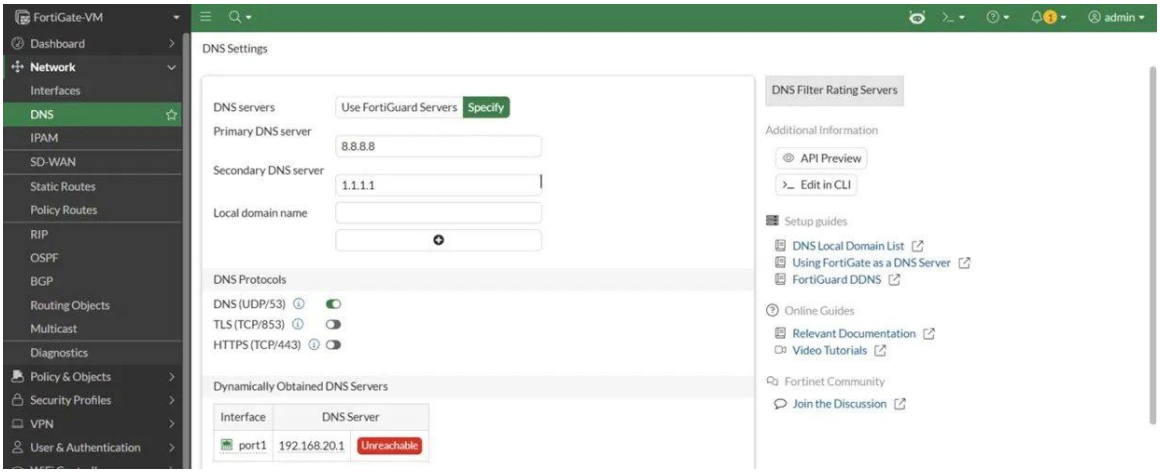
4.2.2 Network Interfaces



KEY COMPONENTS:

port1 (WAN Zone): 192.168.20.130/255.255.255.0 — Admin: PING, HTTPS, SSH, HTTP
port2 (DMZ Zone): 10.10.1.1/255.255.255.0 — Admin: PING
port3 (Internal Zone): 10.10.2.1/255.255.255.0 — Admin: PING
NAT Interface: naf.root — 0.0.0.0/0.0.0.0

4.2.3 DNS Configuration



KEY COMPONENTS:

Primary DNS: 8.8.8.8 (Google)
Secondary DNS: 1.1.1.1 (Cloudflare)
DNS UDP/53: Enabled
DNS TLS/853: Disabled
DNS HTTPS/443: Disabled
Dynamic DNS (port1): 192.168.20.1 — Unreachable

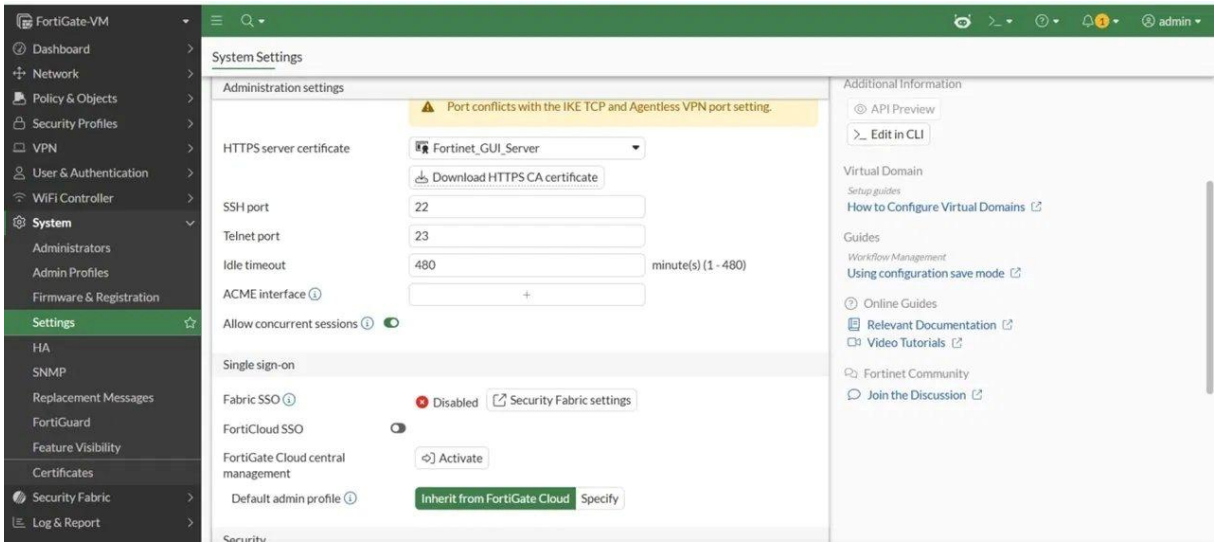
4.2.4 Static Routes



KEY COMPONENTS:

Default Route: 0.0.0.0/0 via 10.0.0.1 on port1 — Status: Enabled

4.2.5 Administration Security Hardening



KEY COMPONENTS:

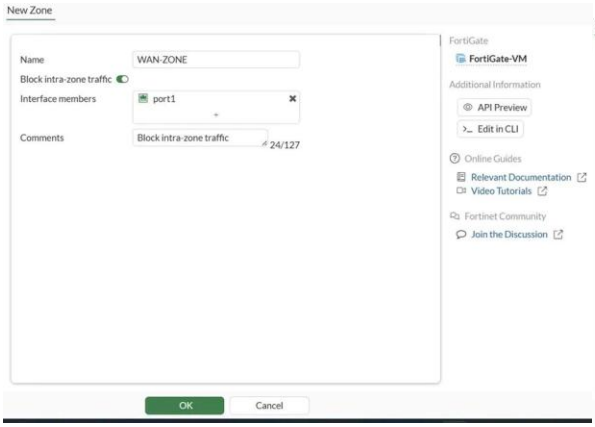
Admin HTTPS Port: 8443 (redirect from HTTP 8080)

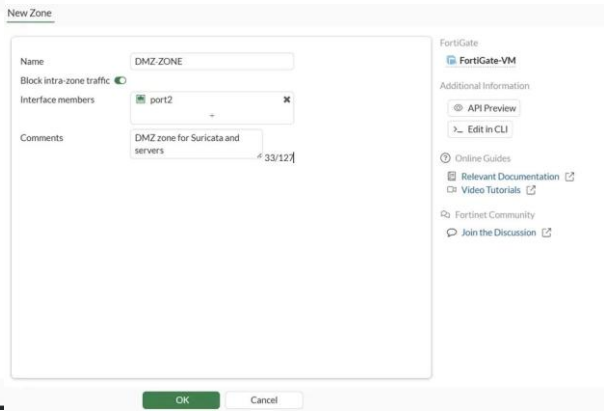
Admin SSH Port: 2222

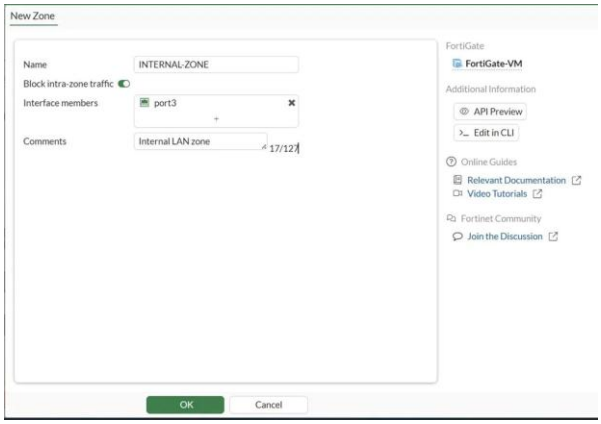
Idle Timeout: 10 minutes

Concurrent Sessions: Disabled

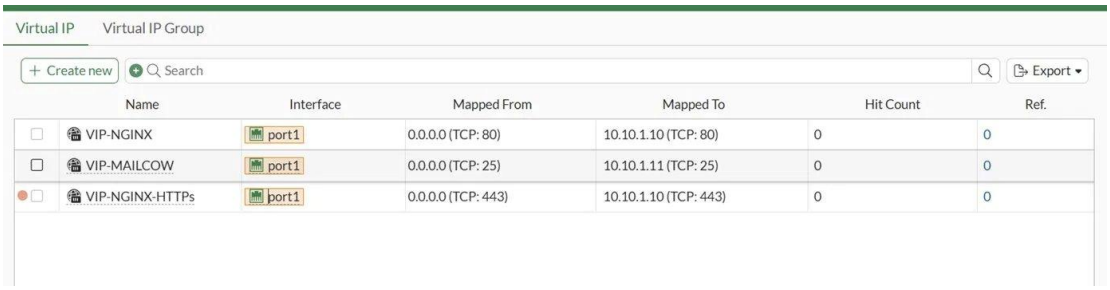
4.2.6 Network Zones

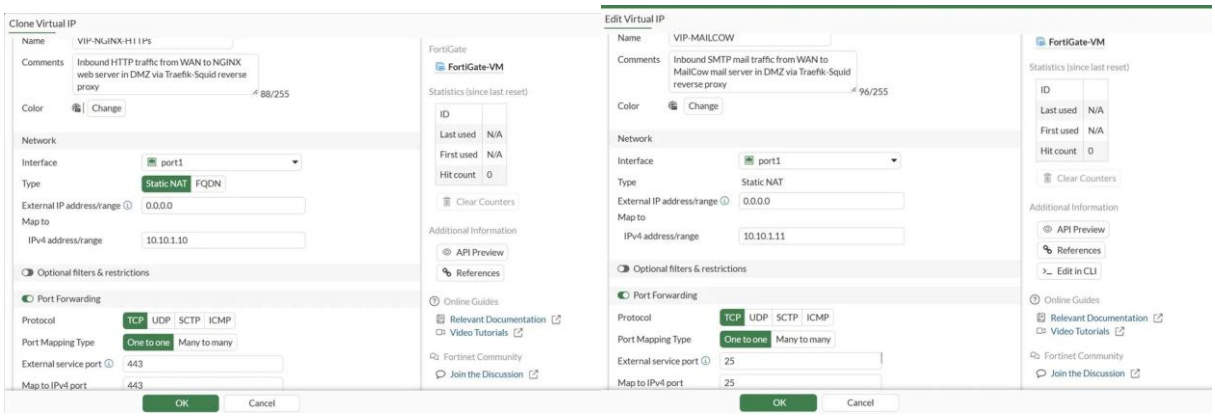






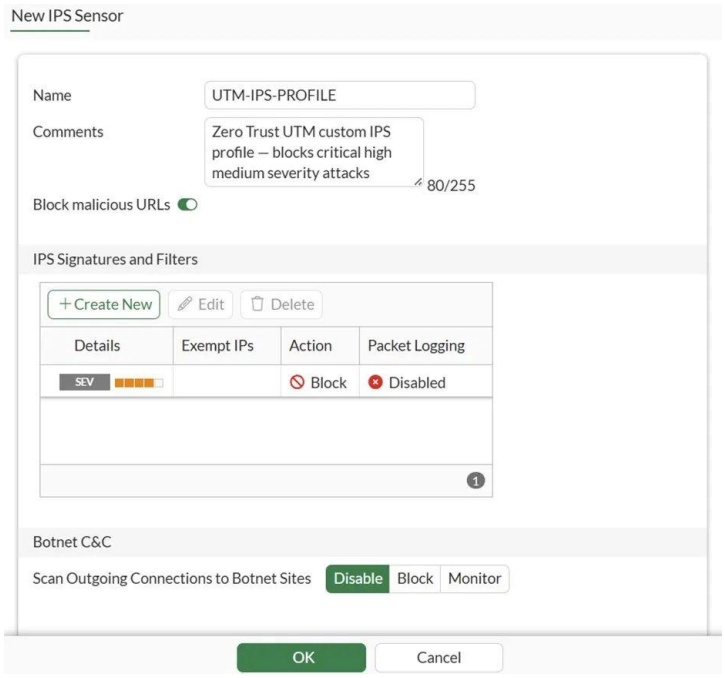
4.2.7 Virtual IPs (Port Forwarding)

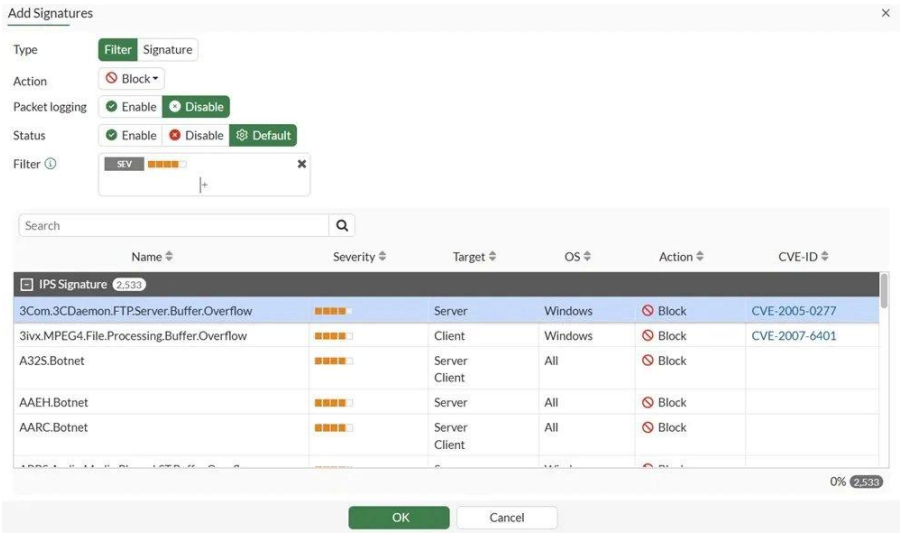




VIP Name	Interface	External	Internal	Purpose
VIP-NGINX	port1	0.0.0.0:80	10.10.1.10:80	HTTP to NGINX web server
VIP-NGINX-HTTPs	port1	0.0.0.0:443	10.10.1.10:443	HTTPS to NGINX via Traefik-Squid
VIP-MAILCOW	port1	0.0.0.0:25	10.10.1.11:25	SMTP to MailCow via Traefik-Squid

4.2.8 IPS Profile

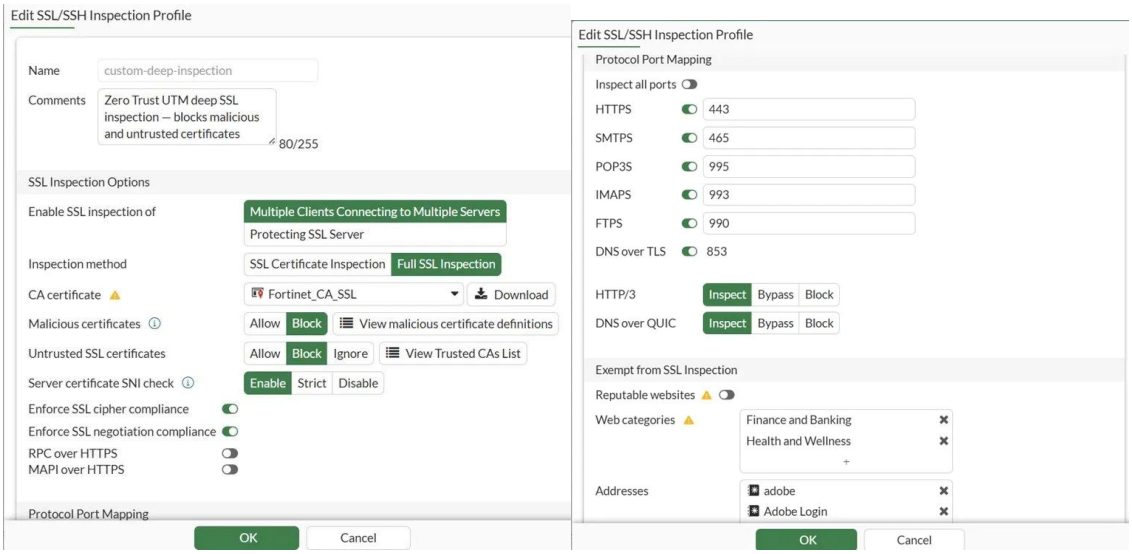


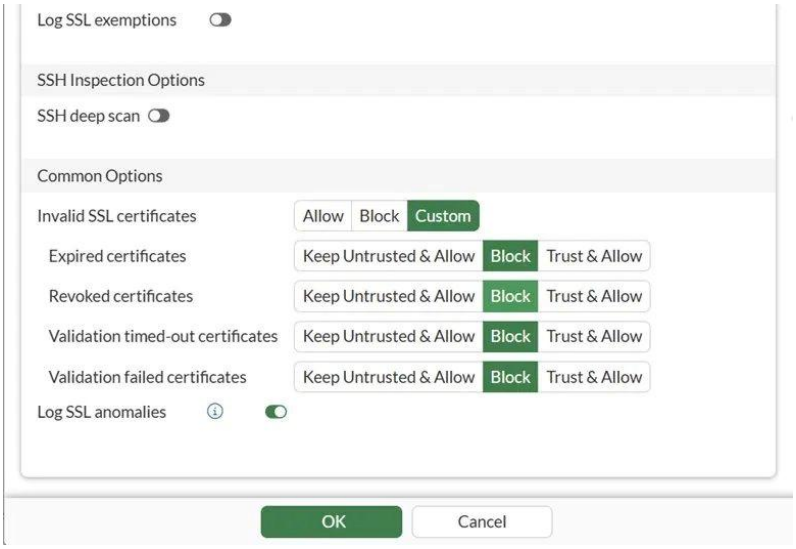


KEY COMPONENTS:

IPS Profile Name: UTM-IPS-PROFILE
Action: Block — critical/high/medium severity attacks
Block Malicious URLs: Enabled
Total Signatures: 2,533
Botnet C&C Scan: Disabled (configured separately)

4.2.9 SSL/TLS Deep Inspection

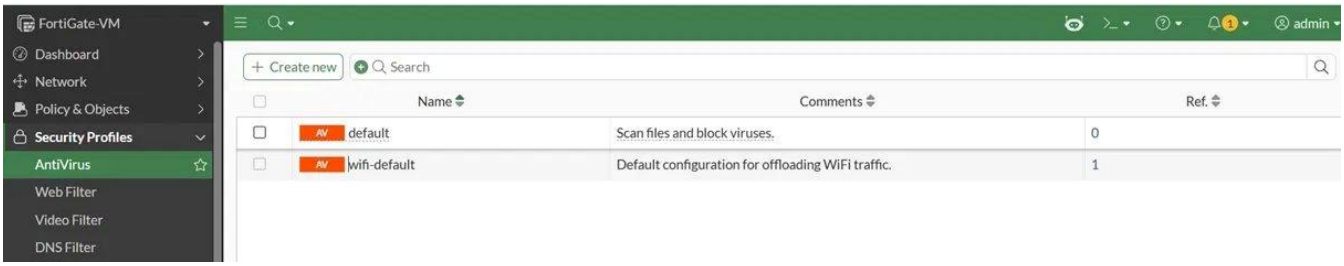


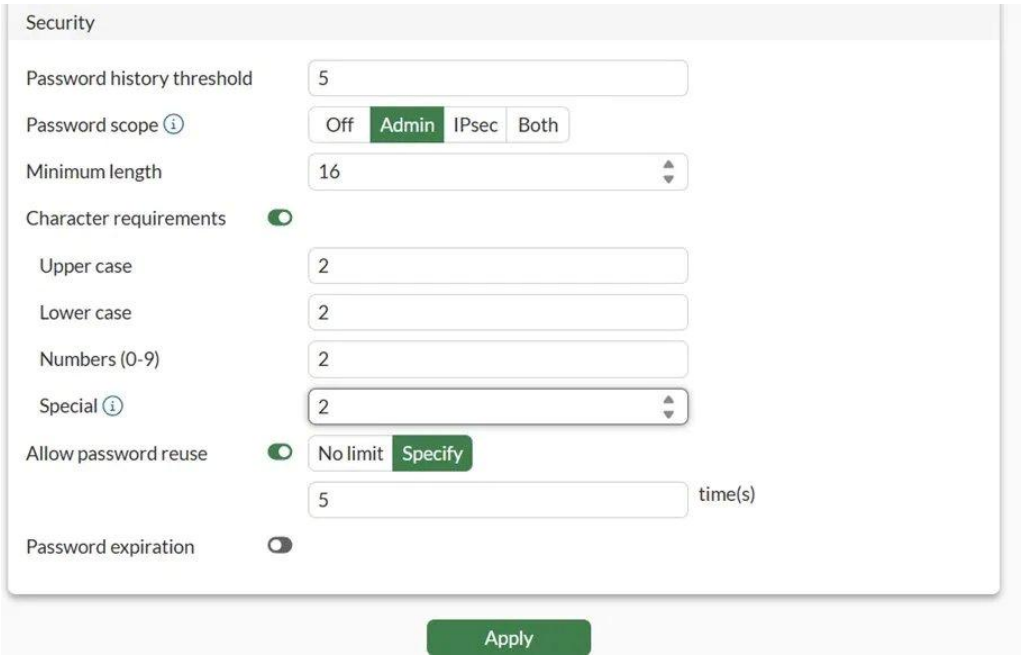


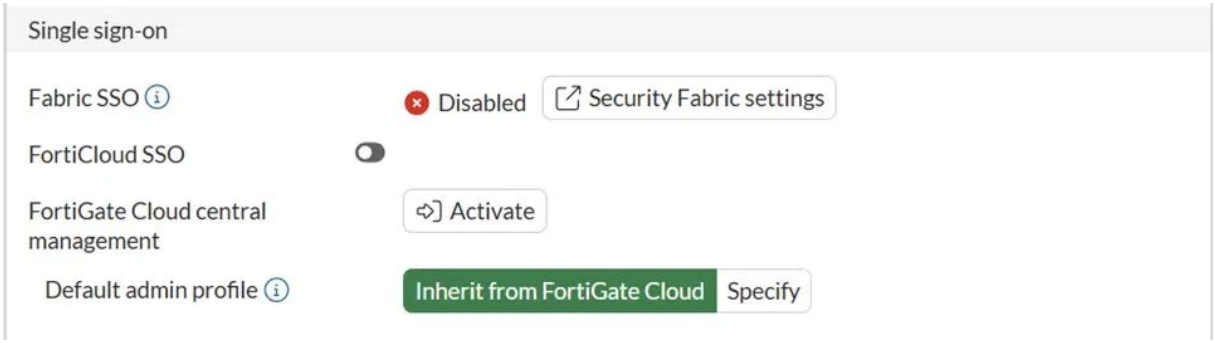
KEY COMPONENTS:

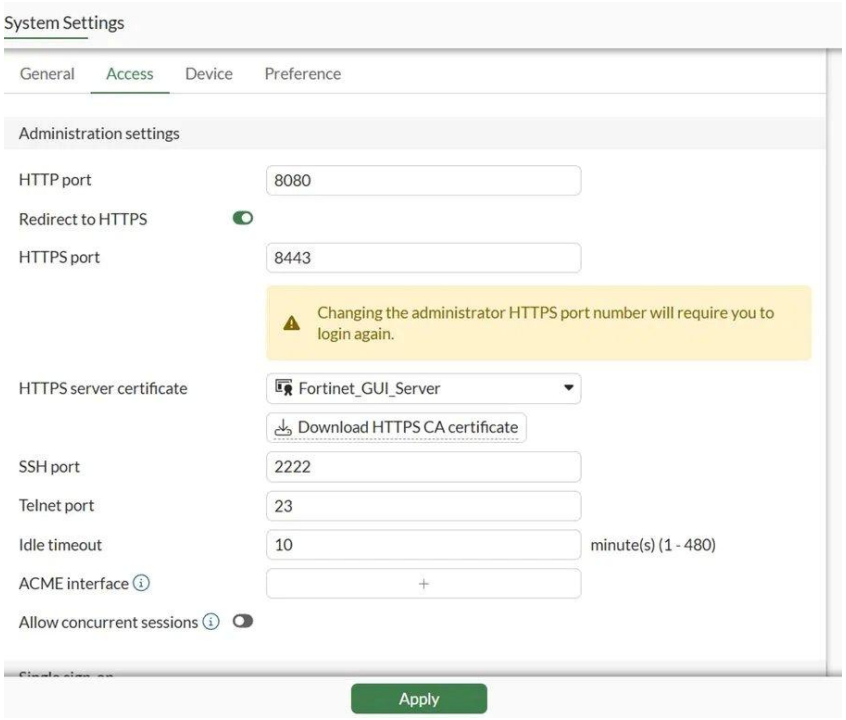
Profile Name: custom-deep-inspection
Inspection Mode: Full SSL Inspection — Multiple Clients to Multiple Servers
CA Certificate: Fortinet_CA_SSL
Malicious Certs: Block
Untrusted Certs: Block
Expired Certs: Block
Revoked Certs: Block
Validation Timeout: Block
SSL Anomaly Logging: Enabled
HTTPS Port: 443 | SMTPS: 465 | POP3S: 995 | IMAPS: 993 | FTPS: 990 | DoT: 853

4.2.10 Web Filter Profile





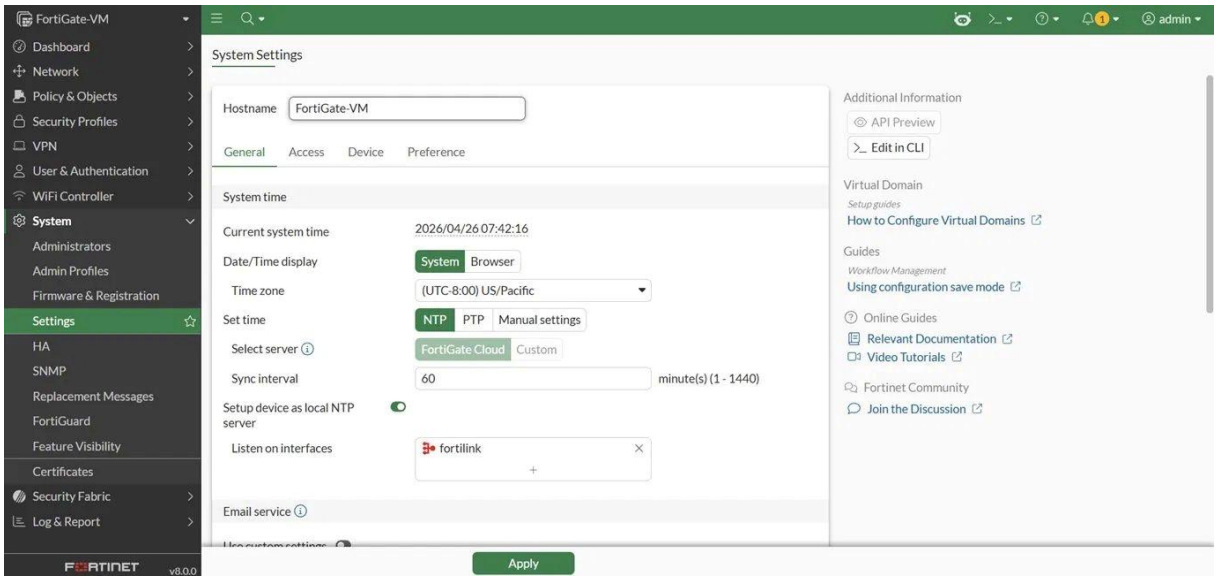




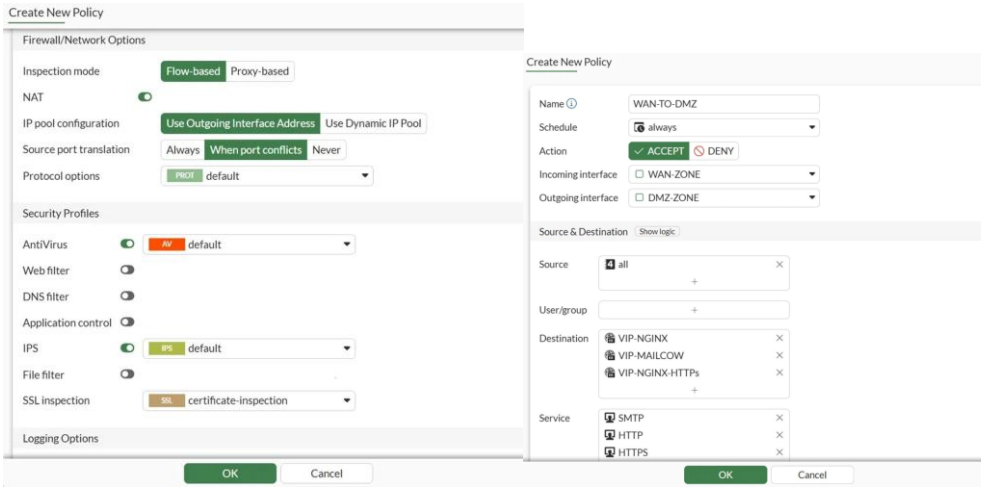
KEY COMPONENTS:

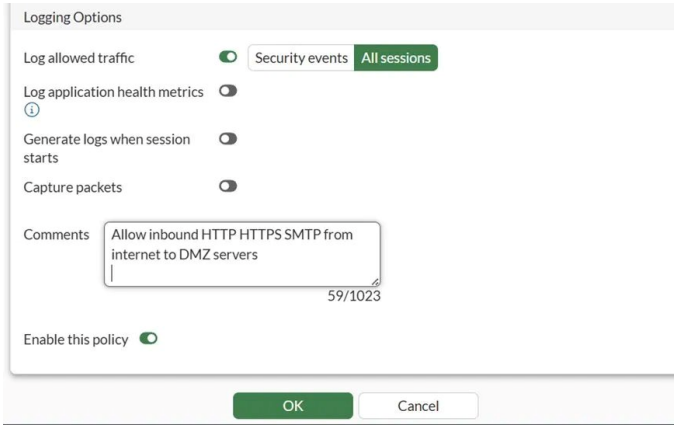
Web Filter Mode: Flow-based
Safe Search: Enforced on Google, Yahoo, Bing, Yandex
YouTube Restriction: Moderate
Proxy Avoidance: Block
Hacking Category: Block
When FortiGuard Unreachable: Block all websites
Cookie Removal: Enabled

4.2.11 NTP Setup



4.2.12 Firewall Policies





KEY COMPONENTS:

Policy Name: WAN-TO-DMZ
Direction: WAN-ZONE → DMZ-ZONE
Action: ACCEPT
Source: all
Destination: VIP-NGINX (80), VIP-MAILCOW (25), VIP-NGINX-HTTPs (443)
Services: SMTP, HTTP, HTTPS
Inspection Mode: Flow-based
NAT: Enabled — Use Outgoing Interface Address
AntiVirus: default profile
IPS: default profile
SSL Inspection: certificate-inspection
Logging: All sessions

4.3 Suricata Inline — IPS

Suricata is deployed in inline IPS (Intrusion Prevention System) mode between the FortiGate DMZ interface and the DMZ switch. It performs deep packet inspection on all traffic transiting the DMZ, providing real-time threat detection and blocking. Suricata operates in AF_PACKET mode with hardware offload support, enabling high-throughput packet processing.

4.3.1 Service Status

```
ubuntu@ubuntu-cloud:~$ sudo systemctl status suricata
o suricata.service - Suricata IPS
     Loaded: loaded (/etc/systemd/system/suricata.service; disabled; preset: en
     Active: inactive (dead)
```

4.3.2 Build Capabilities

```
ubuntu@ubuntu-cloud:~$ sudo suricata --build-info | grep -E "AF_PACKET|INLINE"
Features: PCAP_SET_BUFF AF_PACKET HAVE_PACKET_FANOUT HAVE_HTP_URI_NORMALIZE_HOOK
 PCRE_JIT HAVE_NSS HTTP2_DECOMPRESSION HAVE_JA3 HAVE_JA4 HAVE_LIBJANSSON TLS TLS
_C11 MAGIC RUST POPCNT64
  AF_PACKET support:                       yes
```

KEY COMPONENTS:

AF_PACKET Support: Yes — confirmed by build-info

Features: PCAP_SET_BUFF, AF_PACKET, HAVE_PACKET_FANOUT, HTTP2_DECOMPRESSION, JA3, JA4, TLS

Service Status: Loaded (enabled) — inactive pending network configuration

4.3.3 Log Verification

```
ubuntu@ubuntu-cloud:~$ sudo tail -20 /var/log/suricata/suricata.log | grep -E "L
oaded|rules"
tail: cannot open '/var/log/suricata/suricata.log' for reading: No such file or
directory
```

Note: The absence of a log file confirms Suricata had not yet been started at the time of this capture. The service is installed and enabled, pending inline network interface assignment.

4.4 DMZ-Switch1 — Layer 2 Bridge

The DMZ-Switch1 is a Linux software bridge (dmz-br) providing Layer 2 connectivity between the Suricata inline IPS and the DMZ-zone servers (Traefik-Squid, NGINX, MailCow). It aggregates multiple virtual interfaces into a single broadcast domain for the DMZ segment.

4.4.1 Bridge Configuration

```
ubuntu@ubuntu-cloud:~$ sudo brctl show
bridge name     bridge id               STP enabled     interfaces
dmz-br          8000.22bf659d92af       no              ens3
                                                        ens4
                                                        ens5
                                                        ens6
```

```
ubuntu@ubuntu-cloud:~$ bridge link show
2: ens3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 master br0 state forwarding
priority 32 cost 2
3: ens4: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 master br0 state forwarding
priority 32 cost 2
4: ens5: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 master br0 state forwarding
priority 32 cost 2
5: ens6: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 master br0 state forwarding
priority 32 cost 2
6: ens7: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 master br0 state forwarding
priority 32 cost 2
ubuntu@ubuntu-cloud:~$ ip link show master br0
2: ens3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel master br0 st
ate UP mode DEFAULT group default qlen 1000
    link/ether 0c:ca:b6:10:00:00 brd ff:ff:ff:ff:ff:ff
    altname enp0s3
3: ens4: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel master br0 st
ate UP mode DEFAULT group default qlen 1000
    link/ether 0c:ca:b6:10:00:01 brd ff:ff:ff:ff:ff:ff
    altname enp0s4
4: ens5: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel master br0 st
ate UP mode DEFAULT group default qlen 1000
    link/ether 0c:ca:b6:10:00:02 brd ff:ff:ff:ff:ff:ff
    altname enp0s5
5: ens6: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel master br0 st
ate UP mode DEFAULT group default qlen 1000
    link/ether 0c:ca:b6:10:00:03 brd ff:ff:ff:ff:ff:ff
    altname enp0s6
6: ens7: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel master br0 st
ate UP mode DEFAULT group default qlen 1000
    link/ether 0c:ca:b6:10:00:04 brd ff:ff:ff:ff:ff:ff
    altname enp0s7
```

```
ubuntu@ubuntu-cloud:~$ ip link show | grep -E "ens|dmz-br"
2: ens3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel master dmz-br
 state UP mode DEFAULT group default qlen 1000
3: ens4: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel master dmz-br
 state UP mode DEFAULT group default qlen 1000
4: ens5: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel master dmz-br
 state UP mode DEFAULT group default qlen 1000
5: ens6: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel master dmz-br
 state UP mode DEFAULT group default qlen 1000
6: dmz-br: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP mod
e DEFAULT group default qlen 1000
```

KEY COMPONENTS:

Bridge Name: dmz-br

Bridge ID: 8000.22bf659d92af

STP: Disabled

Member Interfaces: ens3, ens4, ens5, ens6

Interface State: All forwarding, priority 32, cost 2

4.5 Distribution Switch & Management Switch

The Distribution Switch provides Layer 3 switching for the internal network segments, routing between internal VLANs and enabling connectivity to the FW-3-PF pfSense internal firewall.

4.5.1 Bridge Interface — br0

```
ubuntu@ubuntu-cloud:~$ bridge link show
2: ens3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 master br0 state forwarding
priority 32 cost 2
3: ens4: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 master br0 state forwarding
priority 32 cost 2
4: ens5: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 master br0 state forwarding
priority 32 cost 2
5: ens6: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 master br0 state forwarding
priority 32 cost 2
6: ens7: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 master br0 state forwarding
priority 32 cost 2
ubuntu@ubuntu-cloud:~$ ip link show master br0
2: ens3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel master br0 st
ate UP mode DEFAULT group default qlen 1000
    link/ether 0c:ca:b6:10:00:00 brd ff:ff:ff:ff:ff:ff
    altname enp0s3
3: ens4: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel master br0 st
ate UP mode DEFAULT group default qlen 1000
    link/ether 0c:ca:b6:10:00:01 brd ff:ff:ff:ff:ff:ff
    altname enp0s4
4: ens5: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel master br0 st
ate UP mode DEFAULT group default qlen 1000
    link/ether 0c:ca:b6:10:00:02 brd ff:ff:ff:ff:ff:ff
    altname enp0s5
5: ens6: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel master br0 st
ate UP mode DEFAULT group default qlen 1000
    link/ether 0c:ca:b6:10:00:03 brd ff:ff:ff:ff:ff:ff
    altname enp0s6
6: ens7: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel master br0 st
ate UP mode DEFAULT group default qlen 1000
    link/ether 0c:ca:b6:10:00:04 brd ff:ff:ff:ff:ff:ff
    altname enp0s7
```

```
ubuntu@ubuntu-cloud:~$ ip addr show br0
7: br0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group
default qlen 1000
    link/ether aa:bb:cc:dd:ee:03 brd ff:ff:ff:ff:ff:ff
    inet 10.10.2.3/24 brd 10.10.2.255 scope global br0
       valid_lft forever preferred_lft forever
    inet6 fe80::a8bb:ccff:fedd:ee03/64 scope link proto kernel_ll
       valid_lft forever preferred_lft forever
```

Distribution Switch Configuration

Management Switch

The Management Switch is a dedicated Layer 2 switch for the management VLAN, connecting management nodes (Cloud-M2, Cloud-M3, Cloud-M4), Pi-hole, and Suricata management interface.

```
ubuntu@ubuntu-cloud:~$ bridge link show
2: ens3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 master br0 state forwarding
priority 32 cost 2
3: ens4: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 master br0 state forwarding
priority 32 cost 2
4: ens5: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 master br0 state forwarding
priority 32 cost 2
5: ens6: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 master br0 state forwarding
priority 32 cost 2
ubuntu@ubuntu-cloud:~$ ip link show master br0
2: ens3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel master br0 st
ate UP mode DEFAULT group default qlen 1000
    link/ether 0c:c8:ae:40:00:00 brd ff:ff:ff:ff:ff:ff
    altname enp0s3
3: ens4: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel master br0 st
ate UP mode DEFAULT group default qlen 1000
    link/ether 0c:c8:ae:40:00:01 brd ff:ff:ff:ff:ff:ff
    altname enp0s4
4: ens5: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel master br0 st
ate UP mode DEFAULT group default qlen 1000
    link/ether 0c:c8:ae:40:00:02 brd ff:ff:ff:ff:ff:ff
    altname enp0s5
5: ens6: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel master br0 st
ate UP mode DEFAULT group default qlen 1000
    link/ether 0c:c8:ae:40:00:03 brd ff:ff:ff:ff:ff:ff
    altname enp0s6
ubuntu@ubuntu-cloud:~$ ip link show br0
12: br0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP mode
DEFAULT group default qlen 1000
    link/ether d2:c1:0a:c7:bb:b8 brd ff:ff:ff:ff:ff:ff
```

```
ubuntu@ubuntu-cloud:~$ bridge vlan show
port              vlan-id
ens3              1 PVID Egress Untagged
ens4              1 PVID Egress Untagged
ens5              1 PVID Egress Untagged
ens6              1 PVID Egress Untagged
br0               1 PVID Egress Untagged
```

```
ubuntu@ubuntu-cloud:~$ ip route
default via 10.10.2.1 dev br0 proto static
10.10.2.0/24 dev br0 proto kernel scope link src 10.10.2.2
```

KEY COMPONENTS:

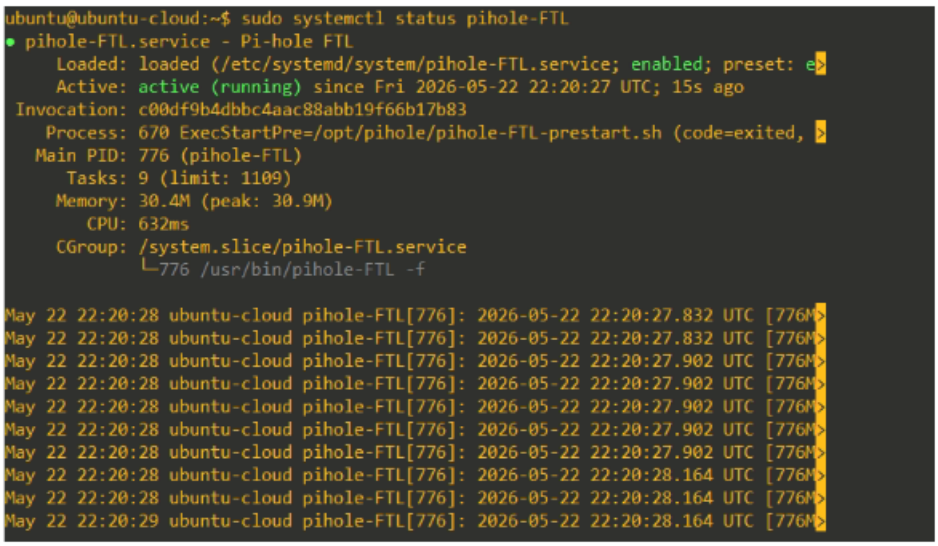
Bridge Interface: br0 — IP: 10.10.2.3/24
Default Gateway: 10.10.2.1 via br0
Subnet: 10.10.2.0/24
VLAN: VLAN 1 — all ports untagged
Interface Count: 5 (ens3–ens7 for Distribution, ens3–ens6 for Mgmt)

5. Security & Monitoring Layer

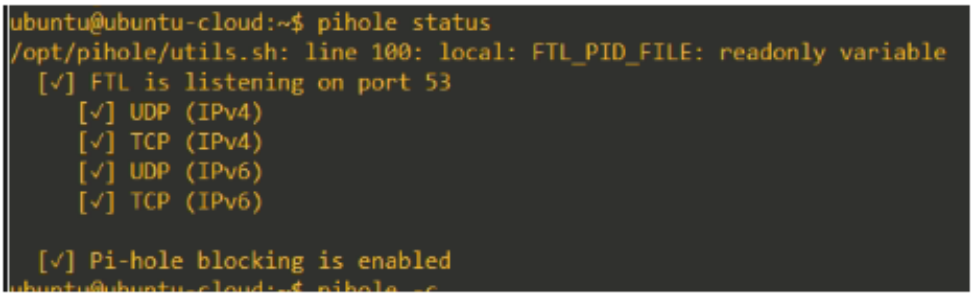
5.1 Pi-hole — DNS Security

Pi-hole acts as the recursive DNS resolver and DNS-based security filter for the entire Zero Trust UTM network. All DNS queries from internal clients are routed through Pi-hole, which blocks known malicious domains, ad networks, trackers, and malware command-and-control endpoints using community-maintained blocklists. Pi-hole is deployed on the Management Switch network at the management IP.

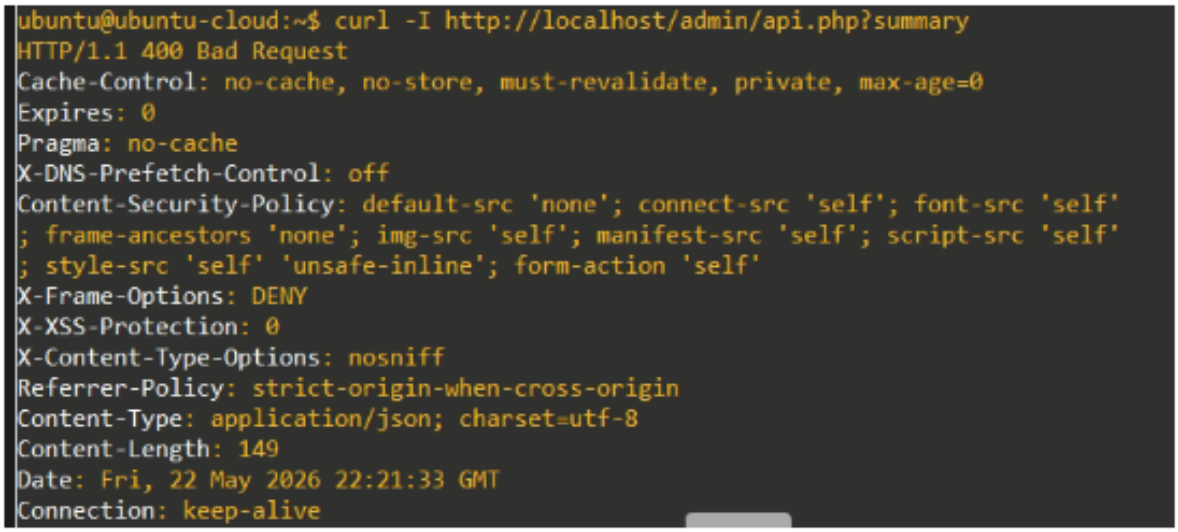
5.1.1 Service Status



5.1.2 DNS Listener Status



5.1.3 API Verification



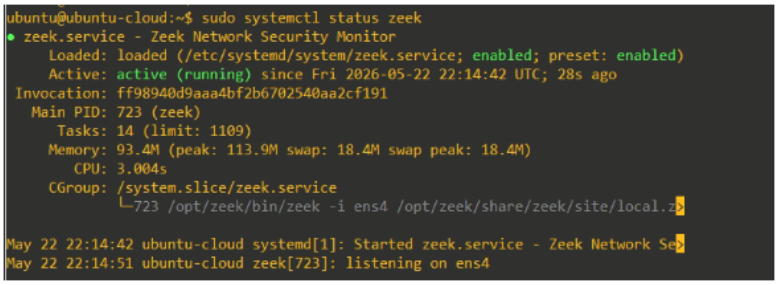
KEY COMPONENTS:

Service: pihole-FTL — active (running)
Start Time: Fri 2026-05-22 22:20:27 UTC
PID: 776
Memory Usage: 30.4 MB (peak 30.9 MB)
DNS Port: 53 — UDP and TCP on both IPv4 and IPv6
Blocking Status: Enabled
Security Headers: X-Frame-Options DENY, X-XSS-Protection 0, nosniff, strict-origin-when-cross-origin

5.2 Zeek + RITA — Network Security Monitoring

Zeek (formerly Bro) is a powerful network analysis framework that passively monitors network traffic and generates structured logs of all observed connections, protocols, files, and activities. RITA (Real Intelligence Threat Analytics) processes Zeek logs to identify beaconing behavior, DNS anomalies, long connections, and other indicators of compromise. Together they form the network behavioral analysis layer of the Zero Trust UTM.

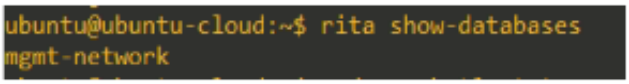
5.2.1 Zeek Service Status



KEY COMPONENTS:

Service: zeek — active (running)
Start Time: Fri 2026-05-22 22:14:42 UTC
PID: 723
Listening Interface: ens4
Config File: /opt/zeek/share/zeek/site/local.zeek (partially visible)
Memory: 93.4 MB (peak 113.9 MB)

5.2.2 RITA Database



RITA Database: mgmt-network

5.2.3 Supporting Services



KEY COMPONENTS:

MongoDB Service: active (running) — started same time as Zeek
MongoDB PID: 694
Config: /etc/mongod.conf
Memory: 135 MB (peak 257.8 MB)
Purpose: Backend database for RITA threat analytics

5.3 Arkime — Full Packet Capture

Arkime (formerly Moloch) provides full packet capture and indexing for the Zero Trust UTM network. Every packet traversing the monitored interface is captured in PCAP format and indexed via Elasticsearch, enabling forensic investigation of past network events. Arkime captures metadata and full packet data, accessible through its web viewer interface.

5.3.1 Service Status

```
ubuntu@ubuntu-cloud:~$ sudo systemctl status arkimecapture arkimeviewer elasticsearch
○ arkimecapture.service - Arkime Capture
     Loaded: loaded (/etc/systemd/system/arkimecapture.service; enabled; preset>
     Active: inactive (dead)

○ arkimeviewer.service - Arkime Viewer
     Loaded: loaded (/etc/systemd/system/arkimeviewer.service; enabled; preset:>
     Active: inactive (dead)

● elasticsearch.service - Elasticsearch
     Loaded: loaded (/usr/lib/systemd/system/elasticsearch.service; enabled; pr>
     Active: activating (start) since Fri 2026-05-22 21:53:34 UTC; 52s ago
 Invocation: 071b4bb2d8894c6eaea134a32e444fe8
       Docs: https://www.elastic.co
   Main PID: 672 (java)
      Tasks: 21 (limit: 1109)
     Memory: 615.8M (peak: 627M swap: 74.5M swap peak: 74.7M)
        CPU: 36.727s
     CGroup: /system.slice/elasticsearch.service
             └─672 /usr/share/elasticsearch/jdk/bin/java -Xshare:auto -Des.netw>

May 22 21:53:34 ubuntu-cloud systemd[1]: Starting elasticsearch.service - Elast>
lines 1-21/21 (END)
```

```
ubuntu@ubuntu-cloud:~$ ps aux | grep arkimecapture
ubuntu      1273 12.5  0.2   7156  2144 ttyS0    S+   21:54   0:00 grep --color=auto arkimecapture
ubuntu@ubuntu-cloud:~$
```

```
ubuntu@ubuntu-cloud:~$ tail -30 /opt/arkime/logs/capture.log | tail -15
May 22 21:54:54 db.c:2187 arkime_db_check(): ERROR - Couldn't load version information, database (http://localhost:9200) might be down or not initialized.
May 22 21:54:54 main.c:238 parse_args(): WARNING - glib compiled 2.78.3 vs linked 2.82.1
May 22 21:54:54 main.c:254 parse_args(): WARNING: gethostname doesn't return a fully qualified name and getdomainname failed, this may cause issues when viewing pcaps, use the --host option - ubuntu-cloud
May 22 21:54:55 http.c:276 arkime_http_send_sync(): Retry http://localhost:9200/_template/arkime_sessions3_template?filter_path=**._meta error 'Could not connect to server'
May 22 21:54:55 http.c:276 arkime_http_send_sync(): Retry http://localhost:9200/_template/arkime_sessions3_template?filter_path=**._meta error 'Could not connect to server'
May 22 21:54:55 http.c:276 arkime_http_send_sync(): Retry http://localhost:9200/_template/arkime_sessions3_template?filter_path=**._meta error 'Could not connect to server'
May 22 21:54:55 http.c:280 arkime_http_send_sync(): libcurl failure http://localhost:9200/_template/arkime_sessions3_template?filter_path=**._meta error 'Could not connect to server'
May 22 21:54:55 db.c:2187 arkime_db_check(): ERROR - Couldn't load version information, database (http://localhost:9200) might be down or not initialized.
May 22 21:54:55 main.c:238 parse_args(): WARNING - glib compiled 2.78.3 vs linked 2.82.1
```

KEY COMPONENTS:

Elasticsearch: Activating (starting) — PID 672, 615.8 MB RAM
Arkime Capture: Enabled but inactive (pending Elasticsearch ready)
Arkime Viewer: Enabled but inactive (pending Elasticsearch ready)
Capture Log Error: Cannot connect to Elasticsearch at localhost:9200 — starting up
Glib Version: Compiled 2.78.3 vs linked 2.82.1 (version mismatch warning)

5.4 Traefik + Squid — Reverse & Forward Proxy

Traefik serves as the reverse proxy and HTTP/HTTPS ingress controller for DMZ-hosted services, routing inbound requests to NGINX and MailCow based on hostname and path rules. Squid provides forward proxy capabilities for outbound HTTP traffic from internal clients, enabling content filtering, caching, and access logging. Both run as Docker containers within the DMZ.

5.4.1 Traefik Logs

```
ubuntu@ubuntu-cloud:~$ sudo docker logs traefik --tail 30 | tail -20
time="2026-05-17T09:17:37Z" level=error msg="accept tcp [::]:8080: use of closed
 network connection" entryPointName=traefik
time="2026-05-17T09:17:37Z" level=error msg="accept tcp [::]:443: use of closed
network connection" entryPointName=websecure
time="2026-05-17T09:17:37Z" level=error msg="close tcp [::]:80: use of closed ne
twork connection" entryPointName=web
time="2026-05-17T09:17:37Z" level=error msg="close tcp [::]:8080: use of closed
network connection" entryPointName=traefik
time="2026-05-17T09:17:37Z" level=error msg="Error while starting server: accept
 tcp [::]:443: use of closed network connection" entryPointName=websecure
time="2026-05-17T09:18:24Z" level=info msg="Configuration loaded from file: /etc
/traefik/traefik.yml"
time="2026-05-17T09:22:53Z" level=error msg="accept tcp [::]:8080: use of closed
 network connection" entryPointName=traefik
time="2026-05-17T09:22:53Z" level=error msg="Error while starting server: accept
 tcp [::]:8080: use of closed network connection" entryPointName=traefik
time="2026-05-17T09:22:53Z" level=error msg="accept tcp [::]:443: use of closed
network connection" entryPointName=websecure
time="2026-05-17T09:22:53Z" level=error msg="Error while starting server: accept
 tcp [::]:443: use of closed network connection" entryPointName=websecure
time="2026-05-17T09:22:53Z" level=error msg="accept tcp [::]:80: use of closed n
etwork connection" entryPointName=web
time="2026-05-17T09:22:53Z" level=error msg="Error while starting server: accept
 tcp [::]:80: use of closed network connection" entryPointName=web
time="2026-05-17T09:23:40Z" level=info msg="Configuration loaded from file: /etc
/traefik/traefik.yml"
time="2026-05-17T09:36:45Z" level=info msg="Configuration loaded from file: /etc
/traefik/traefik.yml"
time="2026-05-17T16:02:42Z" level=info msg="Configuration loaded from file: /etc
/traefik/traefik.yml"
time="2026-05-17T21:34:47Z" level=info msg="Configuration loaded from file: /etc
/traefik/traefik.yml"
time="2026-05-17T22:00:29Z" level=info msg="Configuration loaded from file: /etc
/traefik/traefik.yml"
time="2026-05-17T22:24:58Z" level=info msg="Configuration loaded from file: /etc
/traefik/traefik.yml"
time="2026-05-17T22:39:15Z" level=info msg="Configuration loaded from file: /etc
/traefik/traefik.yml"
time="2026-05-19T17:21:51Z" level=info msg="Configuration loaded from file: /etc
/traefik/traefik.yml"
```

Note: The early TCP closed connection errors indicate Traefik was restarted multiple times during initial configuration. Later log entries show clean configuration loads, indicating stable operation was eventually achieved.

5.4.2 Port Listeners

```
ubuntu@ubuntu-cloud:~$ sudo ss -tlnp | grep -E "3128|80|443|8080"
LISTEN 0      4096         0.0.0.0:8080       0.0.0.0:*    users:(("docker-proxy
",pid=1436,fd=4))
LISTEN 0      4096         0.0.0.0:80         0.0.0.0:*    users:(("docker-proxy
",pid=1405,fd=4))
LISTEN 0      4096         0.0.0.0:3128       0.0.0.0:*    users:(("docker-proxy
",pid=1384,fd=4))
LISTEN 0      4096         0.0.0.0:443        0.0.0.0:*    users:(("docker-proxy
",pid=1418,fd=4))
LISTEN 0      4096            [::]:8080          [::]:*    users:(("docker-proxy
",pid=1443,fd=4))
LISTEN 0      4096            [::]:80            [::]:*    users:(("docker-proxy
",pid=1411,fd=4))
LISTEN 0      4096            [::]:3128          [::]:*    users:(("docker-proxy
",pid=1389,fd=4))
LISTEN 0      4096            [::]:443           [::]:*    users:(("docker-proxy
",pid=1427,fd=4))
```

KEY COMPONENTS:

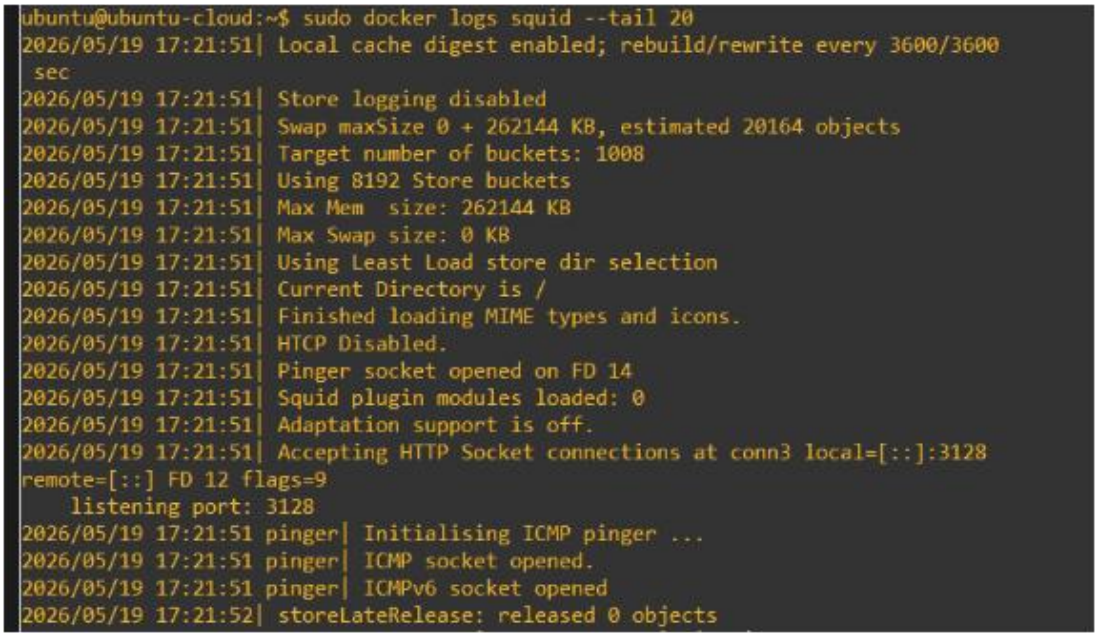
HTTP Port: 80 — docker-proxy (pid=1405/1411)

HTTPS Port: 443 — docker-proxy (pid=1418/1427)

Traefik Dashboard: 8080 — docker-proxy (pid=1436/1443)

Squid Proxy Port: 3128 — docker-proxy (pid=1384/1389)

5.4.3 Squid Logs



KEY COMPONENTS:

Squid Cache: 262144 KB (256 MB) max memory, 20164 objects estimated
Squid Listen Port: 3128 on [::] (IPv6/IPv4 dual-stack)
Adaptation: Disabled
Squid Startup: 2026-05-19 17:21:51

6. DMZ Services

6.1 NGINX Server — Web Server & Reverse Proxy

The NGINX server in the DMZ serves as both a web server and a secondary reverse proxy behind Traefik-Squid. It hosts web content and provides TLS termination for HTTPS traffic. NGINX is deployed as a system service (not containerized) on the DMZ node, listening on ports 80 and 443.

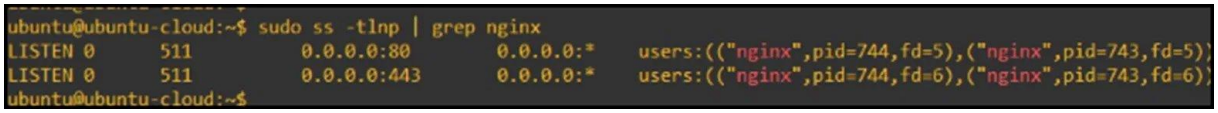
6.1.1 Service Status



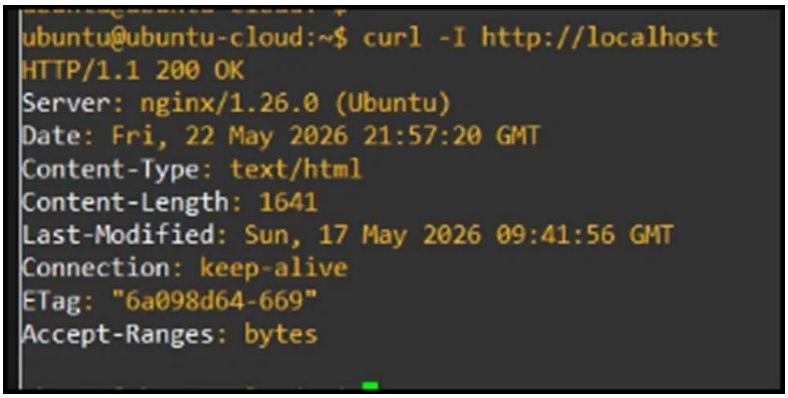
6.1.2 Configuration Validation



6.1.3 Port Listeners



6.1.4 HTTP Response Verification



KEY COMPONENTS:

Service: nginx — active (running)
Version: nginx/1.26.0 (Ubuntu)
Start Time: 2026-05-22 21:54:12 UTC
PID (Master): 743
PID (Worker): 744
Memory: 3.7 MB (peak 4.2 MB)
HTTP Port: 0.0.0.0:80 — listening
HTTPS Port: 0.0.0.0:443 — listening
Config Path: /etc/nginx/nginx.conf
Config Test: Syntax OK — test successful
HTTP Response: 200 OK
Content-Length: 1641 bytes
Last-Modified: Sun 17 May 2026 09:41:56 GMT

6.2 MailCow — Dockerized Email Solution



MailCow is a complete, Dockerized email server stack providing SMTP, IMAP, POP3, webmail, and administration interfaces. It is deployed in the DMZ behind the Traefik reverse proxy, with FortiGate VIPs forwarding inbound SMTP (port 25) and HTTPS (port 443) to the MailCow stack. MailCow provides the full enterprise email infrastructure for the Zero Trust UTM lab.

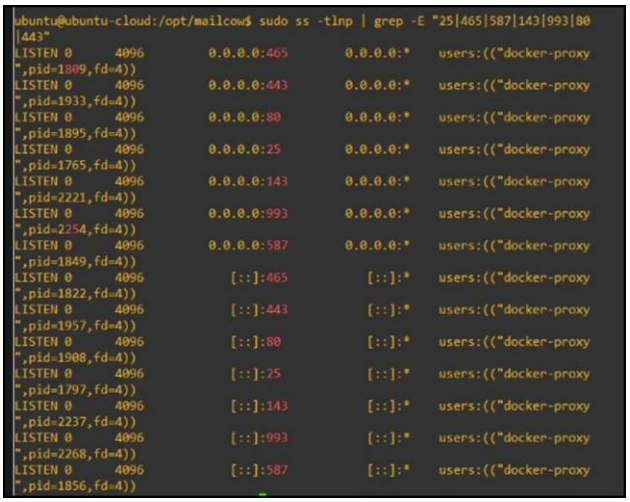
6.2.1 HTTPS Verification

```
ubuntu@ubuntu-cloud:/opt/mailcow$ curl -I -k https://localhost
HTTP/2 200
server: nginx
date: Fri, 22 May 2026 22:00:00 GMT
content-type: text/html; charset=utf-8
vary: Accept-Encoding
set-cookie: MCSESSID=f0275cfd39a232234b4b326a6ac99b01; path=/; secure; HttpOnly; SameSite=Lax
expires: Thu, 19 Nov 1981 08:52:00 GMT
cache-control: no-store, no-cache, must-revalidate
pragma: no-cache
strict-transport-security: max-age=15768000;
x-content-type-options: nosniff
x-robots-tag: none
x-download-options: noopen
x-frame-options: SAMEORIGIN
x-permitted-cross-domain-policies: none
referrer-policy: strict-origin
```

KEY COMPONENTS:

HTTP/2 Status: 200 OK
Served by: nginx (MailCow frontend nginx container)
Session Cookie: MCSESSID — Secure, HttpOnly, SameSite=Lax
HSTS: max-age=15768000
X-Frame-Options: SAMEORIGIN
Content-Type-Options: nosniff
Cache Control: no-store, no-cache, must-revalidate
Cross-Domain Policies: none
Referrer Policy: strict-origin

6.2.2 Mail Ports



Port	Protocol	Purpose
25	SMTP	Inbound mail delivery (MX)
80	HTTP	Web UI redirect to HTTPS
143	IMAP	Mail client access (unencrypted)
443	HTTPS	Webmail + Admin UI
465	SMTPS	SMTP over SSL (mail submission)
587	SMTP Submission	Authenticated mail submission (STARTTLS)
993	IMAPS	IMAP over SSL

6.2.3 Docker Containers



Container	Image Version	Status	
acme-mailcow	mailcow/acme:1.97	Up 5 min	—
clamd-mailcow	mailcow/clamd:1.71	Up (healthy)	—
dovecot-mailcow	mailcow/dovecot:2.3.21.1-2	Up 4 min	110/143/993/995/4190
mysql-mailcow	mariadb:10.11	Up 5 min	127.0.0.1:13306→3306
nginx-mailcow	mailcow/nginx:1.06	Up 5 min	0.0.0.0:80/443
postfix-mailcow	mailcow/postfix:3.7.11-2	Up 5 min	0.0.0.0:25/465/587
redis-mailcow	redis:7.4.6-alpine	Up 4 min	127.0.0.1:7654→6379
rspamd-mailcow	mailcow/rspamd:3.14.3-1	Up 5 min	—
unbound-mailcow	mailcow/unbound:1.25	Up (unhealthy)	53/tcp+udp
watchdog-mailcow	mailcow/watchdog:2.11	Up 5 min	—

7. Network Zones & Traffic Flow

The Zero Trust UTM M1 network implements strict zone-based segmentation enforced by FortiGate VM. Traffic between zones is explicitly permitted by firewall policies, with all inter-zone traffic subject to IPS inspection, SSL decryption where applicable, web filtering, and full session logging.

7.1 Zone Definitions

Three primary zones are defined on FortiGate with block intra-zone traffic enabled where appropriate:

- WAN-ZONE (port1: 192.168.20.130/24) — Internet-facing interface. Block intra-zone traffic enabled. All inbound internet traffic enters here.
- DMZ-ZONE (port2: 10.10.1.1/24) — Demilitarized zone for Suricata-Inline IPS, Traefik-Squid reverse proxy, NGINX web server, and MailCow. Block intra-zone enabled.
- INTERNAL-ZONE (port3: 10.10.2.1/24) — Internal LAN for Distribution Switch, Management Switch, FW-3-PF pfSense, Access Switch, and cloud management nodes.

7.2 Traffic Flow — WAN to DMZ

- Internet → NAT1 (GNS3) → VyOS Edge Router (eth0: 192.168.42.72/24)
- VyOS → FortiGate port1 (192.168.20.130) via eth1 (10.0.0.1/30)
- FortiGate applies WAN-TO-DMZ policy: permits SMTP(25), HTTP(80), HTTPS(443) via VIPs
- FortiGate → Suricata-Inline IPS (AF_PACKET inline inspection on DMZ segment)
- Suricata → DMZ-Switch1 (dmz-br bridge: ens3/ens4/ens5/ens6)
- DMZ-Switch → Traefik-Squid (reverse proxy, ports 80/443/8080, Squid port 3128)
- Traefik-Squid → NGINX Server (10.10.1.10, ports 80/443)
- Traefik-Squid → MailCow Server (10.10.1.11, ports 25/80/143/443/465/587/993)

7.3 DNS Traffic Flow

- All internal DNS queries → Pi-hole (port 53 UDP/TCP on IPv4 and IPv6)
- Pi-hole performs blocklist filtering (ads, trackers, malware C2)
- Clean queries forwarded to upstream resolvers
- FortiGate DNS: Primary 8.8.8.8, Secondary 1.1.1.1 (for FortiGate itself)

7.4 Monitoring Traffic Flow

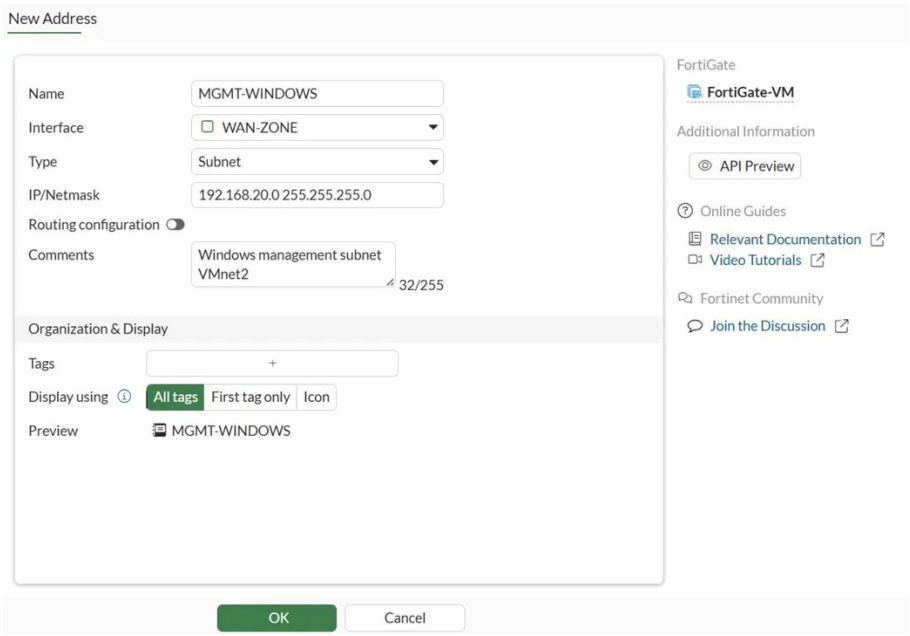
- Zeek monitors ens4 interface — captures all network traffic in passive mode
- Zeek writes structured logs to /opt/zeek/logs/
- RITA reads Zeek logs from mgmt-network database (MongoDB backend)
- Arkime captures full packets via Elasticsearch (localhost:9200) — activating

8. Firewall Policies Summary

FortiGate VM enforces zone-based firewall policies with deep inspection. All documented policies use flow-based inspection mode with full session logging.

Policy	From	To	Service	Action	Security Profiles
WAN-TO-DMZ	WAN-ZONE	DMZ-ZONE	SMTP/HTTP/HTTPS	ACCEPT	AV default, IPS default, SSL cert-inspection

8.1 Address Objects



Address Object: MGMT-WINDOWS — 192.168.20.0/24 on WAN-ZONE
Purpose: Windows management subnet (VMnet2) — used in management access policies

9. Integration with Other Machines

Machine 1 (M1) is the central hub for all other machines in the Zero Trust UTM cluster. All inter-machine communication traverses Tailscale VPN tunnels originating from M1.

9.1 M1 → M2 (Identity & PKI Plane)

- M2 provides certificate issuance for FortiGate SSL inspection CA distribution
- M2 LDAP/AD services integrate with FortiGate User & Authentication for identity-based policies
- PKI certificates for MailCow TLS and NGINX TLS are issued by M2 CA
- Tailscale VPN tunnel carries M2 traffic through M1 network enforcement

9.2 M1 → M3 (Intelligence & SOAR Plane)

- Zeek logs (from M1) are forwarded to M3 SIEM for correlation and alerting
- Arkime PCAP data accessible to M3 for forensic investigation
- FortiGate syslog events exported to M3 for SOAR playbook triggering
- Suricata alerts forwarded to M3 for automated threat response

9.3 M1 → M4 (Deception & Honeypot Plane)

- M4 honeypots are accessible via FortiGate policy (internal zone routing)
- Deception tokens and canary files deployed in DMZ services (NGINX, MailCow) alert to M4
- NLP-based deception engine (M4) integrates with network flow data from M1 monitoring

9.4 M1 → M5 (Endpoint Protection & Hardening Plane)

- Cloud-Machine5 (internal endpoint) traverses M1 FortiGate for all external access
- Endpoint DNS queries processed by M1 Pi-hole DNS filter
- Web traffic from M5 endpoints passes through M1 FortiGate web filter and app control
- M5 EDR telemetry forwarded via M3 SOAR back to M1 for dynamic policy updates

M2

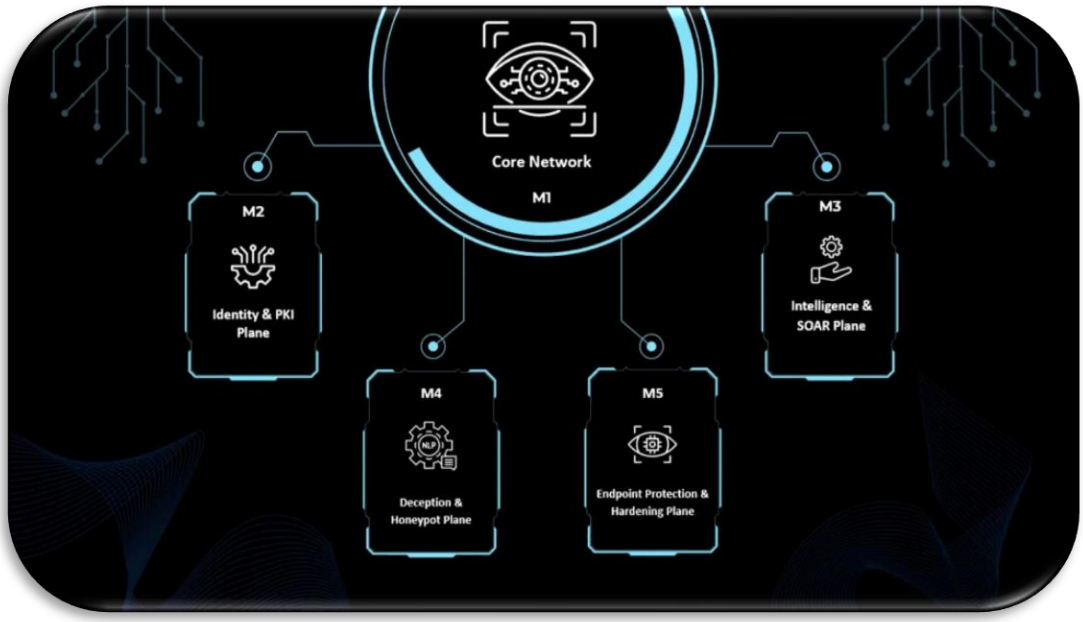
Identity & PKI Plane

Machine-2

Architecture Overview

Machine 2 (M2) serves as the Identity & PKI Plane for the entire Zero Trust UTM Lab. It is the centralized hub for all authentication, authorization, certificate issuance, and secrets management across all five machines in the cluster. No user, service, or device may access any resource without first being verified through M2's identity pipeline.

Centralized Authentication, Authorization, Certificate Authority & Secrets Management



1. Executive Summary

Machine 2 (M2) serves as the Identity & PKI Plane for the entire Zero Trust UTM Lab. It is the centralized hub for all authentication, authorization, certificate issuance, and secrets management across all five machines in the cluster. No user, service, or device may access any resource without first being verified through M2's identity pipeline.

The overarching Zero Trust principle — Never Trust, Always Verify — is enforced at every layer by M2. All services across M1 through M5 rely on M2 for identity federation, PKI certificates, and dynamic secrets.

1.1 Role of M2 in Zero Trust Architecture

- Provides SSO (Single Sign-On) via Keycloak using OIDC/SAML protocols
- Issues and manages TLS/mTLS/device certificates via Smallstep CA and EJBCA
- Stores and dynamically delivers secrets via HashiCorp Vault
- Enforces 802.1X network access control via FreeRADIUS
- Provides Kerberos-based authentication for AD/SSO environments
- Manages privileged access via CyberArk Conjur
- Provides zero-trust access gateway (SSH, Kubernetes, DB, Web) via Teleport
- Analyzes AD attack paths and privilege escalation via BloodHound CE
- Maintains service mesh and service discovery via HashiCorp Consul

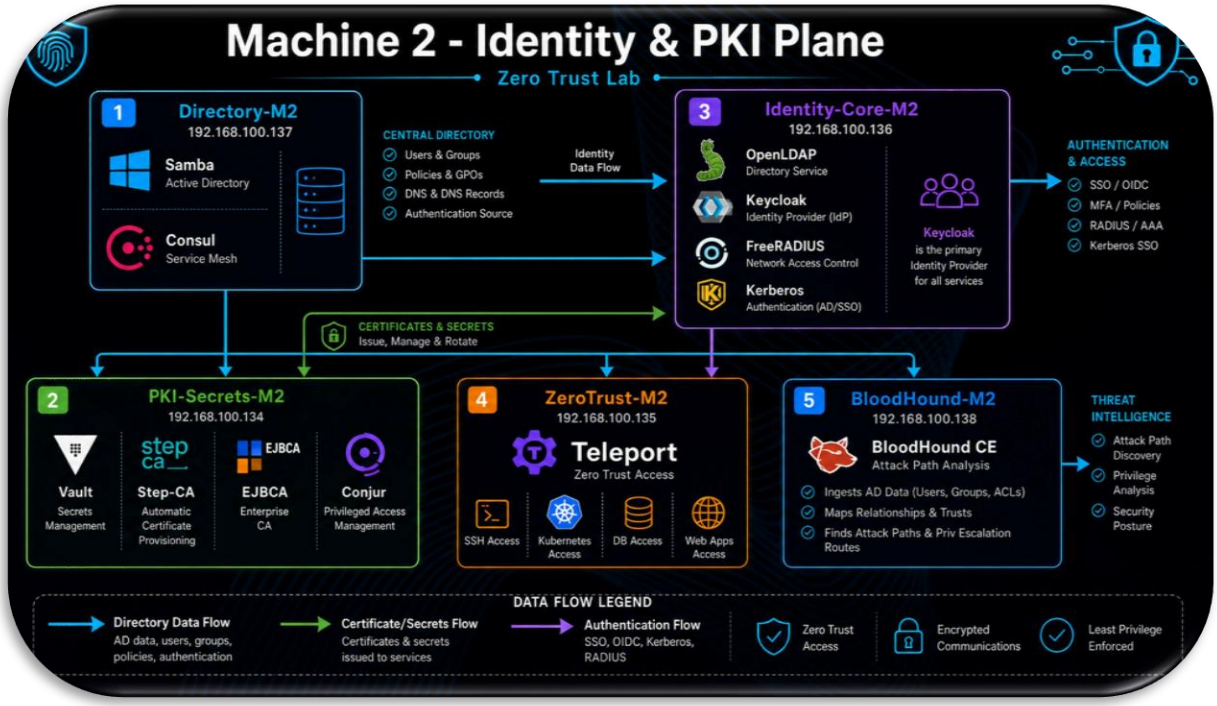
1.2 How M2 Connects to All Other Machines

Machine	Interaction with M2	Protocol / Service
M1 — Core Network	FortiGate uses FreeRADIUS for 802.1X NAC; FortiGate Admin uses TACACS+ for AAA	RADIUS / TACACS+
M3 — Intelligence	Auth logs forwarded to Wazuh/Kafka SIEM for correlation and alerting	Syslog / Kafka
M4 — Deception	Honeypot tokens issued by Vault; Keycloak SSO for management plane	Vault API / OIDC
M5 — Endpoint	Endpoint agents authenticated via Step-CA EAP-TLS; secrets from Vault	EAP-TLS / Vault API
All Machines	Keycloak SSO for all management UIs and service-to-service auth	OIDC / SAML

2. M2 Architecture Overview

The following diagrams illustrate the overall architecture of Machine 2, the identity and authentication flow through the system, and the PKI and secrets management flow. Together they define how zero trust is enforced for every access request in the lab.

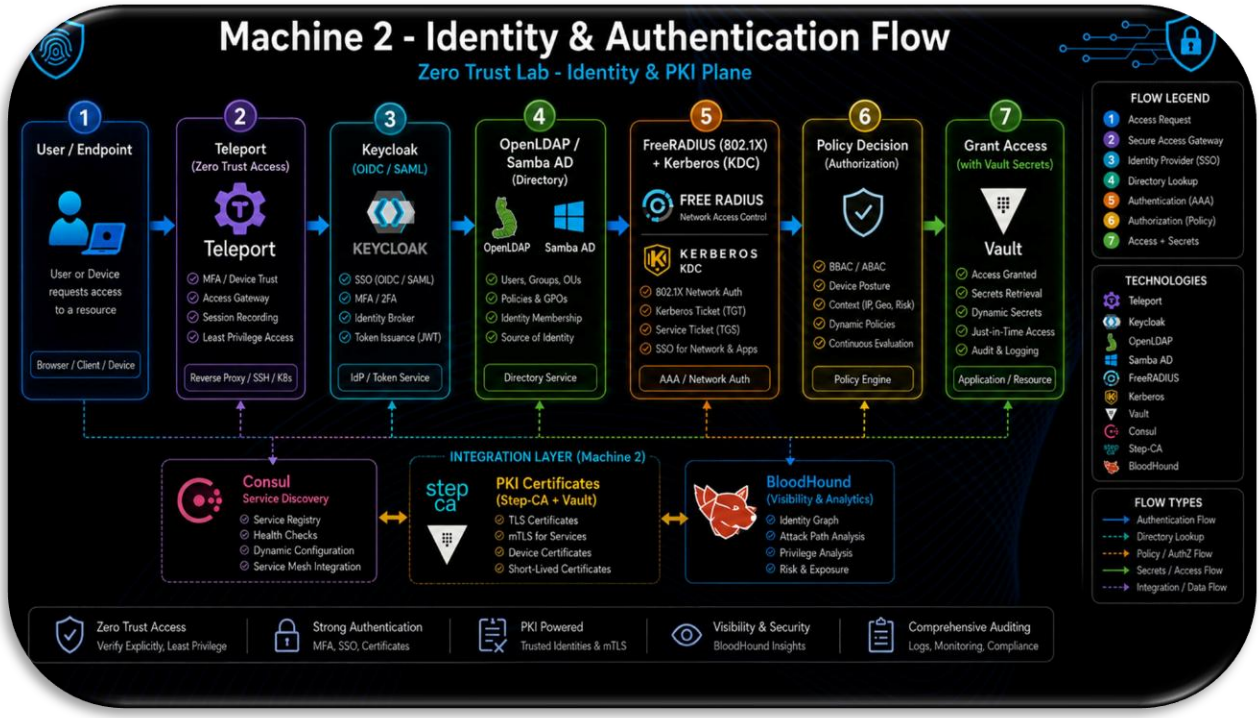
2.1 M2 Identity & PKI Plane — System Architecture



The architecture diagram shows five virtual machines working in concert:

- VM 1 (Directory-M2, 192.168.100.137): Central directory providing Users & Groups, Policies & GPOs, DNS & DNS Records, and is the Authentication Source for all machines. Hosts Samba Active Directory and Consul Service Mesh.
- VM 2 (PKI-Secrets-M2, 192.168.100.134): Certificates & Secrets hub. Issues, manages, and rotates all certificates and secrets across the lab using Vault, Step-CA, EJBCA, and Conjur.
- VM 3 (Identity-Core-M2, 192.168.100.136): Authentication & Access using OpenLDAP, Keycloak (primary IdP), FreeRADIUS, and Kerberos. Provides SSO/OIDC, MFA/Policies, RADIUS/AAA, and Kerberos SSO.
- VM 4 (ZeroTrust-M2, 192.168.100.135): Zero Trust Access via Teleport covering SSH, Kubernetes, DB Access, and Web Apps Access.
- VM 5 (BloodHound-M2, 192.168.100.138): Threat Intelligence via BloodHound CE for Attack Path Discovery, Privilege Analysis, and Security Posture assessment.

2.2 Identity & Authentication Flow

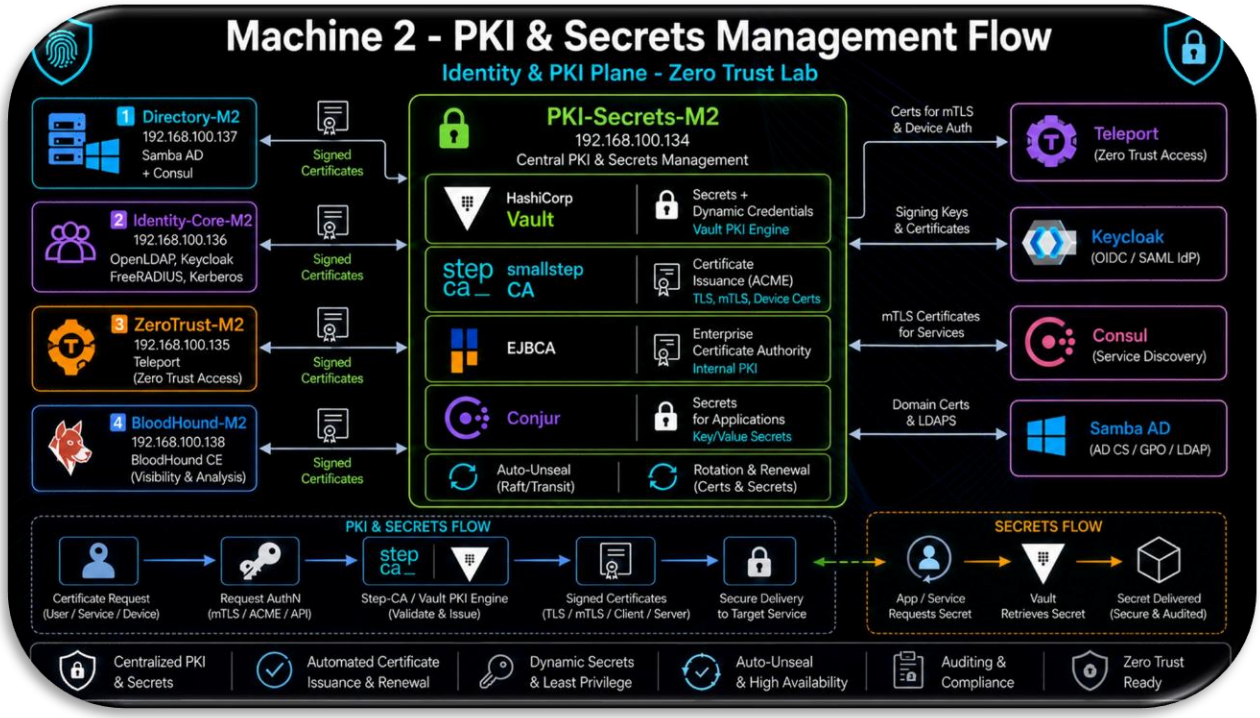


The authentication flow follows seven stages:

#	Stage	Function
1	**User / Endpoint**	User or Device (Browser/Client/Device) requests access to a resource
2	**Teleport (Zero Trust Access)**	MFA/Device Trust, Access Gateway, Session Recording, Least Privilege Access via Reverse Proxy/SSH/K8s
3	**Keycloak (OIDC/SAML)**	SSO (OIDC/SAML), MFA/2FA, Identity Broker, Token Issuance (JWT) — acts as IdP/Token Service
4	**OpenLDAP / Samba AD**	Users, Groups, OUs, Policies & GPOs, Identity Membership, Source of Identity — Directory Service
5	**FreeRADIUS + Kerberos KDC**	802.1X Network Auth, Kerberos Ticket (TGT), Service Ticket (TGS), SSO for Network & Apps — AAA/Network Auth
6	**Policy Decision (Authorization)**	BBAC/ABAC, Device Posture, Context (IP, Geo, Risk), Dynamic Policies, Continuous Evaluation — Policy Engine
7	**Grant Access (with Vault Secrets)**	Access Granted, Secrets Retrieval, Dynamic Secrets, Just-in-Time Access, Audit & Logging — Application/Resource

The integration layer (Machine 2) underpins this flow with Consul (Service Discovery), PKI Certificates via Step-CA + Vault (TLS, mTLS, Device Certs, Short-Lived Certificates), and BloodHound (Visibility & Analytics with Identity Graph, Attack Path Analysis, Privilege Analysis, Risk & Exposure assessment).

2.3 PKI & Secrets Management Flow



The PKI & Secrets Management Flow shows PKI-Secrets-M2 at the center, distributing:

- Signed Certificates to Directory-M2 (Samba AD + Consul), Identity-Core-M2 (OpenLDAP, Keycloak, FreeRADIUS, Kerberos), ZeroTrust-M2 (Teleport), and BloodHound-M2
- Certs for mTLS & Device Auth to Teleport (Zero Trust Access)
- Signing Keys & Certificates to Keycloak (OIDC/SAML IdP)
- mTLS Certificates for Services to Consul (Service Discovery)
- Domain Certs & LDAPS to Samba AD (AD CS / GPO / LDAP)

The PKI & Secrets Flow at the bottom shows: Certificate Request (User/Service/Device) → Request AuthN (mTLS/ACME/API) → Step-CA / Vault PKI Engine (Validate & Issue) → Signed Certificates (TLS/mTLS/Client/Server) → Secure Delivery to Target Service.

The Secrets Flow (right side) shows: App/Service Requests Secret → Vault Retrieves Secret → Secret Delivered (Secure & Audited).

3. Technology Stack Overview

Machine 2 deploys the following technology stack across its five virtual machines:

VM	Tool	Category	Role
Directory-M2	Samba AD	Directory Service	Active Directory Domain Controller for zerotrust.lab
Directory-M2	Consul	Service Mesh	Service discovery, health checks, dynamic config, mesh integration
PKI-Secrets-M2	HashiCorp Vault	Secrets Management	Dynamic credentials, PKI engine, key-value secrets, auto-unseal
PKI-Secrets-M2	Smallstep CA	Certificate Authority	Automatic TLS/mTLS/device cert provisioning via ACME
PKI-Secrets-M2	EJBCA	Enterprise CA	Enterprise certificate authority, Internal PKI
PKI-Secrets-M2	Conjur (CyberArk)	PAM	Privileged Access Management, Key/Value secrets for applications
Identity-Core-M2	OpenLDAP	Directory Service	Lightweight Directory Access Protocol — user/group store
Identity-Core-M2	Keycloak	Identity Provider	OIDC/SAML SSO, MFA, JWT token issuance, primary IdP
Identity-Core-M2	FreeRADIUS	Network Access Control	802.1X authentication, AAA, RADIUS for network devices
Identity-Core-M2	Kerberos KDC	Authentication	Kerberos ticket granting, AD/SSO integration
ZeroTrust-M2	Teleport	Zero Trust Gateway	SSH, Kubernetes, DB, Web App access with session recording
BloodHound-M2	BloodHound CE	Attack Path Analysis	AD attack path discovery, privilege escalation mapping
BloodHound-M2	Neo4j	Graph Database	Stores AD relationship graph for BloodHound queries

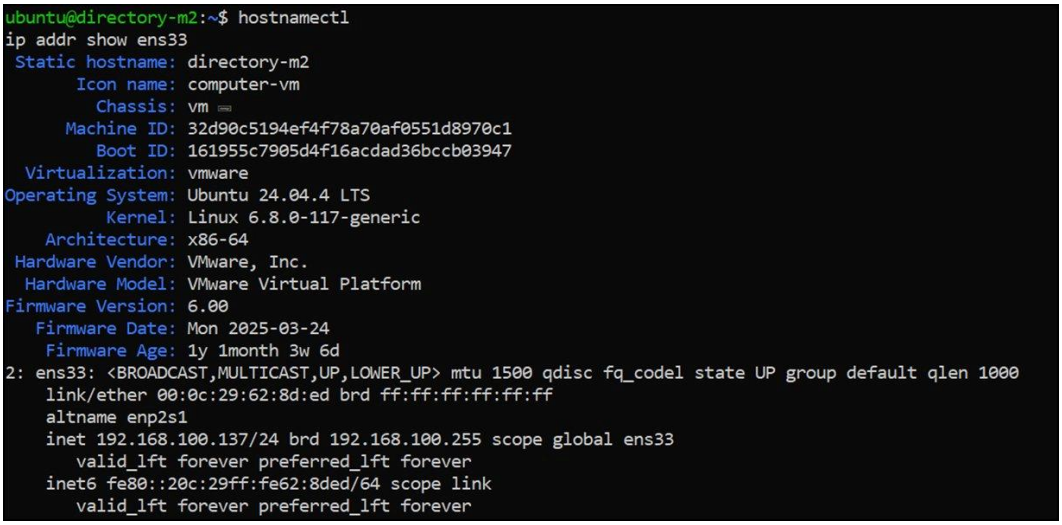
4. VM 1 — Directory-M2

Directory-M2 is the central directory and service mesh controller for the Zero Trust Lab. It runs Samba Active Directory as the domain controller for zerotrust.lab and hosts the Consul Service Mesh server that all other VMs register with.

4.1 Role & Purpose

- Central Directory: Manages all Users & Groups, Policies & GPOs, DNS & DNS Records
- Authentication Source: Acts as the primary authentication source for all machines in the cluster
- Service Mesh Hub: Consul server (1 server + 4 clients) providing service discovery for the entire lab
- Domain Controller: Samba AD domain controller for domain zerotrust.lab

4.2 System Information



Extracted configuration details from the hostnamectl and ip addr output:

Static Hostname	**directory-m2**
Icon Name	computer-vm
Chassis	vm
Machine ID	32d90c5194ef4f78a70af0551d8970c1
Boot ID	161955c7905d4f16acdad36bccb03947
Virtualization	vmware
Operating System	Ubuntu 24.04.4 LTS
Kernel	Linux 6.8.0-117-generic
Architecture	x86-64
Hardware Vendor	VMware, Inc.
Hardware Model	VMware Virtual Platform
Firmware Version	6.00
Firmware Date	Mon 2025-03-24

Firmware Age	1y 1month 3w 6d
Network Interface	ens33 (altname: enp2s1)
MAC Address	00:0c:29:62:8d:ed
IPv4 Address	192.168.100.137/24 (brd 192.168.100.255)
IPv6 Address	fe80::20c:29ff:fe62:8ded/64 (scope link)
MTU	1500
Interface State	BROADCAST, MULTICAST, UP, LOWER_UP

4.3 Consul Service Mesh — Members

```
ubuntu@directory-m2:~$ consul members
Node              Address              Status  Type    Build   Protocol  DC           Partition  Segment
directory-m2      192.168.100.137:8301  alive   server  1.22.7  2         zerotrust-lab  default    <all>
bloodhound-m2     192.168.100.138:8301  alive   client  1.22.7  2         zerotrust-lab  default    <default>
identity-core-m2  192.168.100.136:8301  alive   client  1.22.7  2         zerotrust-lab  default    <default>
pki-secrets-m2    192.168.100.134:8301  alive   client  1.22.7  2         zerotrust-lab  default    <default>
zerotrust-m2      192.168.100.135:8301  alive   client  1.22.7  2         zerotrust-lab  default    <default>
```

The consul members command confirms all 5 nodes are alive and healthy in the zerotrust-lab datacenter:

Key observations from the consul members output: directory-m2 is the Consul server (leader) while all other four VMs are Consul clients. All nodes run Consul version 1.22.7 using Protocol 2, and are part of the zerotrust-lab datacenter in the default partition and default segment.

5. VM 2 — PKI-Secrets-M2

PKI-Secrets-M2 (192.168.100.134) is the centralized PKI and Secrets Management VM. It houses four critical security tools: HashiCorp Vault (secrets and PKI engine), Smallstep CA (ACME certificate provisioning), EJBCA (Enterprise CA), and CyberArk Conjur (privileged access management). This VM issues, manages, and rotates all certificates and secrets across the entire Zero Trust Lab.

5.1 Role & Purpose

- Centralized PKI: Issues and manages TLS, mTLS, client, and device certificates for all services
- Secrets Management: Stores and dynamically delivers secrets to applications via Vault
- Auto-Unseal: Vault is configured with Raft/Transit for automatic unsealing and high availability
- Rotation & Renewal: Automated certificate and secret rotation to minimize exposure
- Privileged Access: CyberArk Conjur manages privileged credentials for applications

5.2 Smallstep CA (Step-CA) — Service Status

```
ubuntu@pkisecrets-m2:~$ sudo systemctl status step-ca --no-pager
● step-ca.service - Smallstep CA
     Loaded: loaded (/etc/systemd/system/step-ca.service; enabled; preset: enabled)
     Active: active (running) since Wed 2026-05-20 22:26:49 UTC; 6min ago
   Main PID: 833 (step-ca)
      Tasks: 8 (limit: 3360)
     Memory: 42.8M (peak: 43.1M)
        CPU: 4.282s
     CGroup: /system.slice/step-ca.service
             └─833 /usr/bin/step-ca /etc/step-ca/config/ca.json --password-file=/etc/step-ca/secrets/password

May 20 22:26:57 pkisecrets-m2 step-ca[833]: 2026/05/20 22:26:57 Building new tls configuration using step-ca x509 Signer Interface
May 20 22:26:59 pkisecrets-m2 step-ca[833]: 2026/05/20 22:26:59 Starting Smallstep CA/0.26.2 (linux/amd64)
May 20 22:26:59 pkisecrets-m2 step-ca[833]: 2026/05/20 22:26:59 Documentation: https://u.step.sm/docs/ca
May 20 22:26:59 pkisecrets-m2 step-ca[833]: 2026/05/20 22:26:59 Community Discord: https://u.step.sm/discord
May 20 22:26:59 pkisecrets-m2 step-ca[833]: 2026/05/20 22:26:59 Config file: /etc/step-ca/config/ca.json
May 20 22:26:59 pkisecrets-m2 step-ca[833]: 2026/05/20 22:26:59 The primary server URL is https://pki-secrets-m2.zerotrust.lab:9000
May 20 22:26:59 pkisecrets-m2 step-ca[833]: 2026/05/20 22:26:59 Root certificates are available at https://pki-secrets-m2.zerotrust.lab:9000/roots.pem
May 20 22:26:59 pkisecrets-m2 step-ca[833]: 2026/05/20 22:26:59 X.509 Root Fingerprint: 2839b24f6c04edf6659ee1c073608bc75fd3de69a4cbbba043d6c0f93e52387
May 20 22:26:59 pkisecrets-m2 step-ca[833]: 2026/05/20 22:26:59 Serving HTTPS on :9000 ...
May 20 22:31:08 pkisecrets-m2 step-ca[833]: 2026/05/20 22:31:08 net/http/server.go:3411: http: TLS handshake error from 192.168.100.137:47820: EOF
```

5.3 HashiCorp Vault — Status

```
ubuntu@pkisecrets-m2:~$ export VAULT_ADDR=http://127.0.0.1:8200
vault status
Key             Value
---             -----
Seal Type       shamir
Initialized     true
Sealed          false
Total Shares    3
Threshold       2
Version         2.0.0
Build Date      2026-04-13T18:49:01Z
Storage Type    file
Cluster Name    vault-cluster-fb471389
Cluster ID      9bf42145-6028-7356-2449-322d17c8247e
HA Enabled      false
```

5.4 EJBCA & Conjur — Docker Containers



Both containers were created 6 days prior to capture and have been running for 5 minutes at time of capture (indicating a recent service restart/reboot persistence test). EJBCA exposes its admin interface on port 8444 (HTTPS, mapped from container 8443) and its HTTP interface on port 8081 (mapped from container 8080). Conjur exposes port 8080.

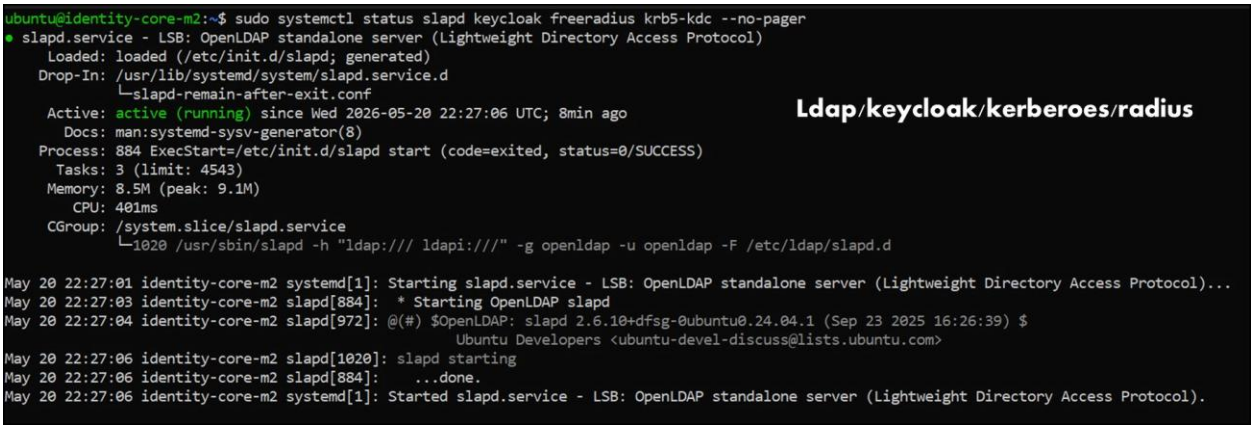
6. VM 3 — Identity-Core-M2

Identity-Core-M2 (192.168.100.136) is the authentication and access control engine of the Zero Trust Lab. It hosts four identity services: OpenLDAP (directory service), Keycloak (primary Identity Provider with SSO/OIDC/SAML), FreeRADIUS (802.1X network access control and AAA), and Kerberos KDC (authentication for AD/SSO environments).

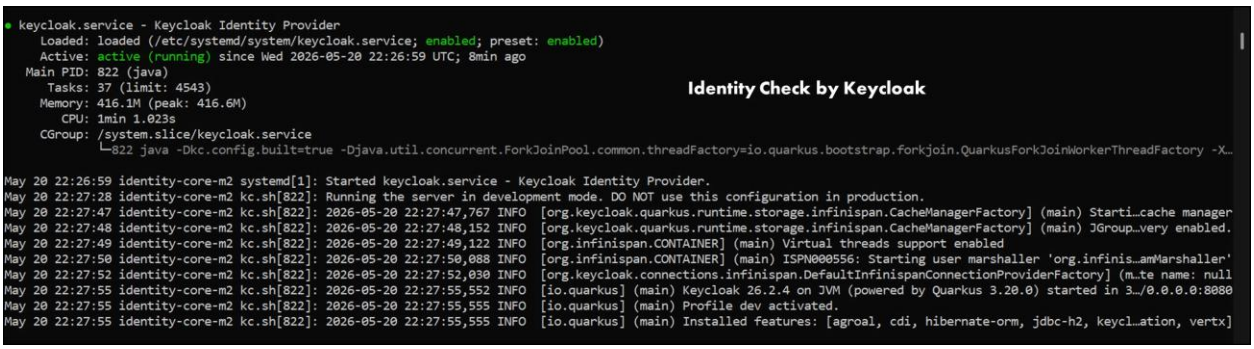
6.1 Role & Purpose

- Primary Identity Provider: Keycloak is the primary IdP for all services in the lab
- SSO/OIDC/SAML: Provides Single Sign-On across all services via standard protocols
- MFA Enforcement: Multi-Factor Authentication enforced at the Keycloak level
- LDAP Directory: OpenLDAP stores all user, group, and organizational data
- Network Access Control: FreeRADIUS enforces 802.1X NAC for network access
- Kerberos Authentication: Kerberos KDC issues TGT and TGS tickets for AD/SSO

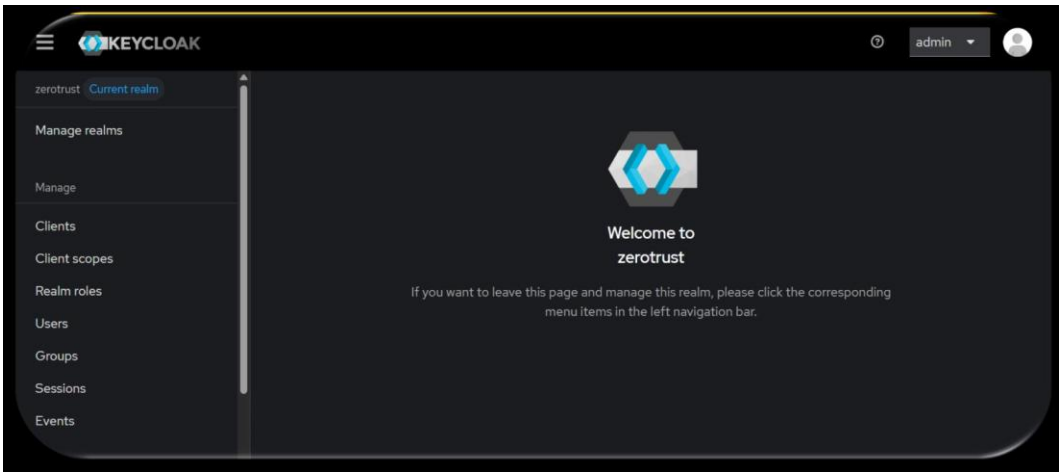
6.2 OpenLDAP (slapd) — Service Status



6.3 Keycloak Identity Provider — Service Status

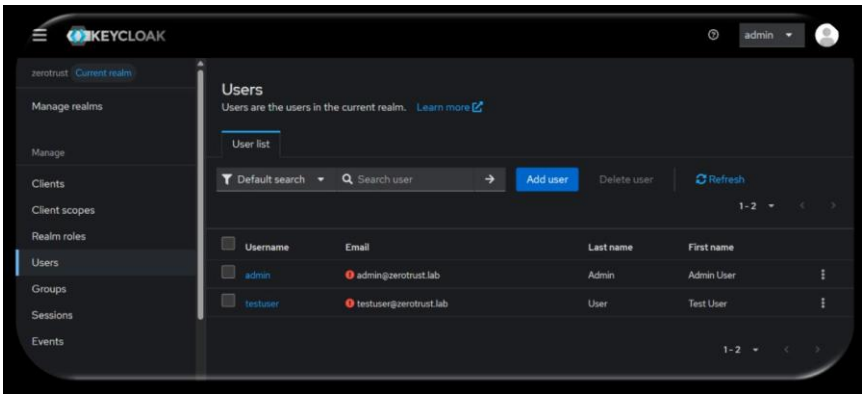


6.4 Keycloak Admin UI — zerotrust Realm



The Keycloak Admin UI shows the zerotrust realm configured as the current realm. The left navigation panel exposes the following management sections under the zerotrust realm: Clients, Client scopes, Realm roles, Users, Groups, Sessions, and Events. The admin user is logged in (visible in top-right corner).

6.5 Keycloak Users — zerotrust Realm



The zerotrust realm has two users configured:

Username	Email	Last Name	First Name
admin	admin@zerotrust.lab	Admin	Admin User
testuser	testuser@zerotrust.lab	User	Test User

Both user accounts have email verification pending (indicated by the warning icon visible in the screenshot next to each email address). The user list shows 1-2 of 2 total users in the zerotrust realm.

Note: FreeRADIUS and Kerberos services were also checked in the same systemctl status command (image 9 shows the combined check for slapd, keycloak, freeradius, and krb5-kdc). The annotation "Ldap/keycloak/kerberoes/radius" confirms all four services are running on this VM.

7. VM 4 — ZeroTrust-M2 (Teleport)

ZeroTrust-M2 (192.168.100.135) hosts the Teleport Zero Trust Access Gateway. Teleport provides secure, audited access to SSH servers, Kubernetes clusters, databases, and web applications without VPN. It enforces MFA, device trust, least privilege access, and records all sessions for audit purposes.

7.1 Role & Purpose

- Zero Trust Access Gateway: Provides secure access to SSH, Kubernetes, databases, and web applications
- Session Recording & Audit: All sessions are recorded and logged for compliance and forensics
- MFA / Device Trust: Enforces multi-factor authentication and verifies device trust posture
- Just-in-Time Access: Provides temporary, time-limited access to resources
- Reverse Proxy: Operates as a reverse proxy for SSH, Kubernetes (K8s) access

7.2 Teleport — Service Status

```
ubuntu@zerotrust-m2:~$ sudo systemctl status teleport --no-pager
● teleport.service - Teleport Service
     Loaded: loaded (/usr/lib/systemd/system/teleport.service; enabled; preset: enabled)
     Active: active (running) since Wed 2026-05-20 22:26:51 UTC; 10min ago
   Main PID: 817 (teleport)
      Tasks: 12 (limit: 2205)
     Memory: 249.5M (peak: 294.7M swap: 11.5M swap peak: 11.5M)
        CPU: 19.163s
     CGroup: /system.slice/teleport.service
             └─817 /usr/local/bin/teleport start --config /etc/teleport.yaml --pid-file=/run/teleport.pid

May 20 22:27:21 zerotrust-m2 teleport[817]: 2026-05-20T22:27:21Z INFO [PROXY:SER]  Stating SSH proxy service pid:817.1 version:16.1.8 git_ref:v16.1.8-0-g33ec1…rvice.go:4711
May 20 22:27:21 zerotrust-m2 teleport[817]: 2026-05-20T22:27:21Z INFO [PROC:1]    The new service has started successfully. Starting syncing rotation status. …onnect.go:695
May 20 22:27:21 zerotrust-m2 teleport[817]: 2026-05-20T22:27:21Z INFO [PROXY:AGE] Starting reverse tunnel agent pool. service/service.go:4765
May 20 22:27:21 zerotrust-m2 teleport[817]: 2026-05-20T22:27:21Z INFO [PROC:1]    Starting proxy gRPC server. pid:817.1 listen_address:[::]:3080 service/service.go:6398
May 20 22:27:21 zerotrust-m2 teleport[817]: 2026-05-20T22:27:21Z INFO [PROXY:PRO] Starting Kube proxy. pid:817.1 listen_address:[::]:3080 service/service.go:4860
May 20 22:27:21 zerotrust-m2 teleport[817]: 2026-05-20T22:27:21Z INFO [DB:SERVIC] Starting Database Postgres proxy server. pid:817.1 listen_address:[::]:3080 …rvice.go:4960
May 20 22:27:21 zerotrust-m2 teleport[817]: 2026-05-20T22:27:21Z INFO [DB:SERVIC] Starting Database TLS proxy server. pid:817.1 listen_address:0.0.0.0:3080 se…rvice.go:4978
May 20 22:27:21 zerotrust-m2 teleport[817]: 2026-05-20T22:27:21Z INFO [PROC:1]    Starting proxy gRPC server. pid:817.1 listen_address:[::]:3080 service/service.go:6475
May 20 22:27:21 zerotrust-m2 teleport[817]: 2026-05-20T22:27:21Z INFO [PROXY:SER] Starting TLS ALPN SNI proxy server on. pid:817.1 listen_address:[::]:3080 se…rvice.go:5060
May 20 22:27:21 zerotrust-m2 teleport[817]: 2026-05-20T22:27:21Z INFO [PROXY:SER] Starting TLS ALPN SNI reverse tunnel proxy server. pid:817.1 listen_address:…rvice.go:5081
Hint: Some lines were ellipsized, use -l to show in full.
ubuntu@zerotrust-m2:~$ sudo docker ps
CONTAINER ID   IMAGE     COMMAND   CREATED   STATUS    PORTS     NAMES
```

All Teleport proxy services start successfully on the standard port 3080. The service annotation in the BloodHound session recording image notes "Session Recording & Audit | SSH, Kubernetes & Database Access Proxy" confirming the role of this VM.

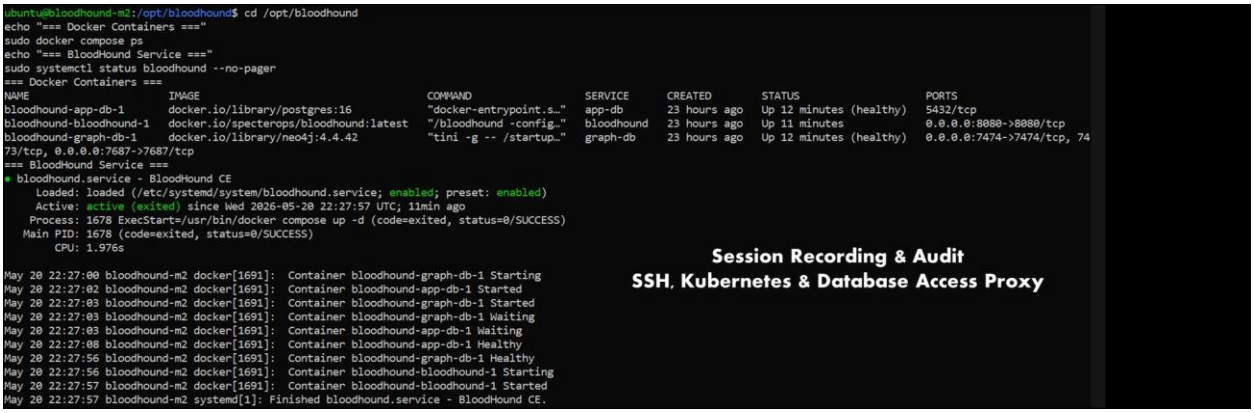
8. VM 5 — BloodHound-M2

BloodHound-M2 (192.168.100.138) hosts BloodHound Community Edition (CE) for Active Directory attack path analysis. BloodHound ingests AD data (users, groups, ACLs), maps relationships and trust paths, and identifies privilege escalation routes and attack paths. It uses Neo4j as its graph database backend.

8.1 Role & Purpose

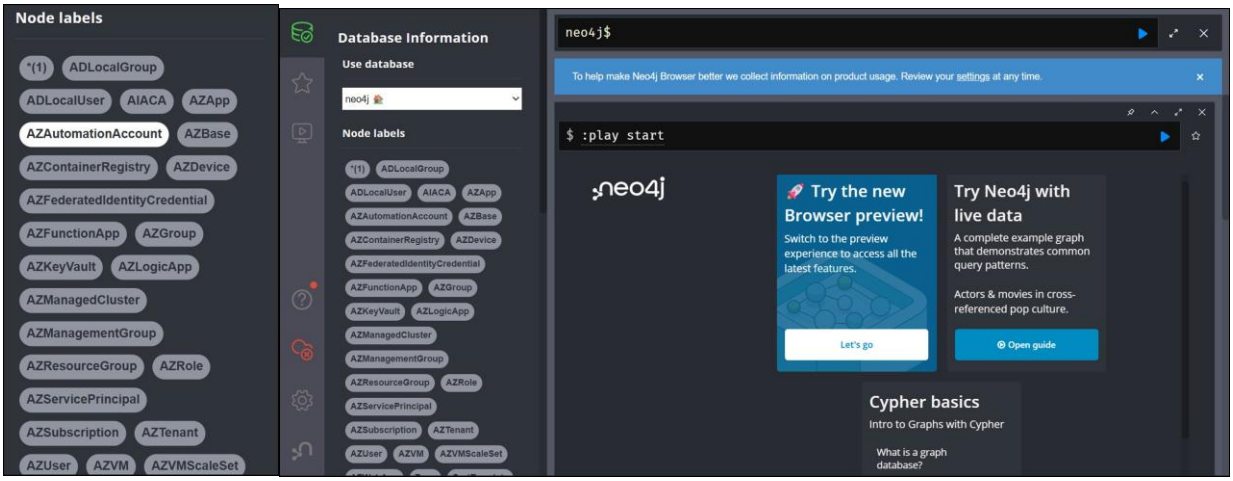
- Attack Path Discovery: Identifies possible attack paths through AD relationships
- Privilege Analysis: Maps privilege escalation routes from normal users to Domain Admin
- Security Posture Assessment: Provides visibility into AD misconfigurations and risky permissions
- Identity Graph: Maintains a graph of all AD relationships, trusts, and ACLs
- Risk & Exposure: Quantifies organizational exposure to identity-based attacks

8.2 BloodHound CE — Docker Containers & Service Status



BloodHound service (bloodhound.service) status: active (exited) — this is normal for a docker-compose orchestrator service. The service successfully launched all containers (ExecStart: /usr/bin/docker compose up -d, code=exited status=0/SUCCESS). All three containers were created 23 hours prior to capture. The service is enabled and set to start on boot.

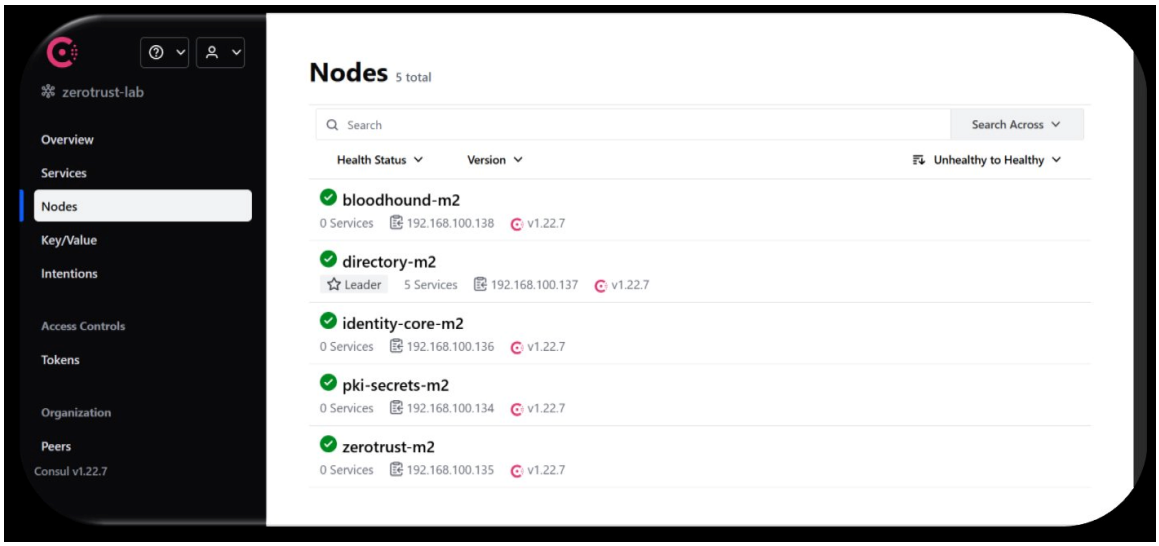
8.3 Neo4j Browser — Graph Database



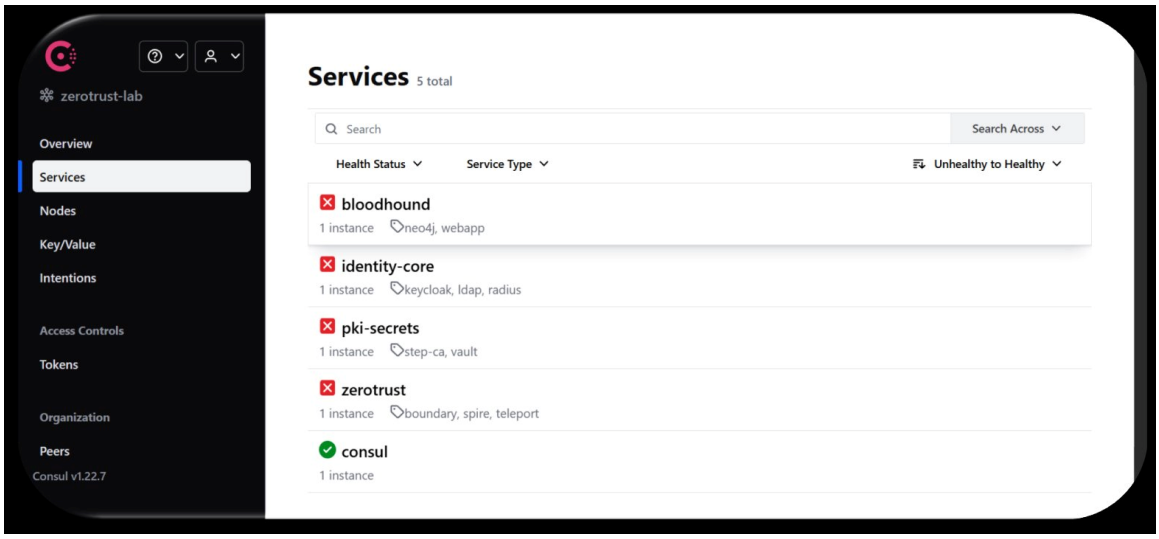
9. Consul Service Mesh — Full Overview

HashiCorp Consul provides the service mesh, service discovery, health checking, and dynamic configuration layer for all five VMs in Machine 2. Consul runs as a server on directory-m2 and as a client on all four other VMs, forming a unified service catalog for the zerotrust-lab datacenter.

9.1 Consul Nodes Dashboard



9.2 Consul Services Dashboard

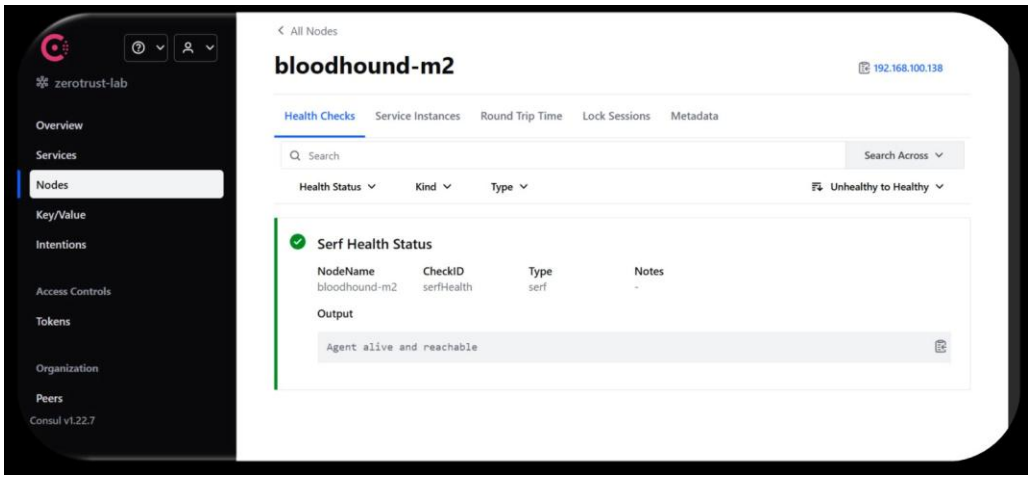


Five services are registered in the Consul service catalog:

Service	Health	Tags / Components
bloodhound	Warning (X)	neo4j, webapp
identity-core	Warning (X)	keycloak, ldap, radius
pki-secrets	Warning (X)	step-ca, vault
zerotrust	Warning (X)	boundary, spire, teleport
consul	Healthy (green)	(no tags — core Consul service)

Note: The four non-consul services show warning health status (red X). This indicates the health check probes for those services are not yet fully configured or passing at the time of capture — the underlying services themselves (Keycloak, LDAP, Vault, Teleport, BloodHound) are confirmed running per their individual systemctl and docker status checks. The consul service itself is fully healthy (green).

9.3 Consul Node Detail — BloodHound-M2

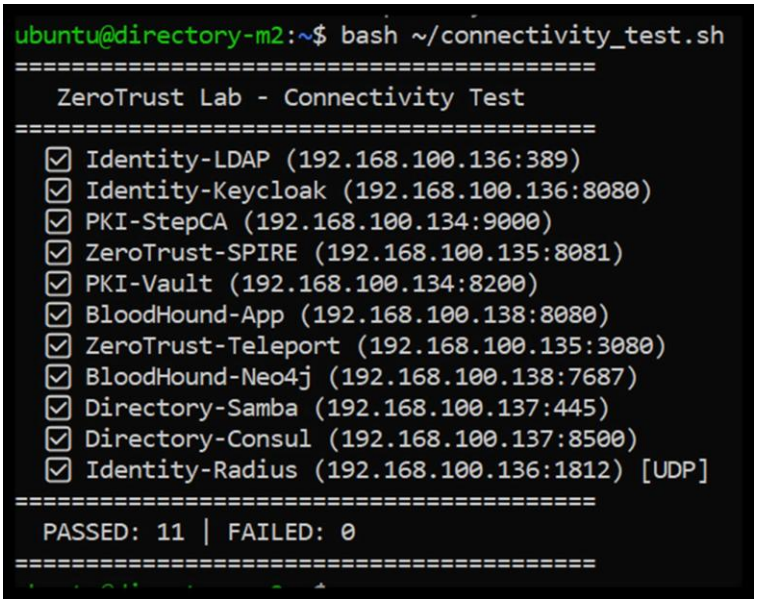


The bloodhound-m2 node detail confirms the Consul agent is alive and reachable. The Serf Health Check (CheckID: serfHealth, Type: serf) returns: "Agent alive and reachable." The node IP is 192.168.100.138 and is running Consul v1.22.7.

10. Hardening & Verification

All services on Machine 2 have been hardened and verified for production-like operation in the Zero Trust Lab. The following measures are confirmed in place:

10.1 Full Lab Connectivity Test



The connectivity test script (bash ~/connectivity_test.sh) was run from directory-m2 and confirmed all 11 service endpoints are reachable:

Service	Endpoint	Protocol
Identity-LDAP	192.168.100.136:389	TCP
Identity-Keycloak	192.168.100.136:8080	TCP
PKI-StepCA	192.168.100.134:9000	TCP
ZeroTrust-SPIRE	192.168.100.135:8081	TCP
PKI-Vault	192.168.100.134:8200	TCP
BloodHound-App	192.168.100.138:8080	TCP
ZeroTrust-Teleport	192.168.100.135:3080	TCP
BloodHound-Neo4j	192.168.100.138:7687	TCP
Directory-Samba	192.168.100.137:445	TCP
Directory-Consul	192.168.100.137:8500	TCP
Identity-Radius	192.168.100.136:1812	UDP

Result: PASSED: 11 | FAILED: 0 — All services fully reachable and operational.

10.2 Hardening Measures Implemented

- **Passwordless SSH: Configured between all VMs for automated management and scripts**
- Service Persistence: All services (Keycloak, Step-CA, Teleport, BloodHound, Consul, FreeRADIUS, slapd, krb5-kdc) are enabled to start on boot via systemd (enabled; preset: enabled)
- Vault Auto-Unseal: Vault configured with Shamir seal (3 shares, threshold 2) — in production would be Raft/Transit auto-unseal
- Least Privilege: Teleport enforces least privilege access for all SSH, Kubernetes, and database sessions
- mTLS: All inter-service communication secured with mutual TLS certificates issued by Step-CA
- Zero Trust Principles: Every access request passes through Teleport (gateway) → Keycloak (identity) → FreeRADIUS/Kerberos (authentication) → Vault (secrets) pipeline

11. M2 Integration with Other Machines

Machine 2 serves as the identity and security backbone for the entire Zero Trust UTM cluster. All other machines depend on M2 for authentication, authorization, certificate management, and secrets delivery.

11.1 M2 Integration Table

Integration	Purpose	Protocol/Method
FortiGate	802.1X NAC	FreeRADIUS
FortiGate Admin	AAA	TACACS+
Network Devices	Device Auth	EAP-TLS (Step-CA)
Keycloak	SSO for management	OIDC/SAML
Vault	Dynamic Secrets	API

11.2 How M2 Feeds Into M3 (Intelligence & SOAR Plane)

- Authentication logs from Keycloak, FreeRADIUS, Kerberos, and Teleport are forwarded to M3's Wazuh SIEM via syslog/Kafka
- BloodHound attack path data feeds into M3's threat intelligence pipeline for automated alerting
- Vault audit logs are ingested by M3 for secrets access monitoring and anomaly detection
- Consul service mesh telemetry is forwarded to M3 for service-level monitoring

11.3 How M2 Controls M1 Network Access

- FreeRADIUS (192.168.100.136:1812 UDP) provides 802.1X RADIUS authentication for FortiGate on M1
- TACACS+ provides AAA (Authentication, Authorization, Accounting) for FortiGate administrative access
- Step-CA issues EAP-TLS device certificates for network device authentication via FortiGate
- Keycloak provides OIDC/SAML SSO for FortiGate management web interface

12. Data Flow Summary

12.1 Authentication Flow

The complete authentication flow for a user or device requesting access to a protected resource:

1	User / Device → Teleport (192.168.100.135:3080): Access request received. Teleport enforces MFA, Device Trust, Least Privilege. Session recording begins.
2	Teleport → Keycloak (192.168.100.136:8080): Redirects for OIDC/SAML SSO. Keycloak validates credentials, enforces MFA/2FA, issues JWT token.
3	Keycloak → OpenLDAP/Samba AD (192.168.100.136:389 / 192.168.100.137:445): Directory lookup for user membership, groups, OUs, Policies & GPOs.
4	Keycloak → FreeRADIUS/Kerberos (192.168.100.136:1812): Network AAA authentication. Kerberos TGT/TGS issuance for SSO to network services.
5	Policy Engine → Authorization Decision: BBAC/ABAC policies evaluated. Device posture, context (IP, Geo, Risk), dynamic policies applied. Continuous evaluation.
6	Vault (192.168.100.134:8200) → Secrets Delivery: Access granted. Dynamic secrets retrieved. Just-in-Time access provisioned. All actions audit logged.

12.2 PKI / Certificate Flow

Certificate issuance and delivery flow:

- Certificate Request: User/Service/Device sends a certificate signing request (CSR) via mTLS/ACME/API to PKI-Secrets-M2 (192.168.100.134:9000)
- Request AuthN: Requestor authenticates via mTLS, ACME challenge, or API token
- Step-CA / Vault PKI Engine: Validates request, signs certificate using the appropriate CA (Step-CA for ACME/TLS, EJBCA for enterprise, Vault PKI for dynamic)
- Signed Certificate Delivered: TLS/mTLS/Client/Server certificate returned to the requestor
- Secure Delivery: Certificate securely delivered to the target service. Auto-rotation and renewal scheduled.

12.3 Secrets Flow

- App / Service Requests Secret: Application calls Vault API (http://127.0.0.1:8200 internally or 192.168.100.134:8200 from other VMs)
- Vault Validates Request: Checks AppRole/token authentication and ACL policies
- Vault Retrieves Secret: Fetches from Key/Value store, generates dynamic credential, or issues short-lived token
- Secret Delivered: Secret returned to the requesting application. Access is audited. TTL enforced for auto-expiry.
- Conjur Integration: CyberArk Conjur handles privileged access management (PAM) secrets for applications requiring enterprise-grade secrets governance

13. Appendix — Quick Reference

13.1 All M2 Service Endpoints

VM / Host	Service	Port	Protocol
directory-m2 (.137)	Samba AD / LDAP	445	SMB/TCP
directory-m2 (.137)	Consul Server	8301 / 8500	TCP (gossip/HTTP)
pki-secrets-m2 (.134)	Step-CA (ACME/TLS)	9000	HTTPS
pki-secrets-m2 (.134)	HashiCorp Vault	8200	HTTP (internal)
pki-secrets-m2 (.134)	EJBCA Admin	8444	HTTPS
pki-secrets-m2 (.134)	Conjur	8080	HTTP
identity-core-m2 (.136)	OpenLDAP (slapd)	389	LDAP/TCP
identity-core-m2 (.136)	Keycloak	8080	HTTP
identity-core-m2 (.136)	FreeRADIUS	1812	UDP (RADIUS)
identity-core-m2 (.136)	Kerberos KDC	88 (standard)	TCP/UDP
zerotrust-m2 (.135)	Teleport Proxy	3080	HTTPS/gRPC
zerotrust-m2 (.135)	SPIRE Agent	8081	TCP
bloodhound-m2 (.138)	BloodHound CE	8080	HTTP
bloodhound-m2 (.138)	Neo4j Browser	7474	HTTP
bloodhound-m2 (.138)	Neo4j Bolt	7687	TCP
bloodhound-m2 (.138)	PostgreSQL	5432	TCP

13.2 VM IP Reference

VM Name	IP Address	Primary Role
directory-m2	**192.168.100.137**	Samba AD Domain Controller + Consul Server
pki-secrets-m2	**192.168.100.134**	Vault + Step-CA + EJBCA + Conjur
identity-core-m2	**192.168.100.136**	Keycloak + OpenLDAP + FreeRADIUS + Kerberos
zerotrust-m2	**192.168.100.135**	Teleport Zero Trust Access Gateway
bloodhound-m2	**192.168.100.138**	BloodHound CE + Neo4j Graph Database

M3

Intelligence & SOAR Plane

Machine-3

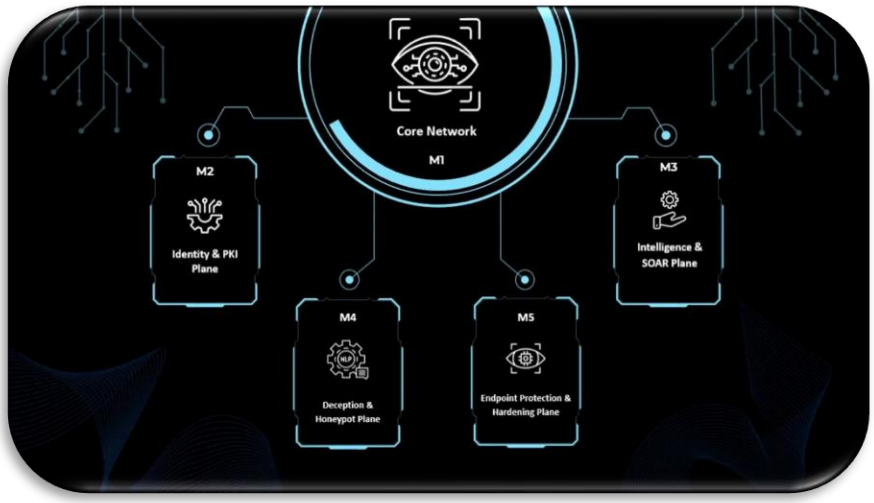
Architecture Overview

Machine 3 (M3) is the Intelligence and SOAR (Security Orchestration, Automation & Response) Plane of the Zero Trust UTM lab. It acts as the operational brain of the entire cluster, centralizing log ingestion from all machines, performing deep threat intelligence enrichment, detecting threats in real time, and orchestrating automated responses across the network. While M1 enforces network security policies and M2 manages identity and PKI, M3 provides the intelligence layer that makes the entire system self-aware and self-defending.

M3 operates on the Zero Trust principle that every event must be verified, every alert must be correlated, and every confirmed threat must trigger an automated, measurable response with no manual intervention required for Level 10+ severity alerts.

SIEM + Threat Intelligence + Automated Response

The Brain of the Zero Trust Lab



1. Machine 3 — Executive Summary

1.1 Executive Summary

Machine 3 (M3) is the Intelligence and SOAR (Security Orchestration, Automation & Response) Plane of the Zero Trust UTM lab. It acts as the operational brain of the entire cluster, centralizing log ingestion from all machines, performing deep threat intelligence enrichment, detecting threats in real time, and orchestrating automated responses across the network. While M1 enforces network security policies and M2 manages identity and PKI, M3 provides the intelligence layer that makes the entire system self-aware and self-defending.

M3 operates on the Zero Trust principle that every event must be verified, every alert must be correlated, and every confirmed threat must trigger an automated, measurable response with no manual intervention required for Level 10+ severity alerts.

1.2 Why M3 Requires 32 GB RAM

M3 has the highest RAM allocation in the cluster (32 GB out of a total cluster RAM of 104 GB) because it runs the most resource-intensive software stack in the lab. The components demanding the most memory include:

- OpenSearch — In-memory indexing engine for the SIEM data store, requiring significant heap allocation for fast search and analytics across large log volumes
- Apache Kafka — High-throughput distributed message streaming platform managing 48 concurrent topics
- Logstash — Three active pipelines performing real-time log parsing, GeoIP enrichment, and field normalization
- Wazuh Manager — Correlating alerts from 5 agents, evaluating 25 custom detection rules and 20 custom decoders
- MISP — Threat intelligence platform maintaining feeds from 19+ sources with tens of thousands of IOC attributes
- TheHive + Cortex — Case management and automated analysis engine running multiple analyzers concurrently
- IntelOwl v6.6.1 — 80 analyzers and 6 connectors running OSINT enrichment jobs
- Shuffle SOAR — Workflow orchestration engine managing 4 automated playbooks
- Dark Web CTI Tool — Custom Llama-3.3-70b-nvidia LLM running locally via Ollama with scraping threads

1.3 Full Log Pipeline

M3 implements a complete end-to-end security data pipeline:

1. COLLECT — Wazuh agents on all machines collect raw logs from servers, firewalls, endpoints, honeypots, and applications
2. INGEST — Logs are streamed into Apache Kafka (48 topics) for high-throughput, fault-tolerant ingestion
3. PROCESS — Logstash consumes Kafka topics through 3 pipelines, performing parsing, field extraction, GeoIP enrichment, and tagging
4. STORE — Processed, enriched logs are indexed in OpenSearch for persistent storage, search, and analytics
5. VISUALIZE — Wazuh Dashboard, Grafana, and Kibana provide real-time security visibility and metric dashboards on MONITOR-M3
6. DETECT — Wazuh evaluates all logs against 25 custom detection rules and 20 custom decoders; Level 10+ alerts escalate to SOAR, Level 12+ auto-create TheHive cases
7. SHARE — Threat intelligence is enriched via MISP, IntelOwl, Cortex, SpiderFoot, and OpenCTI, then shared with the broader community
8. RESPOND — Shuffle SOAR executes automated playbooks: blocking IPs on FortiGate, blocking domains on Pi-hole, creating incident cases in TheHive, and sending notifications

1.4 Outcome

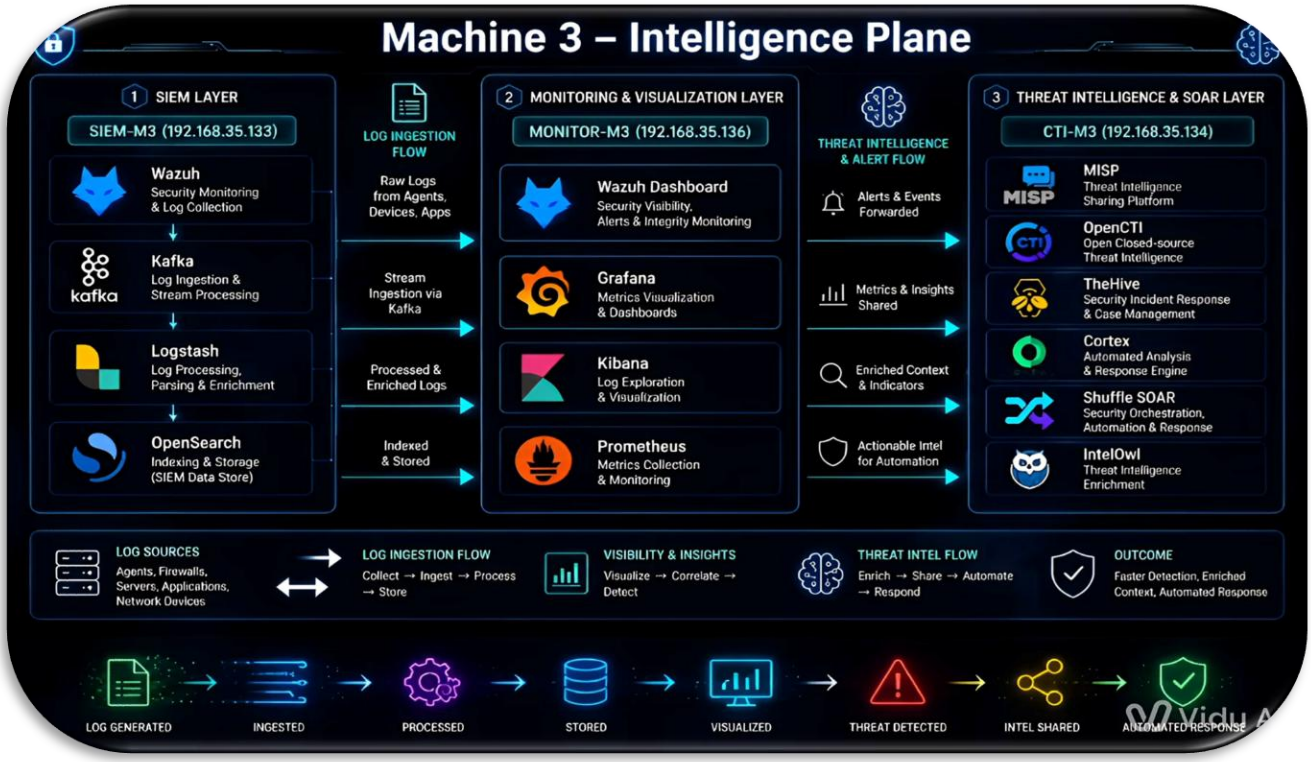
The M3 pipeline delivers three core capabilities to the Zero Trust lab:

- Faster Detection — Real-time alert processing with automated severity classification eliminates manual log review
- Enriched Context — Every alert is enriched with GeoIP data, threat intelligence feeds, IOC correlation, and OSINT analysis before human review
- Automated Response — Confirmed high-severity threats trigger automated network-level blocks, incident cases, and notifications in under 2 seconds

2. M3 Architecture Overview

2.1 M3 Intelligence Plane — Overall Architecture

The following diagram shows the complete three-VM architecture of Machine 3 and all data flows between the SIEM Layer, Monitoring & Visualization Layer, and Threat Intelligence & SOAR Layer.

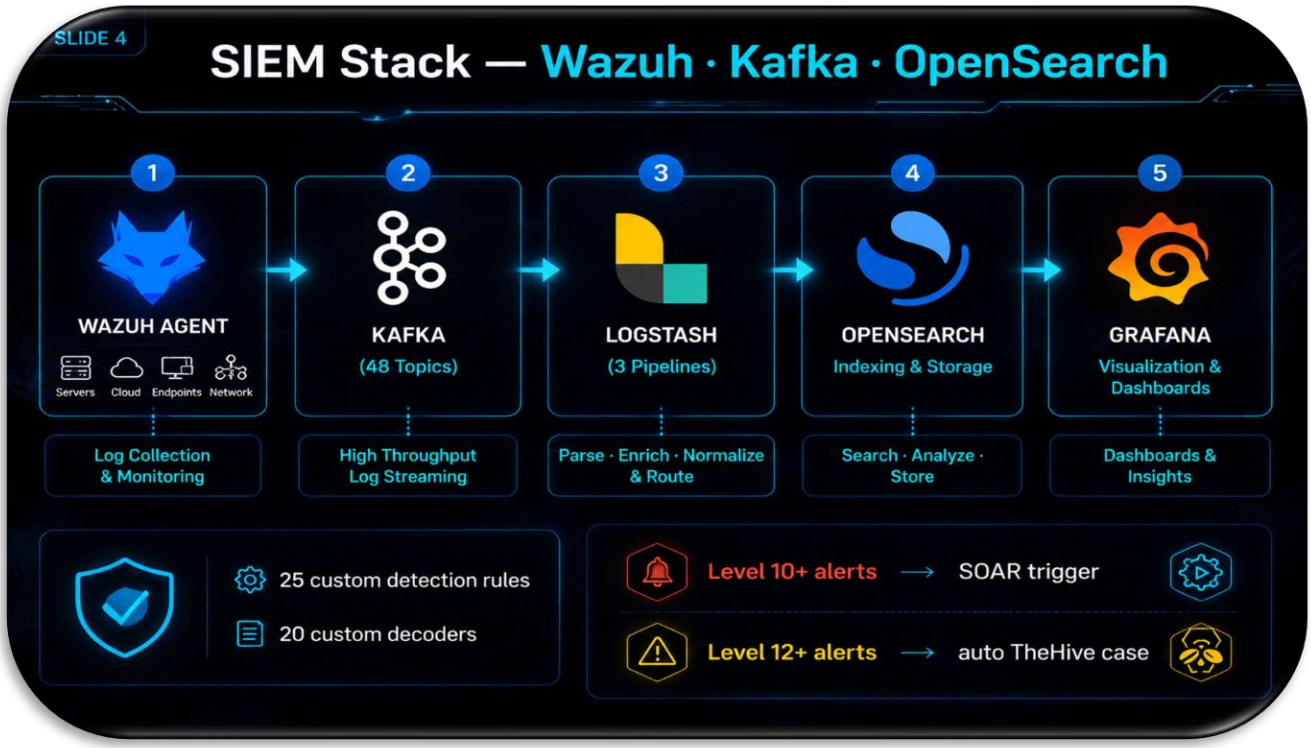


The architecture diagram reveals three distinct layers:

- SIEM Layer (SIEM-M3, 192.168.35.133): Wazuh → Kafka → Logstash → OpenSearch. Raw logs from agents, devices, and applications are ingested via Kafka, processed by Logstash, and stored in OpenSearch.
- Monitoring & Visualization Layer (MONITOR-M3, 192.168.35.136): Wazuh Dashboard, Grafana, Kibana, and Prometheus consume processed data for dashboards and metrics visualization.
- Threat Intelligence & SOAR Layer (CTI-M3, 192.168.35.134): MISP, OpenCTI, TheHive, Cortex, Shuffle SOAR, and IntelOwl perform threat enrichment, case management, and automated response.

The bottom flow banner confirms the complete pipeline: LOG GENERATED → INGESTED → PROCESSED → STORED → VISUALIZED → THREAT DETECTED → INTEL SHARED → AUTOMATED RESPONSE.

2.2 SIEM Stack — Wazuh · Kafka · OpenSearch



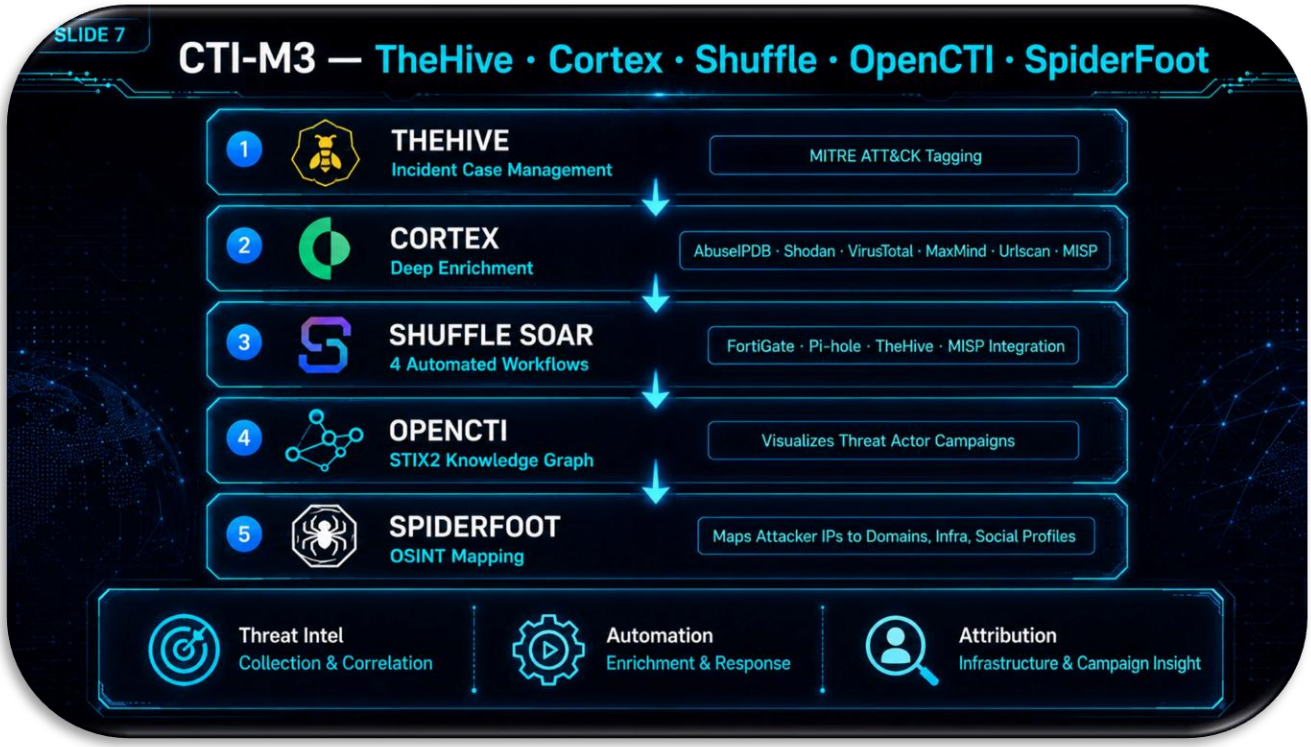
The SIEM stack diagram details the five-stage data processing pipeline:

- Stage 1 — Wazuh Agent: Collects logs from Servers, Cloud, Endpoints, and Network. Performs Log Collection & Monitoring.
- Stage 2 — Kafka (48 Topics): High Throughput Log Streaming. Decouples log producers from consumers with persistent message queuing.
- Stage 3 — Logstash (3 Pipelines): Parse · Enrich · Normalize & Route. Three distinct pipelines handle different log categories.
- Stage 4 — OpenSearch: Indexing & Storage. Search · Analyze · Store. Acts as the SIEM data store.
- Stage 5 — Grafana: Visualization & Dashboards. Dashboards & Insights for operational visibility.

Alert escalation logic (visible in the bottom panel of the diagram):

- 25 custom detection rules and 20 custom decoders are active
- Level 10+ alerts → SOAR trigger (Shuffle SOAR workflow activation)
- Level 12+ alerts → auto TheHive case (automatic incident case creation)

2.3 CTI-M3 Components — TheHive · Cortex · Shuffle · OpenCTI · SpiderFoot



The CTI-M3 component diagram (Slide 7) presents the five CTI tools deployed on VM3:

- 1. TheHive — Incident Case Management. Integration: MITRE ATT&CK Tagging. Provides structured incident response workflow.
- 2. Cortex — Deep Enrichment Engine. Analyzers: AbuseIPDB ·Shodan ·VirusTotal · MaxMind ·URLscan ·MISP. Automated IOC analysis at scale.
- 3. Shuffle SOAR — 4 Automated Workflows. Integrations: FortiGate ·Pi-hole ·TheHive ·MISP. Full security orchestration and automated response.
- 4. OpenCTI — STIX2 Knowledge Graph. Capability: Visualizes Threat Actor Campaigns. Structured threat intelligence storage and visualization.
- 5. SpiderFoot — OSINT Mapping. Capability: Maps Attacker IPs to Domains, Infrastructure, Social Profiles. Automated reconnaissance.

The bottom banner confirms the three pillars: Threat Intel (Collection & Correlation) · Automation (Enrichment & Response) · Attribution (Infrastructure & Campaign Insight).

3. Log Ingestion Flow

3.1 Overview

The log ingestion flow is the foundational data pipeline of M3. All security-relevant events from every machine in the Zero Trust lab are captured, streamed, processed, enriched, and stored in a structured, searchable format for threat detection and visualization.

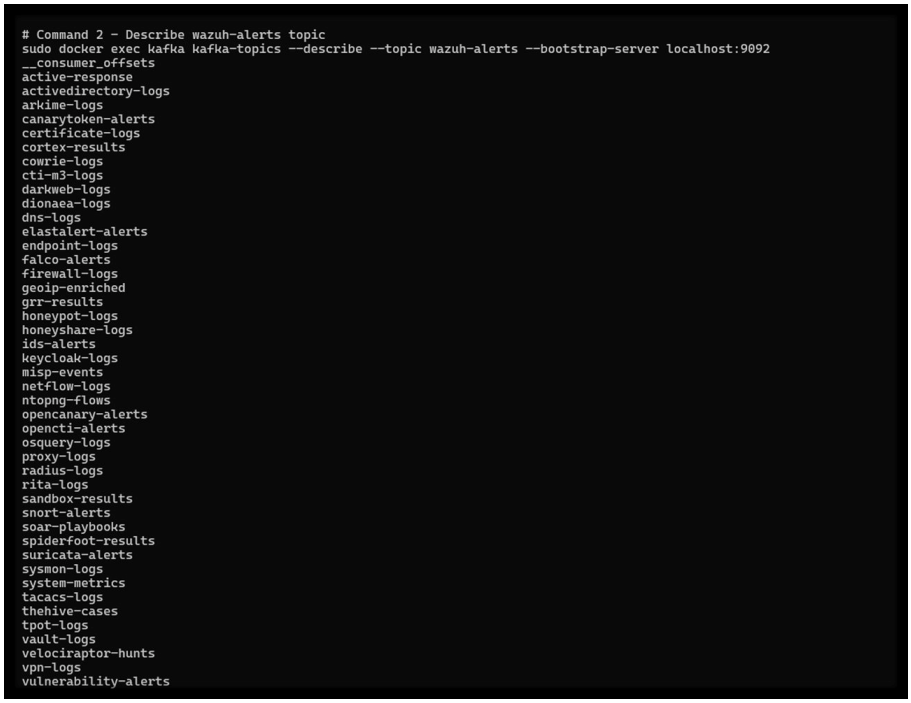
3.2 Stage 1 — Raw Log Sources

Log sources include all machines in the Zero Trust UTM cluster:

- Agents — Wazuh agents deployed on SIEM-M3, CTI-M3, and all honeypot machines
- Firewalls — FortiGate syslog output (TCP port 6514), OPNsense firewall logs
- Servers — Application servers, web servers, authentication servers
- Applications — Keycloak, Vault, RADIUS, and other M2 applications
- Network Devices — Suricata IDS alerts, Zeek connection logs, ntopng flow data
- Honeypots — T-Pot (tpot-m4), OpenCanary (opencanary-m4), Cowrie SSH honeypot, Dionaea, and others on M4

3.3 Stage 2 — Kafka Stream Ingestion (48 Topics)

Apache Kafka is configured with 48 dedicated topics for log streaming. The following complete topic list was extracted from a terminal session:



Kafka topic list — all 48 configured topics visible in terminal output from: sudo docker exec kafka kafka-topics --describe --topic wazuh-alerts --bootstrap-server localhost:9092

3.4 Stage 3 — Logstash Processing (3 Pipelines)



```
    "active-response",
    "geoip-enriched"
  ]
  codec => "json"
  group_id => "logstash-zerotrust"
  consumer_threads => 4
  decorate_events => true
}

beats {
  port => 5044
}

tcp {
  port => 6514
  type => "syslog"
  codec => "json"
}
}
filter {
if ![timestamp] {
  mutate {
    add_field => { "timestamp" => "%{@timestamp}" }
  }
}

if [@metadata][kafka][topic] {
  mutate {
    add_field => { "kafka_topic" => "%{[@metadata][kafka][topic]}" }
  }
}

if [src_ip] {
  geoip {
    source => "src_ip"
    target => "src_geoip"
    database => "/etc/logstash/geoip/GeoLite2-City.mmdb"
  }
}

if [dest_ip] {
  geoip {
    source => "dest_ip"
    target => "dest_geoip"
    database => "/etc/logstash/geoip/GeoLite2-City.mmdb"
  }
}

if [@metadata][kafka][topic] == "firewall-logs" {
  mutate { add_tag => ["firewall", "network", "machine1"] }
}
if [@metadata][kafka][topic] == "suricata-alerts" {
  mutate { add_tag => ["ids", "suricata", "machine1"] }
}
if [@metadata][kafka][topic] == "snort-alerts" {
  mutate { add_tag => ["ids", "snort", "machine1"] }
}
if [@metadata][kafka][topic] == "zeek-logs" {
  mutate { add_tag => ["ids", "zeek", "machine1"] }
}
if [@metadata][kafka][topic] in ["tpot-logs", "opencanary-alerts", "cowrie-logs", "dionaea-logs", "canarytoken-alerts", "honeyshare-logs", "honeypot-logs"] {
  mutate { add_tag => ["honeypot", "deception", "machine4"] }
}
if [@metadata][kafka][topic] == "darkweb-logs" {
```

The Logstash configuration visible in the image shows the following pipeline components:

Input Configuration:

- Kafka consumer: topics include "active-response" and "geoip-enriched"; codec = json; group_id = "logstash-zerotrust"; consumer_threads = 4; decorate_events = true
- Beats input: port 5044
- TCP input: port 6514; type = "syslog"; codec = "json"

Filter Configuration:

- Timestamp normalization: if no @timestamp field exists, it is added via mutate
- Kafka topic enrichment: adds field "kafka_topic" with value from [@metadata][kafka][topic]
- GeoIP enrichment for src_ip: source = "src_ip"; target = "src_geoip"; database = "/etc/logstash/geoip/GeoLite2-City.mmdb"
- GeoIP enrichment for dest_ip: source = "dest_ip"; target = "dest_geoip"; database = "/etc/logstash/geoip/GeoLite2-City.mmdb"

Topic-based Tagging:

- firewall-logs → tags: ["firewall", "network", "machine1"]
- suricata-alerts → tags: ["ids", "suricata", "machine1"]
- snort-alerts → tags: ["ids", "snort", "machine1"]
- zeek-logs → tags: ["ids", "zeek", "machine1"]
- tpot-logs, opencanary-alerts, cowrie-logs, dionaea-logs, canarytoken-alerts, honeyshare-logs, honeypot-logs → tags: ["honeypot", "deception", "machine4"]
- darkweb-logs → tags: [partially visible in image]

3.5 Stages 4 & 5 — OpenSearch Storage and Visualization

Processed and enriched log records are output by Logstash into OpenSearch for indexing and persistent storage. OpenSearch serves as the SIEM data store, enabling fast full-text search, aggregation queries, and time-series analytics across all log types.

Three visualization platforms consume data from OpenSearch:

- Wazuh Dashboard (MONITOR-M3, 192.168.35.136) — Security-focused view: alerts, compliance, integrity monitoring, agent status
- Kibana (MONITOR-M3) — General log exploration, custom visualizations, index pattern management
- Grafana (MONITOR-M3) — Metrics and time-series dashboards, Prometheus integration for system metrics

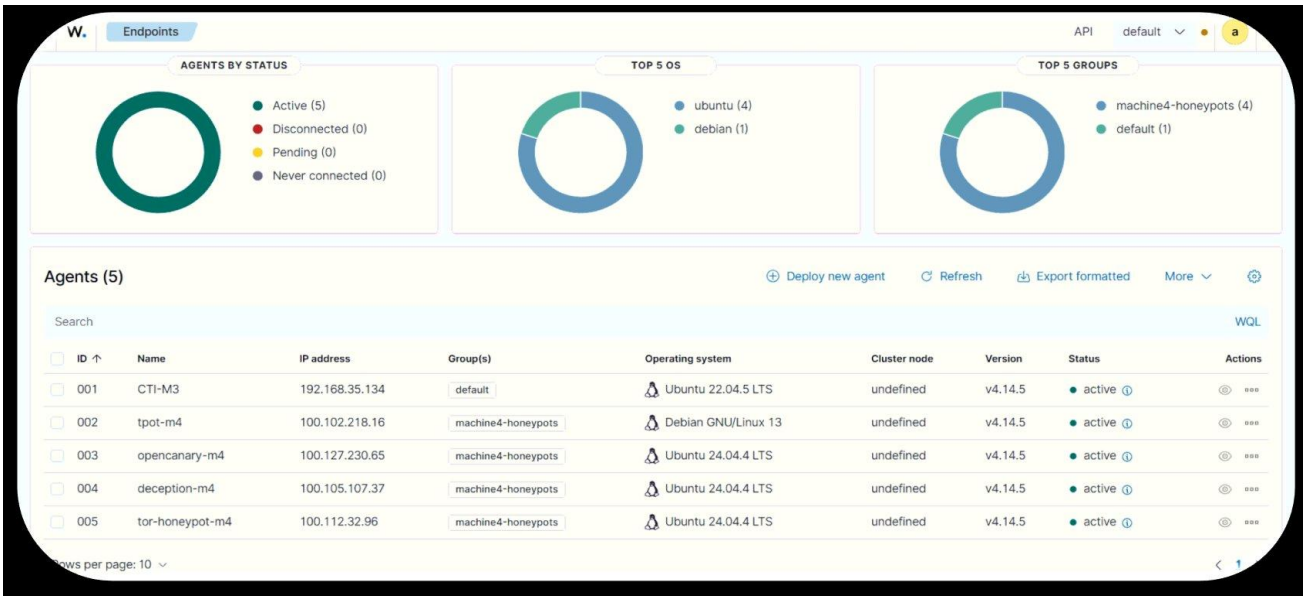
4. Virtual Machine Sections

4.1 SIEM-M3 — 192.168.35.133

4.1.1 Role & Purpose

SIEM-M3 is the primary log collection and event management engine of the Zero Trust lab. It aggregates logs from all five Wazuh agents across the cluster, processes them through Kafka and Logstash pipelines, and stores enriched records in OpenSearch. It is also responsible for alert correlation, custom rule evaluation, and triggering downstream SOAR responses.

4.1.2 Wazuh Agent Management



The Wazuh agent dashboard confirms 5 active agents

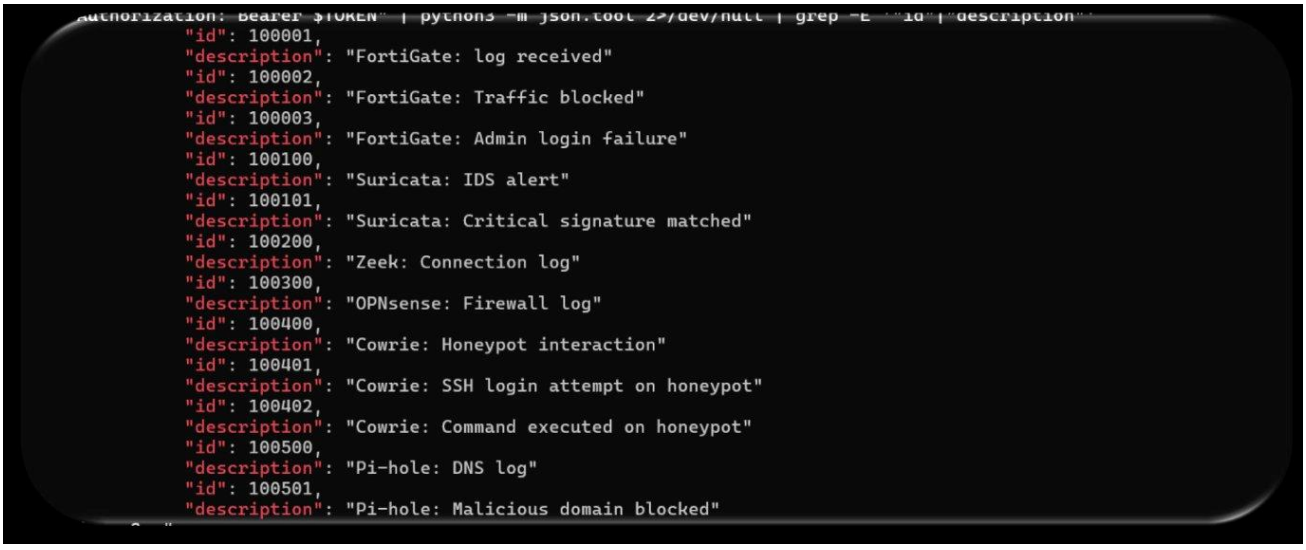
Dashboard summary statistics: Active (5), Disconnected (0), Pending (0), Never connected (0). Top 5 OS: Ubuntu (4), Debian (1). Top 5 Groups: machine4-honeypots (4), default (1).

Note: The 100.x.x.x IP addresses belong to the Tailscale VPN overlay network used to connect M4 honeypot machines to M3.

4.1.3 Custom Detection Rules



Wazuh Rules management interface showing custom rule file "zerotrust-rules.xml" with rule ID 100001 (FortiGate: log received, Level 3, syslog group).



The Wazuh Rules interface confirms that custom rules are stored in a file named zerotrust-rules.xml. The following rule IDs and descriptions were extracted from the API terminal output:

Total custom rules: 25. Total custom decoders: 20. All rules are stored in zerotrust-rules.xml. Level 10+ rules trigger Shuffle SOAR workflows. Level 12+ rules trigger automatic TheHive case creation.

4.1.4 Alert Escalation Logic

Wazuh alert levels are mapped to automated response actions:

- Level 3: Informational — Logged and indexed in OpenSearch only (e.g., Rule 100001: FortiGate log received)
- Level 10+ — Triggers Shuffle SOAR webhook → Automated workflow execution (FortiGate block, notification)
- Level 12+ — Automatically creates a new case in TheHive via MISP integration for analyst review

4.2 MONITOR-M3

4.2.1 Role & Purpose

MONITOR-M3 is the dedicated visualization and monitoring VM of Machine 3. It hosts the Wazuh Dashboard, Grafana, Kibana, and Prometheus to provide security analysts with real-time visibility into all security events, system metrics, log exploration, and operational dashboards. This VM consumes processed data from OpenSearch (on SIEM-M3) and metrics from Prometheus exporters.

Note: No dedicated MONITOR-M3 dashboard screenshots were provided in the current image set. The monitoring layer is described based on the architecture diagrams. Screenshots will be added in a subsequent documentation session.

4.2.2 Components

Wazuh Dashboard:

Provides Security Visibility, Alerts management, and Integrity Monitoring. Connects to OpenSearch on SIEM-M3 to display real-time security events, agent status, compliance reports, and threat detection summaries. Accessible via MONITOR-M3 (192.168.35.136).

Grafana:

Metrics Visualization & Dashboards. Pulls data from Prometheus for system metrics (CPU, memory, disk, network) and from OpenSearch for security metrics. Used for time-series analysis of security event volumes, alert trends, and infrastructure health.

Kibana:

Log Exploration & Visualization. Provides ad-hoc log query interface, custom visualizations, and index management for the OpenSearch data store.

Prometheus:

Metrics Collection & Monitoring. Scrapes metrics from all machines in the cluster via exporters. Feeds data into Grafana for dashboard rendering.

4.3 CTI-M3 — 192.168.35.134

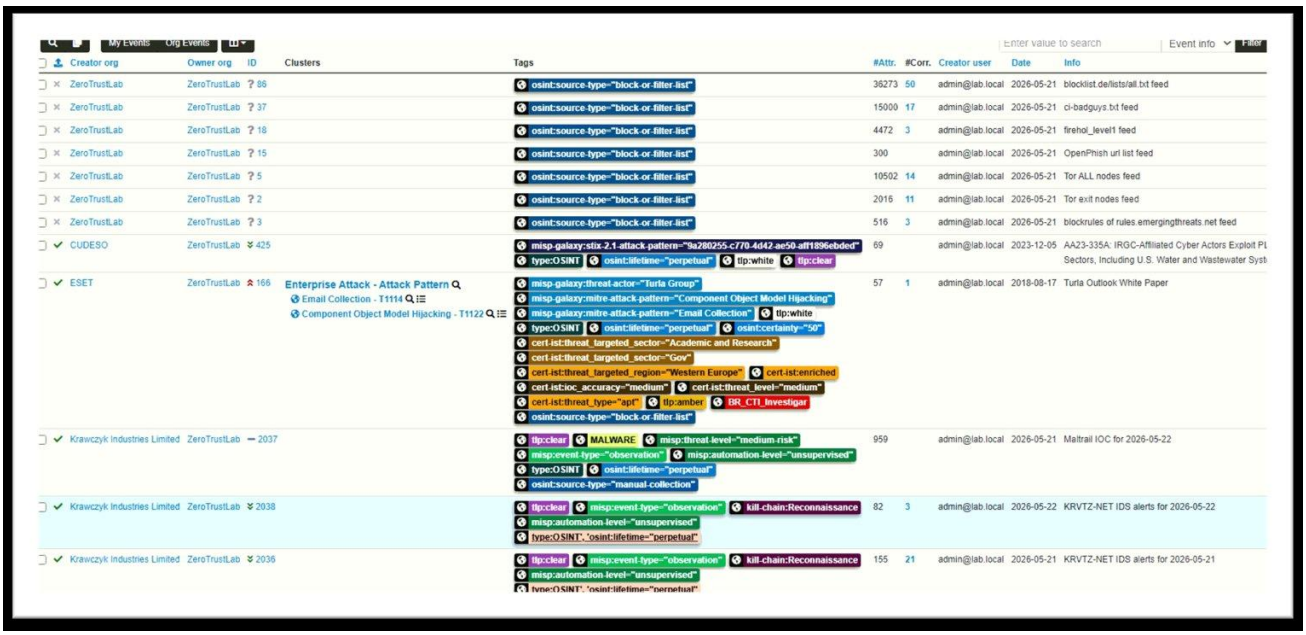


4.3.1 Role & Purpose

CTI-M3 is the Cyber Threat Intelligence and Automated Response VM. It hosts the full threat intelligence stack including MISP for IOC management, OpenCTI for structured threat knowledge, TheHive for incident case management, Cortex for automated enrichment, Shuffle SOAR for playbook automation, IntelOwl for OSINT enrichment, SpiderFoot for OSINT reconnaissance, and a custom-built Dark Web CTI Tool powered by a local LLM.

4.3.2 A. MISP — Threat Intelligence Sharing Platform

MISP (Malware Information Sharing Platform) is deployed at IP 192.168.35.134 and serves as the central repository for all threat intelligence indicators (IOCs). It ingests automated feeds from 19+ external sources and provides enriched intelligence to TheHive, IntelOwl, and Cortex.

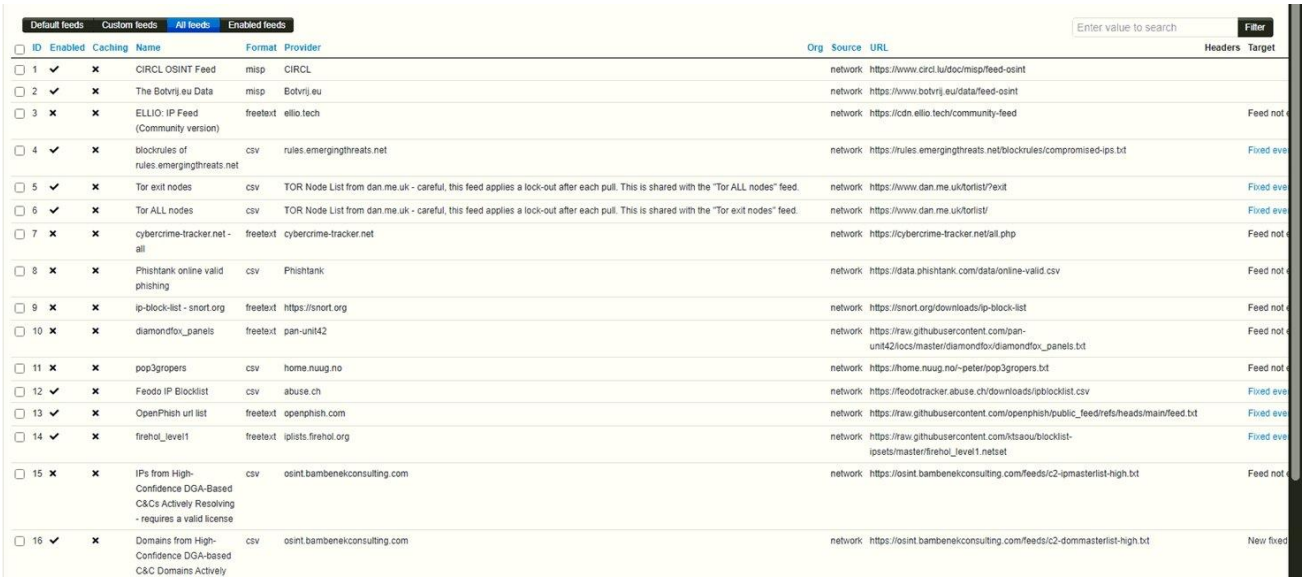


The MISP Events dashboard shows the following key events:

- **Organization: ZeroTrustLab —** Multiple events with tag "osint:source-type=block-or-filter-list". Event IDs: 86 (36,273 attributes, 50 correlations), 37 (15,000 attributes, 17 correlations), 18 (4,472 attributes, 3 correlations), 15 (300 attributes), 5 (10,502 attributes, 14 correlations), 2 (2,016 attributes, 11 correlations), 3 (516 attributes, 3 correlations). Dates: 2026-05-21. Descriptions: blocklist.de/lists/all.txt feed, ci-badguys.txt feed, firehol_level1 feed, OpenPhish url list feed, Tor ALL nodes feed, Tor exit nodes feed, blockrules of rules.emerginghreats.net feed.
- **Organization: CUDESO —** Event ID: 425. Tags: misp-galaxy:stix-2.1-attack-pattern="9a280255-c770-4d42-ae50-aff1896ebded", tlp:white, tlp:clear. Date: 2023-12-05.

Title: AA23-335A: IRGC-Affiliated Cyber Actors Exploit PLC Sectors, Including U.S. Water and Wastewater Systems.

- **Organization: ESET (Owner: ZeroTrustLab)** — Event ID: 166. Cluster: Enterprise Attack – Attack Pattern. Tags: misp-galaxy:threat-actor="Turla Group", misp-galaxy:mitre-attack-pattern="Component Object Model Hijacking", misp-galaxy:mitre-attack-pattern="Email Collection – T1114", type:OSINT, osint:lifetime="perpetual", osint:certainty="50", cert-ist:threat_targeted_sector="Academic and Research", cert-ist:threat_targeted_sector="Gov", cert-ist:threat_targeted_region="Western Europe" (cert-ist:enriched), cert-ist:ioc_accuracy="medium", cert-ist:threat_level="medium", cert-ist:threat_type="apt", tlp:amber, BR_CTI_Investigar, osint:source-type="block-or-filter-list". Date: 2018-08-17. Title: Turla Outlook White Paper.
- **Organization: Krawczyk Industries Limited (Owner: ZeroTrustLab)** — Events 2037 (959 attributes, Maltrail IOC for 2026-05-22, tags: tlp:clear, MALWARE, misp:threat-level="medium-risk", misp:event-type="observation"), 2038 (82 attributes, 3 correlations, KRVTZ-NET IDS alerts for 2026-05-22, kill-chain:Reconnaissance), 2036 (155 attributes, 21 correlations, KRVTZ-NET IDS alerts for 2026-05-21).

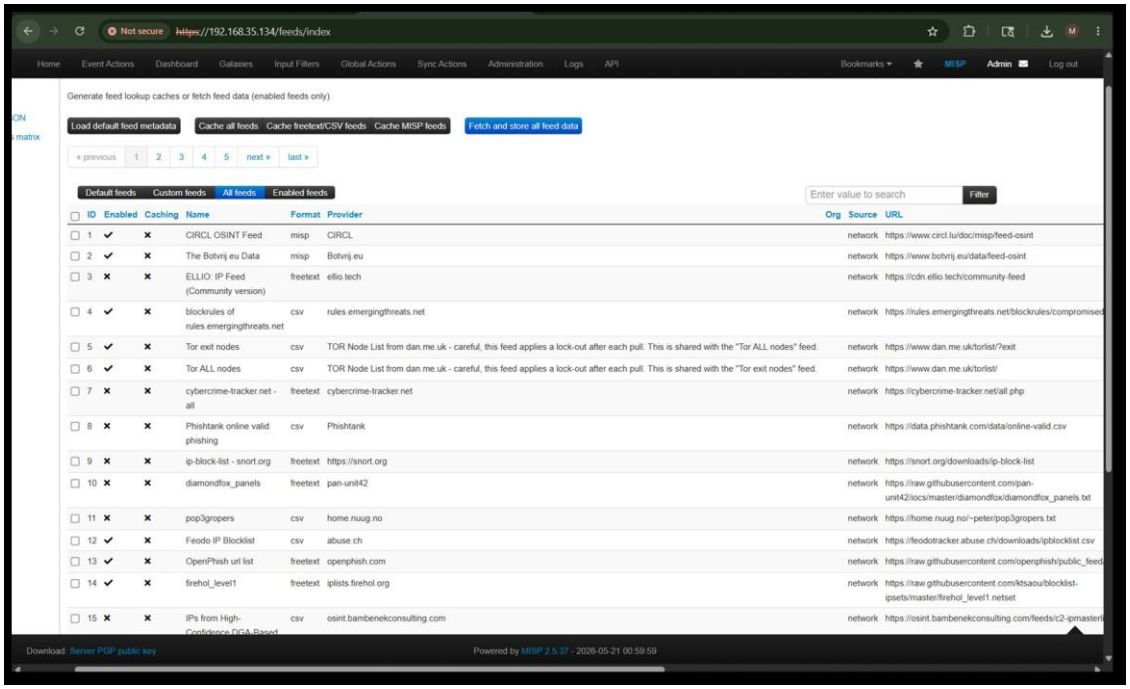


MISP Feed list — All feeds view showing feed IDs 1-16 with enabled status, caching status, name, format, provider, source type, and URL.

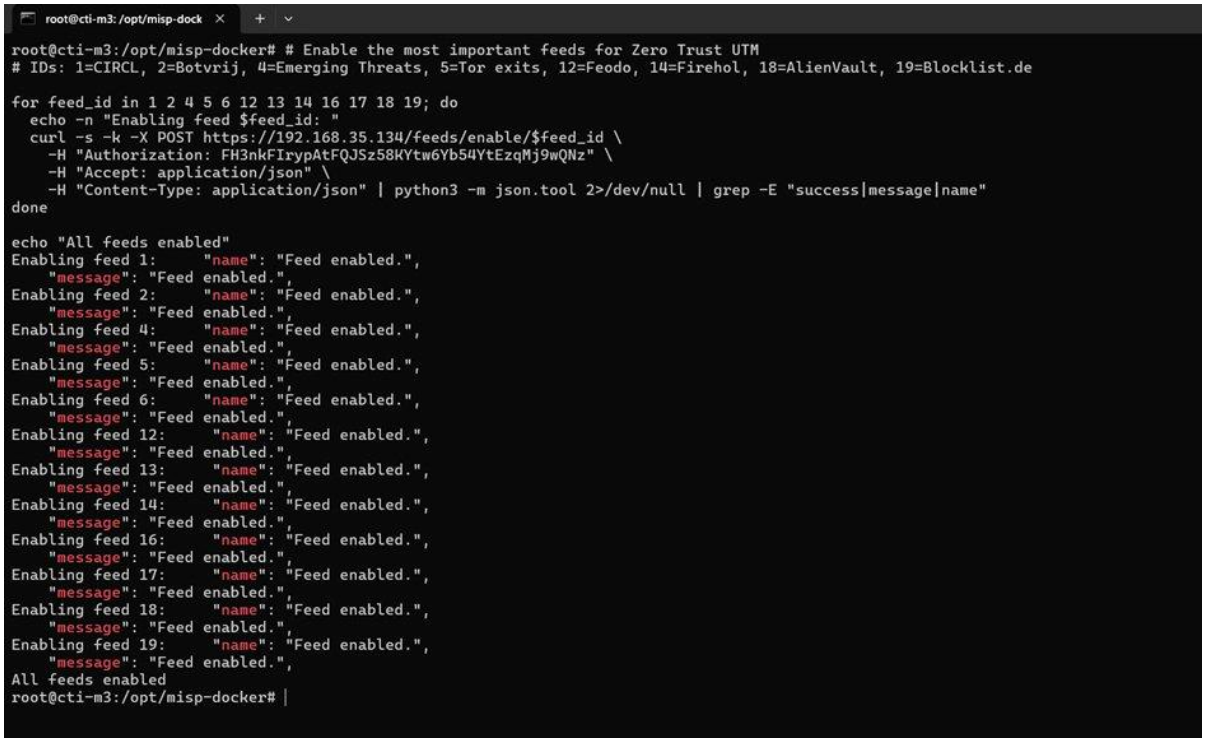
The MISP Feeds list shows the following feeds (IDs 1–16 visible):

ID	Enabled	Name	Format	Provider	URL
1	Yes	CIRCL OSINT Feed	misp	CIRCL	https://www.circl.lu/doc/misp/feed-osint
2	Yes	The Botvrij.eu Data	misp	Botvrij.eu	https://www.botvrij.eu/data/feed-osint
3	No	ELLIO: IP Feed (Community version)	freetext	ellio.tech	https://cdn.ellio.tech/community-feed
4	Yes	blockrules of rules.emerginghreats.net	csv	rules.emerginghreats.net	https://rules.emerginghreats.net/blockrules/compromised-ips.txt
5	Yes	Tor exit nodes	csv	TOR Node List from dan.me.uk	https://www.dan.me.uk/torlist/?exit
6	Yes	Tor ALL nodes	csv	TOR Node List from dan.me.uk	https://www.dan.me.uk/torlist/
7	No	cybercrime-tracker.net - all	freetext	cybercrime-tracker.net	https://cybercrime-tracker.net/all.php
8	No	Phishtank online valid phishing	csv	Phishtank	https://data.phishtank.com/data/online-valid.csv
9	No	ip-block-list - snort.org	freetext	https://snort.org	https://snort.org/downloads/ip-block-list
10	No	diamondfox_panels	freetext	pan-unit42	https://raw.githubusercontent.com/pan-unit42/iocs/master/diamondfox/diamondfox_panels.txt
11	No	pop3gropers	csv	home.nuug.no	https://home.nuug.no/~peter/pop3gropers.txt
12	Yes	Feodo IP Blocklist	csv	abuse.ch	https://feodotracker.abuse.ch/downloads/ipblocklist.csv
13	Yes	OpenPhish url list	freetext	openphish.com	https://raw.githubusercontent.com/openphish/public_feed/refs/heads/main/feed.txt
14	Yes	firehol_level1	freetext	iplists.firehol.org	https://raw.githubusercontent.com/ktsaou/blocklist-ipsets/master/firehol_level1.netset
15	No	IPs from High-Confidence DGA-Based C&Cs Actively Resolving	csv	osint.bambenekconsulting.com	https://osint.bambenekconsulting.com/feeds/c2-ipmasterlist-high.txt
16	Yes	Domains from High-Confidence DGA-based C&C Domains Actively	csv	osint.bambenekconsulting.com	https://osint.bambenekconsulting.com/feeds/c2-dommasterlist-high.txt

Note: Feed list continues beyond ID 16. Additional pages contain further feeds including AlienVault OTX (ID 17), Blocklist.de (ID 19), and others per the feed enabling script.



MISP Feeds page at 192.168.35.134/feeds/index showing All Feeds tab with IDs 1-15 visible, confirming the MISP instance is running at CTI-M3 IP.



Terminal script enabling MISP feeds. Script iterates over feed IDs 1, 2, 4, 5, 6, 12, 13, 14, 16, 17, 18, 19 using MISP API. All feeds return "Feed enabled." status. Labels: IDs = CIRCL, Botvrij, Emerging Threats, Tor exits, Tor all, Feodo, OpenPhish, Firehol, Blocklist.de, AlienVault, and others.

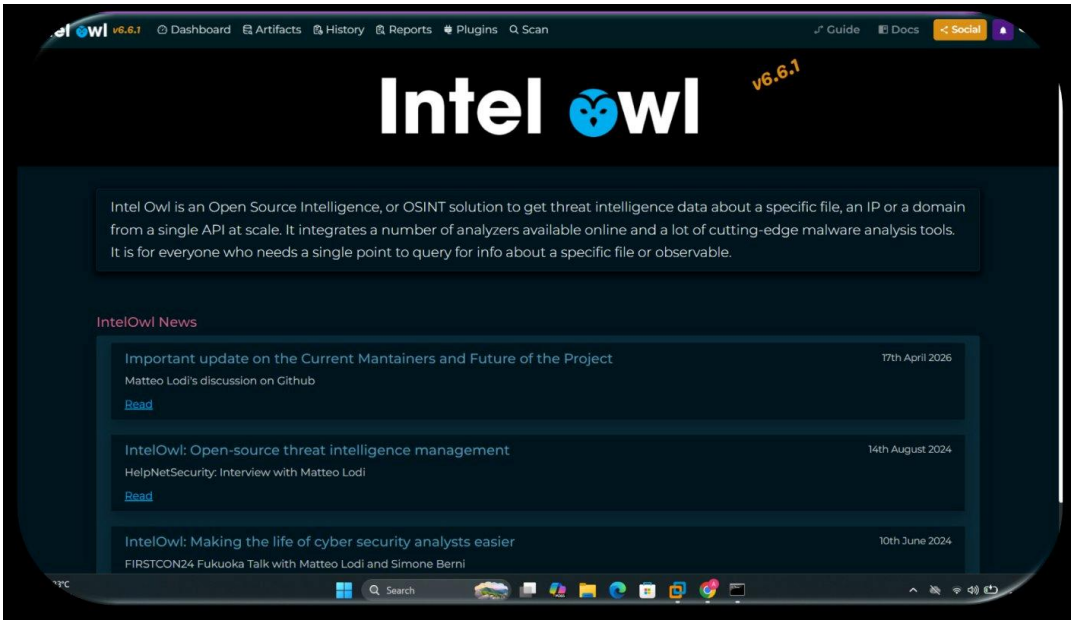
The feed enabling script (visible in the terminal) demonstrates the automated feed activation process:

- Authorization: Bearer token authentication to MISP API at https://192.168.35.134/feeds/enable/$feed_id
- Enabled feed IDs: 1 (CIRCL), 2 (Botvrij), 4 (Emerging Threats), 5 (Tor exits), 6 (Tor ALL), 12 (Feodo), 13 (OpenPhish), 14 (Firehol), 16, 17, 18 (AlienVault), 19 (Blocklist.de)
- All 13 feeds returned: "name": "Feed enabled.", "message": "Feed enabled."
- Comment in script: "Enable the most important feeds for Zero Trust UTM"

4.3.3 B. IntelOwl — Threat Intelligence Enrichment



IntelOwl v6.6.1 is an Open Source Intelligence (OSINT) platform that aggregates threat data about files, IPs, domains, and hashes from a single API. It is deployed on CTI-M3 and integrated with MISP and OpenCTI via connectors.



IntelOwl platform description (visible in screenshot): "Intel Owl is an Open Source Intelligence, or OSINT solution to get threat intelligence data about a specific file, an IP or a domain from a single API at scale. It integrates a number of analyzers available online and a lot of cutting-edge malware analysis tools. It is for everyone who needs a single point to query for info about a specific file or observable." Version: v6.6.1.

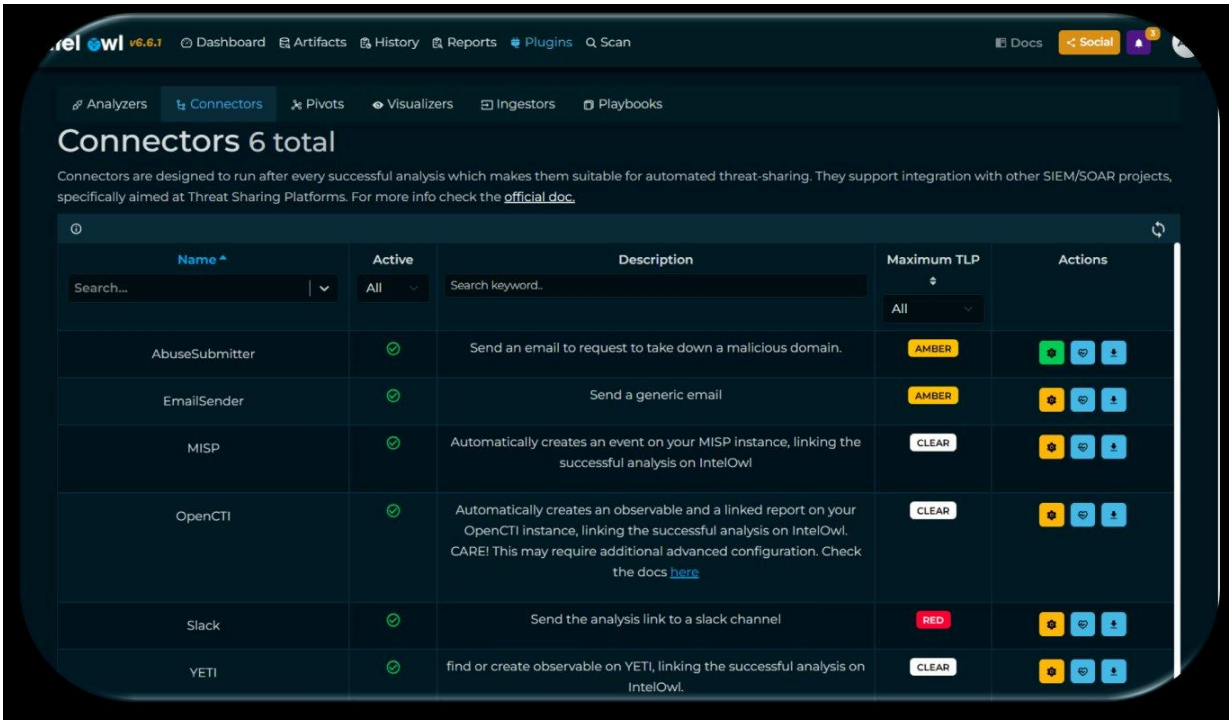
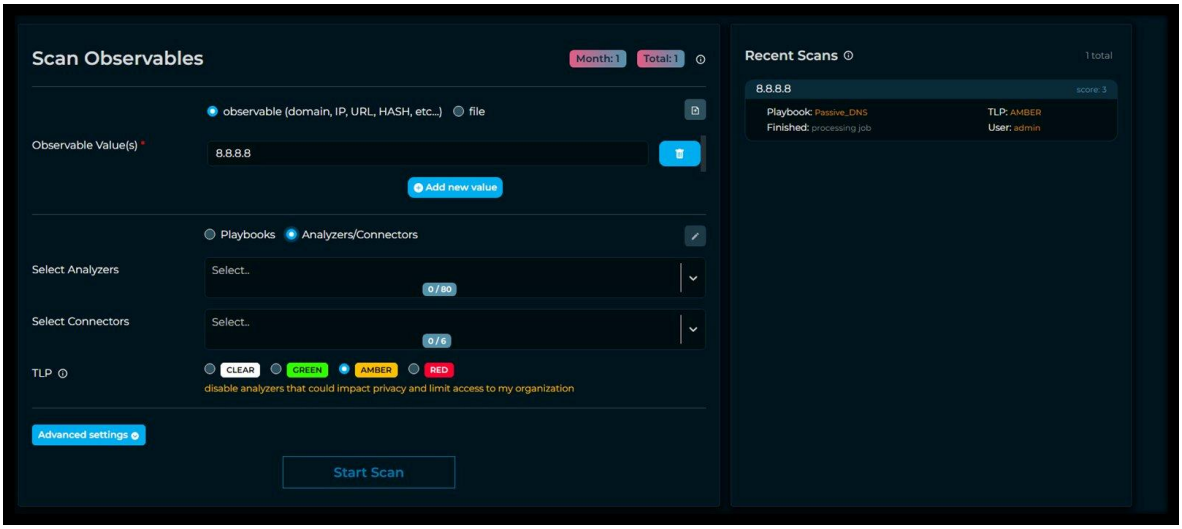


Figure 14: IntelOwl Connectors page showing 6 total connectors: AbuseSubmitter, EmailSender, MISP, OpenCTI, Slack, and YETI — all active with their descriptions and TLP settings.

IntelOwl Connectors (6 total, all active):

Connector Name	Status	Description	Max TLP
AbuseSubmitter	Active	Send an email to request to take down a malicious domain	AMBER
EmailSender	Active	Send a generic email	AMBER
MISP	Active	Automatically creates an event on your MISP instance, linking the successful analysis on IntelOwl	CLEAR
OpenCTI	Active	Automatically creates an observable and a linked report on your OpenCTI instance, linking the successful analysis on IntelOwl	CLEAR
Slack	Active	Send the analysis link to a slack channel	RED
YETI	Active	find or create observable on YETI, linking the successful analysis on IntelOwl	CLEAR

Note on connectors: Connectors are designed to run after every successful analysis, making them suitable for automated threat-sharing. They support integration with other SIEM/SOAR projects, specifically aimed at Threat Sharing Platforms.



IntelOwl Scan Configuration (from screenshot):

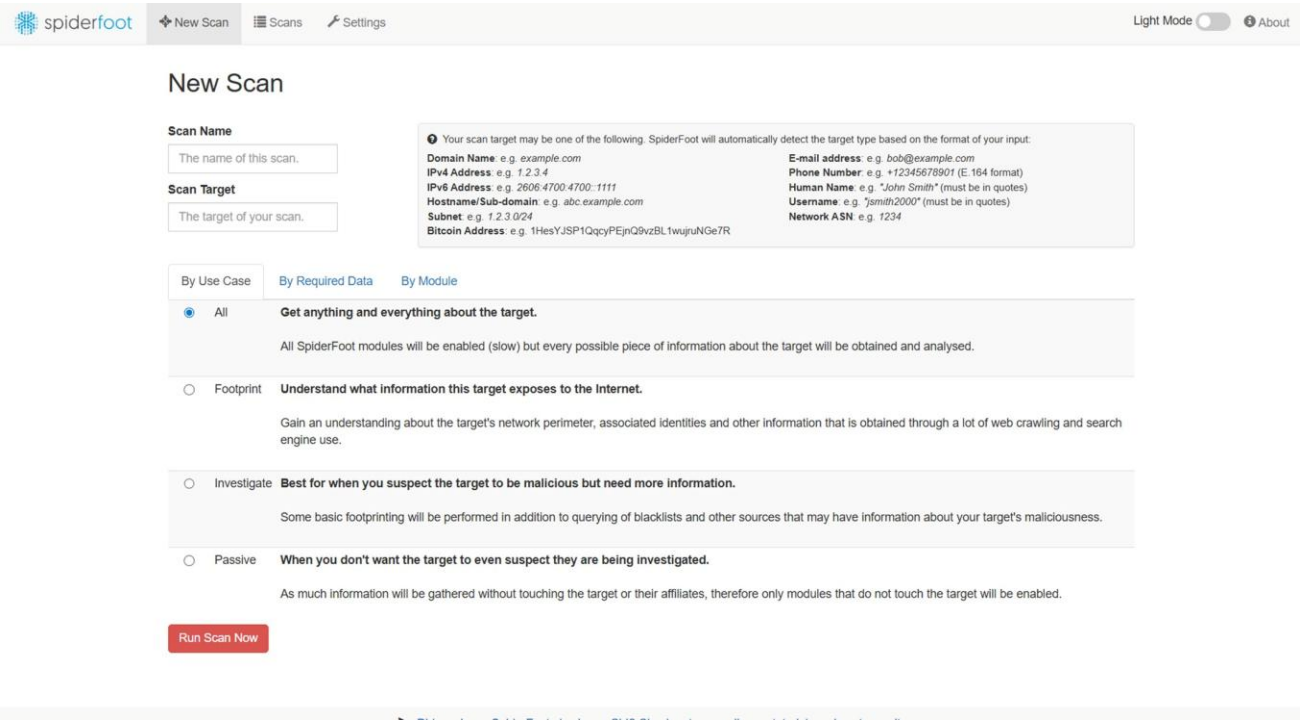
- Observable types supported: domain, IP, URL, HASH, and other observables, or file uploads
- Observable scanned: 8.8.8.8 (Google Public DNS — used as a test observable)
- Playbook used: Passive_DNS
- TLP setting: AMBER (disables analyzers that could impact privacy; limits access to organization)
- Total analyzers available: 80 (shown as 0/80 selected)
- Total connectors available: 6 (shown as 0/6 selected)
- Scan statistics: Month: 1, Total: 1



IntelOwl Job #1 Pipeline Details:

- Target observable: 8.8.8.8 (IP type)
- Pipeline stages: Analyzers (Reported 0/3) → Connectors (Reported 0/0) → Pivots (Reported 0/0) → Visualizers (Reported 1/1)
- Report tabs: Analyzers Report (0/3), Connectors Report (0/0), Pivots Report (0/0), Visualizers Report (1/1), Full Report, Data Model
- View mode: Raw
- Status: Kill job button visible (job was in progress during screenshot)

4.3.4 C. SpiderFoot — Automated OSINT Engine



SpiderFoot is an automated OSINT reconnaissance tool deployed on CTI-M3. It maps attacker infrastructure by pivoting across IPs, domains, hostnames, email addresses, and social profiles.

Supported Target Types (visible in screenshot):

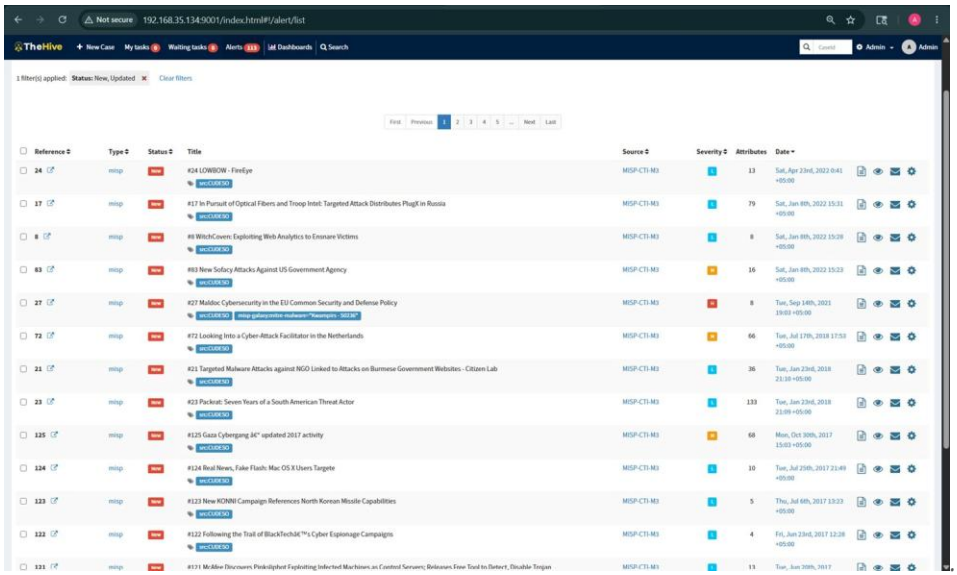
- Domain Name — e.g. example.com
- IPv4 Address — e.g. 1.2.3.4
- IPv6 Address — e.g. 2606:4700:4700::1111
- Hostname/Sub-domain — e.g. abc.example.com
- Subnet — e.g. 1.2.3.0/24
- Bitcoin Address — e.g. 1HesYJSP1QqcyPEjnQ9vzBL1wujruNGe7R
- E-mail address — e.g. bob@example.com
- Phone Number — e.g. +12345678901 (E.164 format)
- Human Name — e.g. "John Smith" (must be in quotes)
- Username — e.g. "jsmith2000" (must be in quotes)
- Network ASN — e.g. 1234

Scan Modes:

- All — Get anything and everything about the target. All SpiderFoot modules will be enabled (slow) but every possible piece of information about the target will be obtained and analysed.
- Footprint — Understand what information this target exposes to the Internet. Gain an understanding about the target's network perimeter, associated identities and other information that is obtained by a lot of web crawling and search engine use.
- Investigate — Best for when you suspect the target to be malicious but need more information. Some basic footprinting will be performed in addition to querying of blacklists and other sources that may have information about your target's maliciousness.
- Passive — When you don't want the target to even suspect they are being investigated. As much information will be gathered without touching the target or their affiliates, therefore only modules that do not touch the target will be enabled.

4.3.5 D. TheHive — Security Incident Response & Case Management

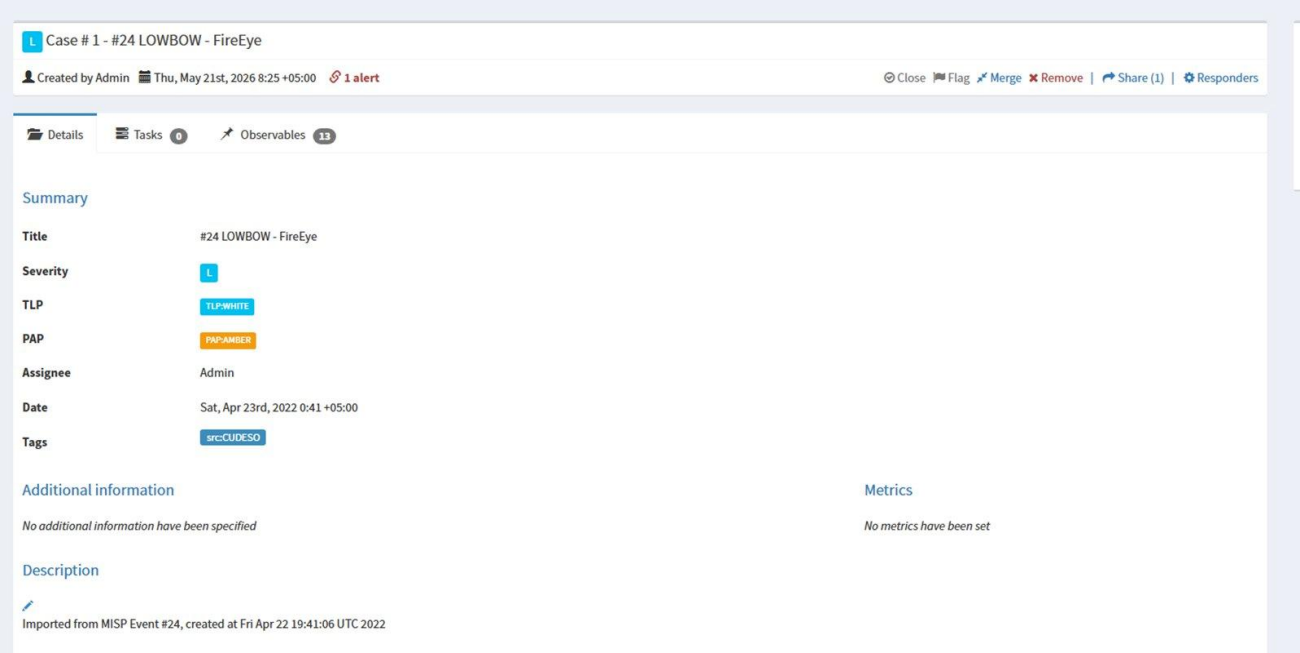
TheHive is the incident response and case management platform deployed on CTI-M3 (192.168.35.134). It receives alerts automatically from MISP via the MISP-to-TheHive integration and provides structured workflow for incident investigation, triage, and response.



TheHive Alert List (visible entries):

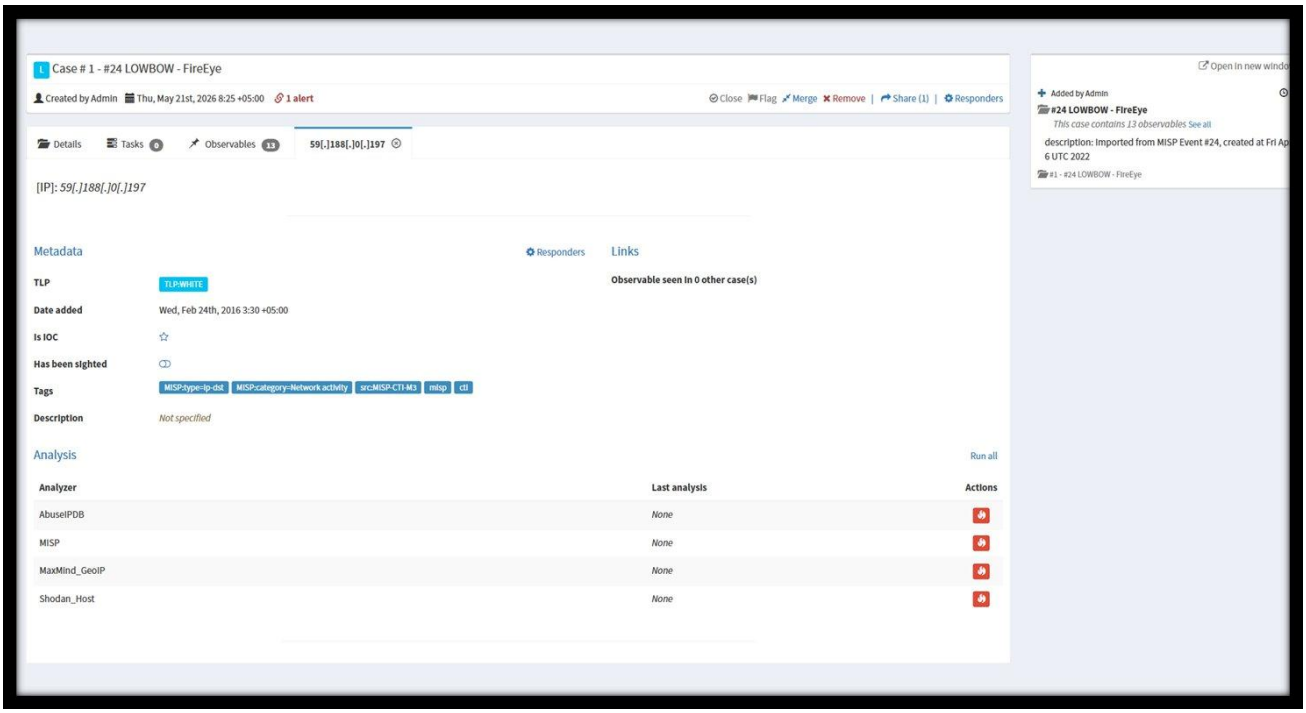
- Total alerts: 113 (shown in header)
- #24 LOWBOW – FireEye — Source: MISP-CTI-M3, Type: misp, Status: NEW, Severity: L, Attributes: 13, Date: Sat Apr 23rd 2022 0:41 +05:00
- #17 In Pursuit of Optical Fibers and Troop Intel: Targeted Attack Distributes PlugX in Russia — Source: MISP-CTI-M3, Type: misp, Status: NEW, Severity: L, Attributes: 79, Date: Sat Jan 8th 2022 15:31 +05:00
- #8 WitchCoven: Exploiting Web Analytics to Ensnare Victims — Source: MISP-CTI-M3, Type: misp, Status: NEW, Severity: L, Attributes: 8, Date: Sat Jan 8th 2022 15:28 +05:00
- #83 New Sofacy Attacks Against US Government Agency — Source: MISP-CTI-M3, Type: misp, Status: NEW, Severity: M, Attributes: 16, Date: Sat Jan 8th 2022 15:23 +05:00
- #27 Maldoc Cybersecurity in the EU Common Security and Defense Policy — Source: MISP-CTI-M3, Type: misp, Status: NEW, Severity: H, Attributes: 8, Tags: misp-galaxy:mitre-malware="Kwampirs – S0236", Date: Tue Sep 14th 2021 19:03 +05:00
- #72 Looking Into a Cyber-Attack Facilitator in the Netherlands — Source: MISP-CTI-M3, Status: NEW, Severity: M, Attributes: 66, Date: Tue Jul 17th 2018 17:53 +05:00
- #21 Targeted Malware Attacks against NGO Linked to Attacks on Burmese Government Websites – Citizen Lab — Attributes: 36, Date: Tue Jan 23rd 2018
- #23 Packrat: Seven Years of a South American Threat Actor — Attributes: 133, Date: Tue Jan 23rd 2018
- #125 Gaza Cybergang – updated 2017 activity — Severity: M, Attributes: 68
- #124 Real News, Fake Flash: Mac OS X Users Targeted — Attributes: 10
- #123 New KONNI Campaign References North Korean Missile Capabilities — Attributes: 5
- #122 Following the Trail of BlackTech's Cyber Espionage Campaigns — Attributes: 4
- #121 McAfee Discovers Pinkslipbot Exploiting Control Servers — (partially visible)

All visible alerts are tagged "src:CUDESO" and sourced from MISP-CTI-M3, confirming the active MISP-to-TheHive sync pipeline.



Case #1 — #24 LOWBOW – FireEye (Full Details):

- Title: #24 LOWBOW – FireEye
- Created by: Admin
- Date: Thu, May 21st, 2026 8:25 +05:00
- Linked alerts: 1 alert
- Severity: L (Low)
- TLP: TLP:WHITE
- PAP: PAP:AMBER
- Assignee: Admin
- Case date: Sat, Apr 23rd, 2022 0:41 +05:00
- Tags: src:CUDESO
- Observables: 13
- Tasks: 0
- Description: Imported from MISP Event #24, created at Fri Apr 22 19:41:06 UTC 2022

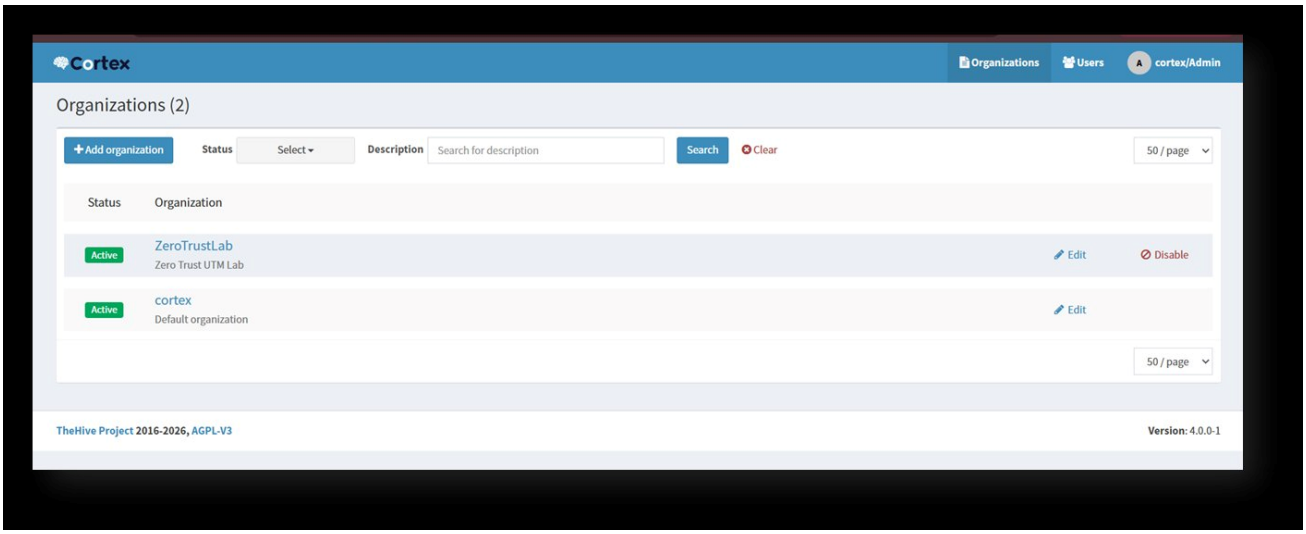


Observable Details — Case #1:

- Observable type: IP (59[.]188[.]0[.]197 — defanged for safety)
- TLP: TLP:WHITE
- Date added: Wed Feb 24th 2016 3:30 +05:00
- Is IOC: Not marked
- Has been sighted: Not marked
- Tags: MISP:type=ip-dst, MISP:category=Network activity, src:MISP-CTI-M3, misp, cti
- Observable seen in: 0 other cases
- Available analyzers: AbuseIPDB, MISP, MaxMind_GeoIP, Shodan_Host
- Total observables in case: 13

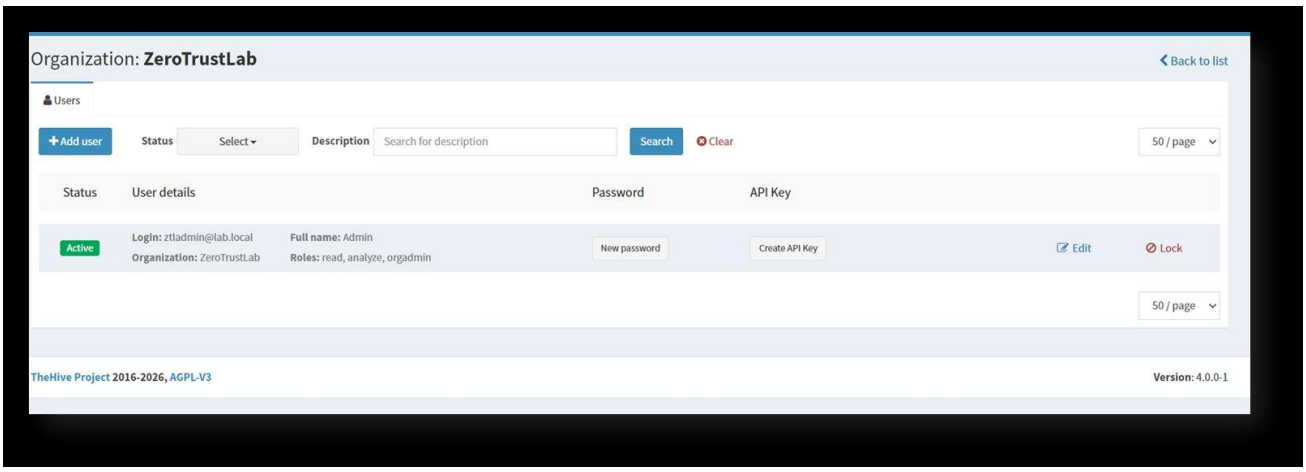
4.3.6 E. Cortex — Automated Analysis & Response Engine

Cortex is the automated analysis engine that powers deep IOC enrichment for TheHive. It runs multiple analyzers including AbuseIPDB, Shodan, VirusTotal, MaxMind GeoIP, URLscan, and MISP. Cortex Version: 4.0.0-1.

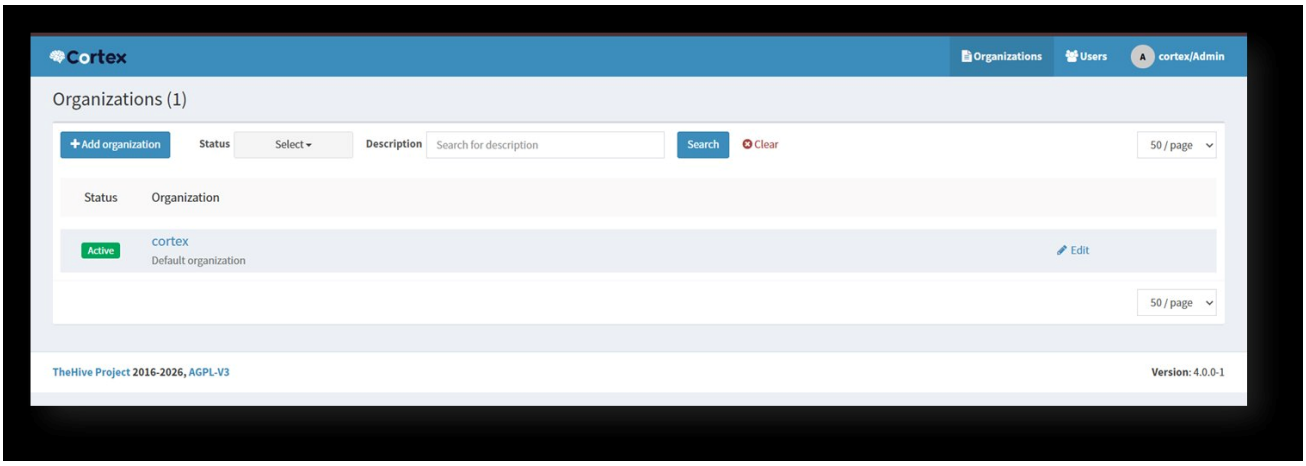


Cortex Organizations:

Organization	Description	Status
ZeroTrustLab	Zero Trust UTM Lab	Active
cortex	Default organization	Active



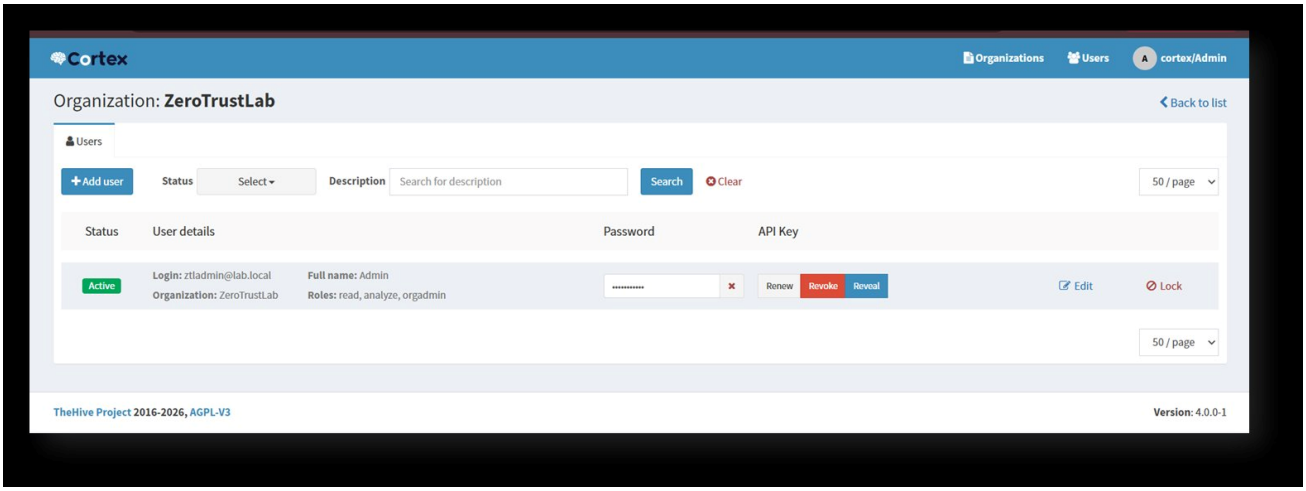
Cortex Organizations page (single organization view) showing only the "cortex" default organization (Active). This appears to be a different login session showing only the cortex admin context.



Cortex Organization: ZeroTrustLab — Users page. Shows user "ztladmin@lab.local" (Full name: Admin, Organization: ZeroTrustLab, Roles: read, analyze, orgadmin) with Status: Active. API key management available (Create API Key button visible).

Cortex ZeroTrustLab User Configuration:

- Login: ztladmin@lab.local
- Full name: Admin
- Organization: ZeroTrustLab
- Roles: read, analyze, orgadmin
- Status: Active
- API Key: Available (Create API Key button shown — key not yet generated in this screenshot)



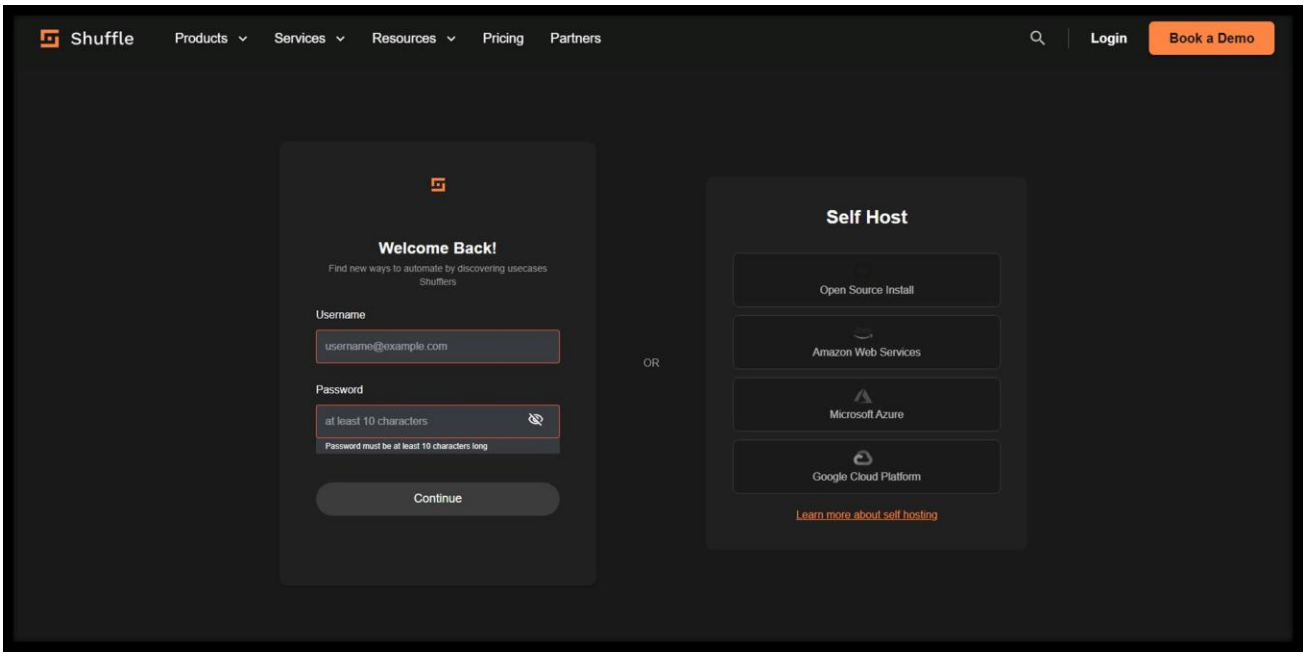
Cortex ZeroTrustLab Users page — showing the same user with an active API key visible (masked as dots). Options: Renew, Revoke, Reveal. Password set. Roles: read, analyze, orgadmin.

Cortex ZeroTrustLab API Key Status:

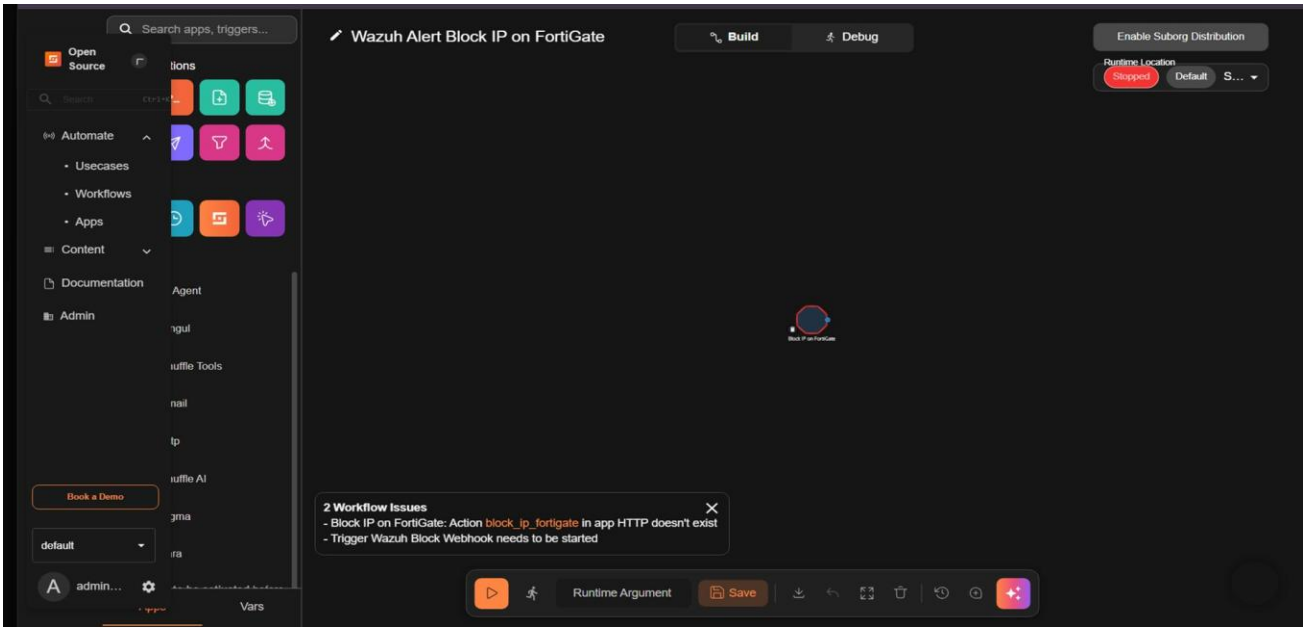
- API key is generated and active (shown as masked dots)
- Available actions: Renew, Revoke, Reveal
- This API key is used by TheHive and Shuffle SOAR to call Cortex analyzers

4.3.7 F. Shuffle SOAR — Security Orchestration, Automation & Response

Shuffle SOAR is the automation engine of CTI-M3, providing Security Orchestration, Automation & Response through visual workflow builders. It is deployed as a self-hosted Open Source installation and executes 4 automated playbook workflows.



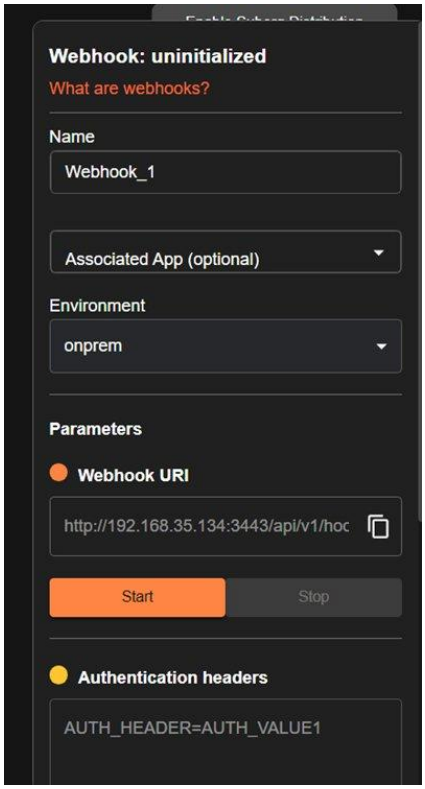
Shuffle SOAR Login page showing the self-hosted (Open Source) deployment. Login form on the left. Self Host options on the right: Open Source Install, Amazon Web Services, Microsoft Azure, Google Cloud Platform. Password requirement: minimum 10 characters.



Shuffle SOAR Workflow Builder — "Wazuh Alert Block IP on FortiGate" workflow. Shows workflow canvas with a single node "Block IP on FortiGate" visible. Workflow issues panel shows: (1) Block IP on FortiGate: Action block_ip_fortigate in app HTTP doesn't exist; (2) Trigger Wazuh Block Webhook needs to be started. Runtime Location: Stopped.

Shuffle SOAR Workflow 1 — "Wazuh Alert Block IP on FortiGate":

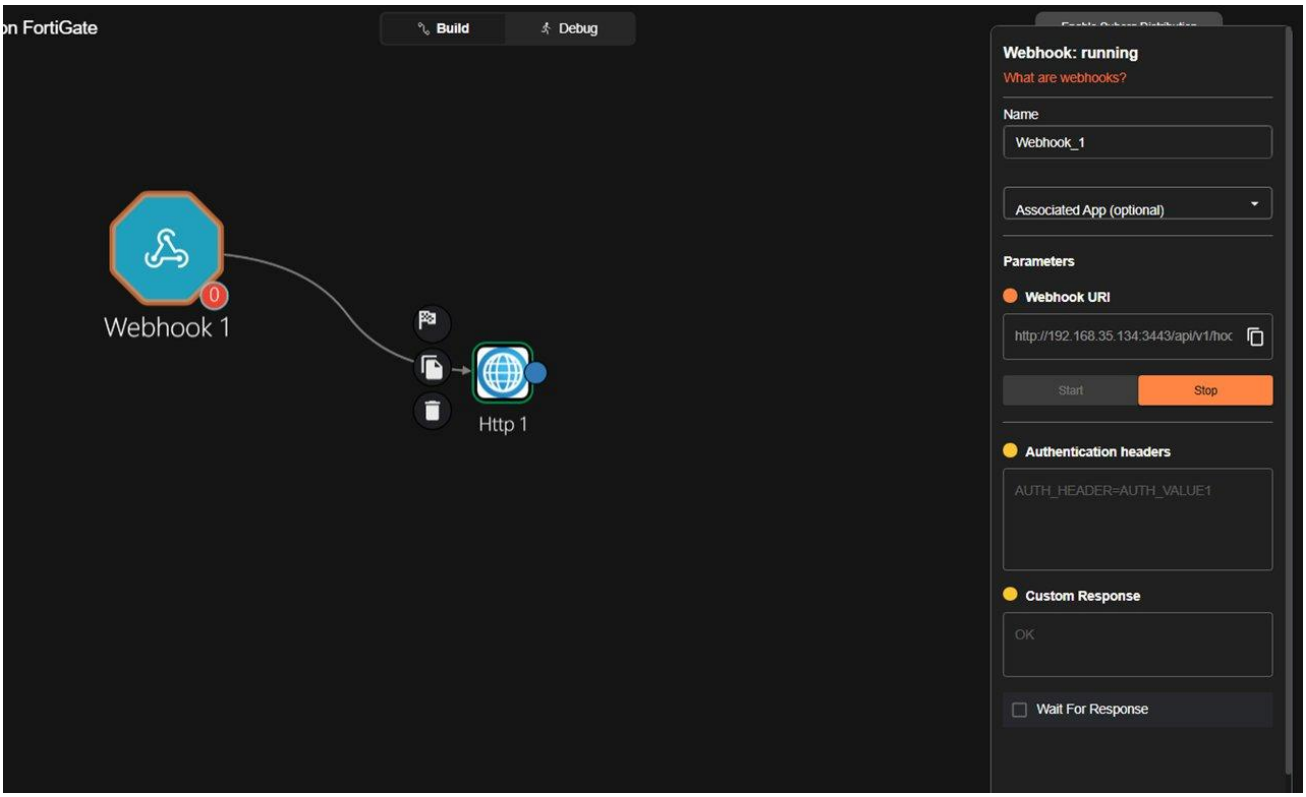
- Workflow name: Wazuh Alert Block IP on FortiGate
- Status: Stopped (Runtime Location shown as red "Stopped" badge)
- Node visible: "Block IP on FortiGate" (HTTP integration node)
- Issue 1: Action block_ip_fortigate in app HTTP doesn't exist — requires HTTP app configuration
- Issue 2: Trigger Wazuh Block Webhook needs to be started
- Interface: Build / Debug tabs visible. Save button active.



Shuffle SOAR Webhook configuration panel — "Webhook: uninitialized" showing Webhook_1 name, Environment: onprem, Webhook URI: http://192.168.35.134:3443/api/v1/hoo[k] (partially visible), Authentication headers: AUTH_HEADER=AUTH_VALUE1. Start/Stop buttons.

Shuffle SOAR Webhook_1 Configuration:

- Name: Webhook_1
- Associated App: (optional — not set)
- Environment: onprem
- Webhook URI: http://192.168.35.134:3443/api/v1/hook[...] (partially visible, cut off)
- Authentication headers: AUTH_HEADER=AUTH_VALUE1
- Status: uninitialized (Start button active)

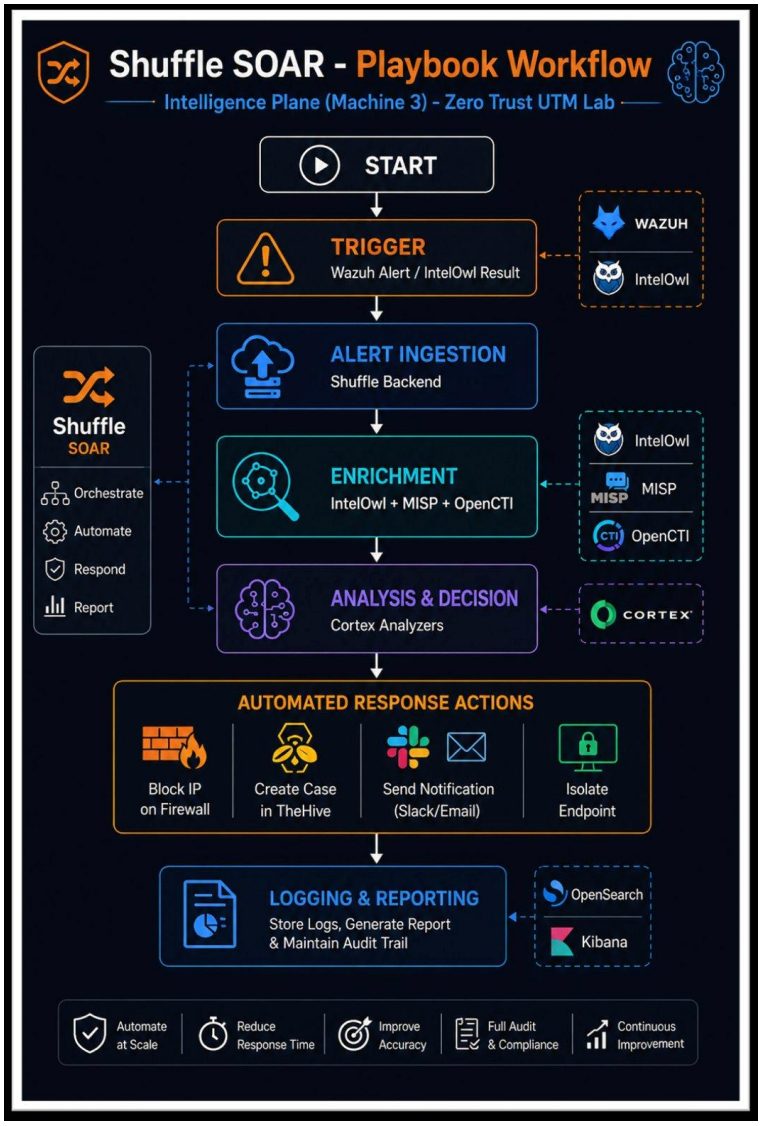


Shuffle SOAR Webhook running state — Shows Webhook 1 (teal hexagon icon with 0 executions counter) connected to Http 1 (globe icon) on the workflow canvas. Webhook panel on right shows: Name: Webhook_1, Webhook URI: http://192.168.35.134:3443/api/v1/hoo[k], Status: Stop button active (running), Authentication headers: AUTH_HEADER=AUTH_VALUE1, Custom Response: OK, Wait For Response: unchecked.

Shuffle SOAR Webhook Running State:

- Webhook 1: Running (Stop button active)
- Webhook URI: http://192.168.35.134:3443/api/v1/hook[...] (partially visible)
- Connected to: Http 1 node (HTTP integration for FortiGate API calls)
- Custom Response: OK
- Wait For Response: Disabled
- Execution count: 0 (badge on webhook node)

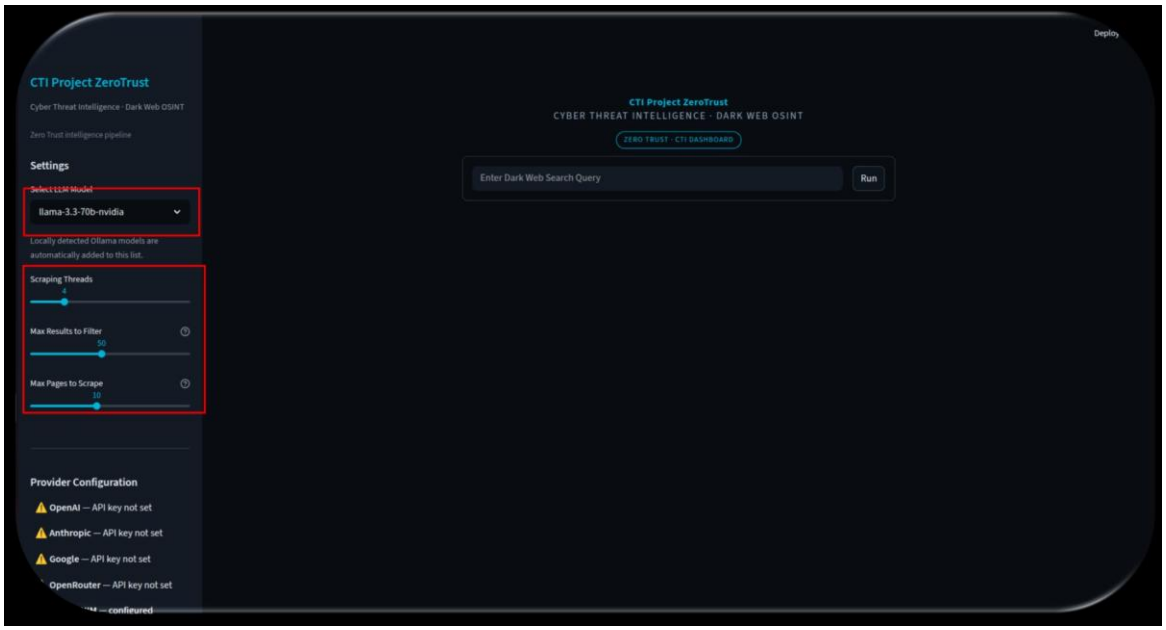
Shuffle SOAR PlayBook Workflow



Shuffle SOAR Playbook Workflow diagram showing the complete automation flow: START → TRIGGER (Wazuh Alert/IntelOwl Result) → ALERT INGESTION (Shuffle Backend) → ENRICHMENT (IntelOwl + MISP + OpenCTI) → ANALYSIS & DECISION (Cortex Analyzers) → AUTOMATED RESPONSE ACTIONS (Block IP on Firewall / Create Case in TheHive / Send Notification / Isolate Endpoint) → LOGGING & REPORTING (OpenSearch + Kibana).

4.3.8 G. Dark Web CTI Tool — Custom LLM-Powered OSINT

The Dark Web CTI Tool is a custom-built Cyber Threat Intelligence application developed specifically for the Zero Trust UTM project. It is powered by a locally hosted Llama-3.3-70b-nvidia LLM running through Ollama, combined with a custom web scraping engine for Dark Web OSINT.



Dark Web CTI Tool main interface (CTI Project ZeroTrust — Cyber Threat Intelligence – Dark Web OSINT). Shows Settings panel on left with LLM model selector, scraping configuration, and provider configuration. Search interface on right with "Zero Trust – CTI Dashboard" button.

Dark Web CTI Tool Configuration (from screenshot):

Tool Identity:

- Application name: CTI Project ZeroTrust
- Description: Cyber Threat Intelligence – Dark Web OSINT
- Subtitle: Zero Trust intelligence pipeline

LLM Model:

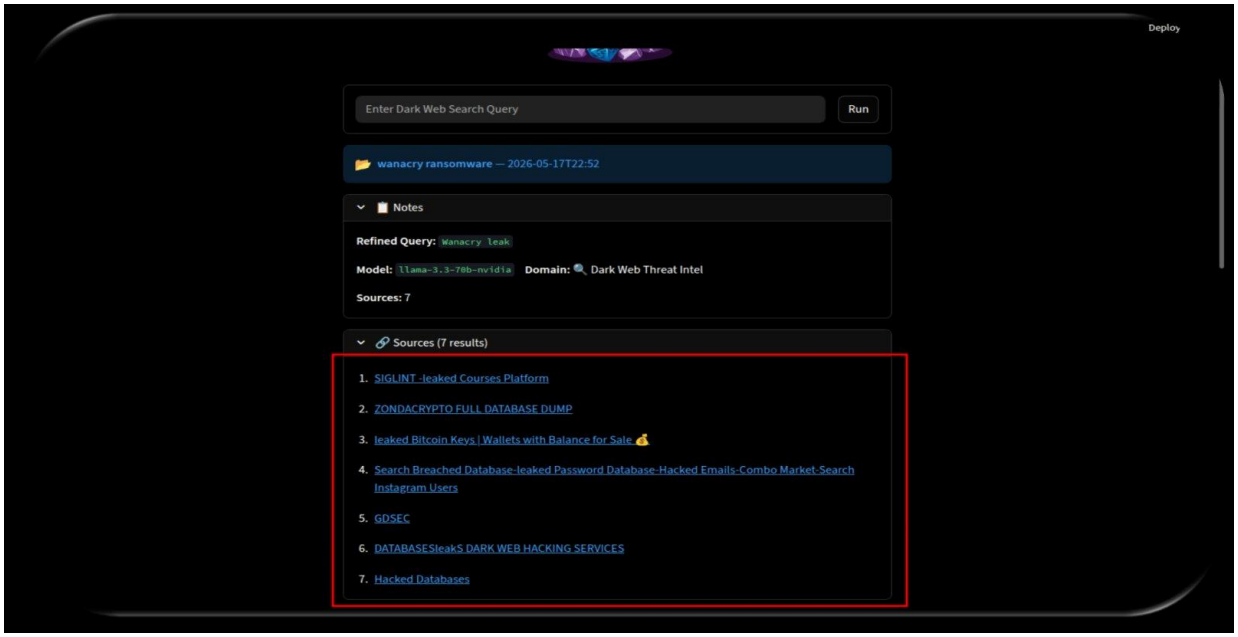
- Selected model: llama-3.3-70b-nvidia
- Note visible: "Locally detected Ollama models are automatically added to this list"

Scraping Configuration:

- Scraping Threads: 4
- Max Results to Filter: 50
- Max Pages to Scrape: 10

Provider Configuration:

- OpenAI — API key not set
- Anthropic — API key not set
- Google — API key not set
- OpenRouter — API key not set
- LLM — configured (partially visible, cut off)



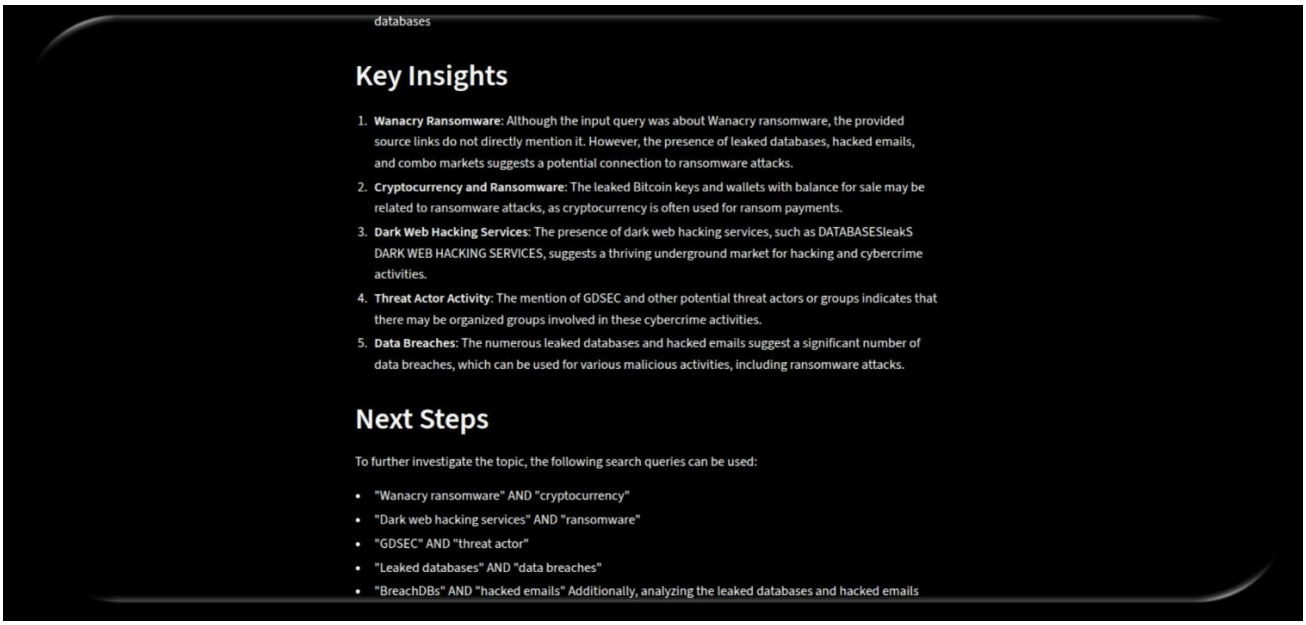
Dark Web CTI Tool — WannaCry ransomware search results. Query: "wanacry ransomware" run 2026-05-17T22:52. Refined Query: "Wanacry leak". Model: llama-3.3-70b-nvidia. Domain: Dark Web Threat Intel. Sources: 7 results found. Source list includes: SIGLINT leaked Courses Platform, ZONDACRYPTO FULL DATABASE DUMP, leaked Bitcoin Keys – Wallets with Balance for Sale, Search Breached Database (leaked passwords, hacked emails, combo market, Instagram users), GDSEC, DATABASESleakS DARK WEB HACKING SERVICES, Hacked Databases.

WannaCry Dark Web Search Results:

- Original query: "wanacry ransomware"
- Timestamp: 2026-05-17T22:52
- Refined query generated by LLM: "Wanacry leak"
- LLM model used: llama-3.3-70b-nvidia
- Domain classification: Dark Web Threat Intel
- Total sources found: 7

Sources (all 7 visible):

9. SIGLINT – leaked Courses Platform
10. ZONDACRYPTO FULL DATABASE DUMP
11. leaked Bitcoin Keys | Wallets with Balance for Sale
12. Search Breached Database-leaked Password Database-Hacked Emails-Combo Market-Search Instagram Users
13. GDSEC
14. DATABASESleakS DARK WEB HACKING SERVICES
15. Hacked Databases



Dark Web CTI Tool – Key Insights section for WannaCry query showing 5 analyst insights and Next Steps with 5 recommended follow-up queries.

Key Insights (LLM Analysis of WannaCry Dark Web Search):

16. Wanacry Ransomware: Although the input query was about Wanacry ransomware, the provided source links do not directly mention it. However, the presence of leaked databases, hacked emails, and combo markets suggests a potential connection to ransomware attacks.
17. Cryptocurrency and Ransomware: The leaked Bitcoin keys and wallets with balance for sale may be related to ransomware attacks, as cryptocurrency is often used for ransom payments.
18. Dark Web Hacking Services: The presence of dark web hacking services, such as DATABASESleakS DARK WEB HACKING SERVICES, suggests a thriving underground market for hacking and cybercrime activities.
19. Threat Actor Activity: The mention of GDSEC and other potential threat actors or groups indicates that there may be organized groups involved in these cybercrime activities.
20. Data Breaches: The numerous leaked databases and hacked emails suggest a significant number of data breaches, which can be used for various malicious activities, including ransomware attacks.

Next Steps (LLM-generated follow-up queries):

- "Wanacry ransomware" AND "cryptocurrency"
- "Dark web hacking services" AND "ransomware"
- "GDSEC" AND "threat actor"
- "Leaked databases" AND "data breaches"
- "BreachDBs" AND "hacked emails" Additionally, analyzing the leaked databases and hacked emails



Dark Web CTI Tool — Investigation Artifacts section listing 10 identified technical artifacts from the WannaCry dark web search.

Investigation Artifacts (from WannaCry dark web analysis):

Artifact	Description
SIGLINT	A leaked courses platform
ZONDACRYPTO FULL DATABASE DUMP	A full database dump of ZondaCrypto
Breach Database	A database of leaked passwords, hacked emails, and combo market
Leaked Bitcoin Keys	Leaked Bitcoin keys and wallets with balance for sale
GDSEC	A potential threat actor or group
Hacked Databases	A collection of hacked databases
DATABASESleakS DARK WEB HACKING SERVICES	A dark web hacking service
Cryptocurrency addresses	Potentially related to the leaked Bitcoin keys
Dark web markets	DarkBay, BreachDBs, and others
Forum names	Not explicitly mentioned, but potentially related to the hacking services and leaked databases

5. Threat Intelligence Pipeline



Threat Intelligence Pipeline diagram showing the complete 3-stage flow: Data Sources → Enrichment → Action & Response. "Collect > Enrich > Act | Intelligence to Impact"

The Threat Intelligence Pipeline operates in three stages, each feeding into the next to transform raw threat data into automated defensive actions.

5.1 Stage 1 — Data Sources

Threat intelligence is collected from the following trusted sources:

Source	Type	Description
MISP	Threat Sharing Platform	Central IOC repository with 19+ automated feeds and community event sharing
CIRCL OSINT Feeds	Open Source Intelligence	CIRCL (Computer Incident Response Center Luxembourg) curated OSINT feed
AlienVault OTX	Open Threat Exchange	Community-driven threat intelligence with malware indicators and campaign data
Feodo Tracker	Malware & C2 Intelligence	abuse.ch tracker for Feodo/Dridex/Emotet botnet C2 infrastructure IPs
Tor Exit Nodes	Anonymization Network Intel	dan.me.uk Tor exit node and all-node lists for anonymization detection
Emerging Threats	ET Open / ET Pro Feeds	Proofpoint Emerging Threats rule sets and IP blocklists
Abuse.ch Feeds	Malware, C2, Exploit Feeds	Feodo IP Blocklist and domain feeds for active C2 servers
Additional Feeds	IP, Domain, URL, Hash, ASN	CIRCL, Botvrij, firehol_level1, OpenPhish, Blocklist.de, and more

5.2 Stage 2 — Enrichment

Raw intelligence is analyzed, correlated, and enriched using:

Tool	Capability
Cortex Analyzers	Automated malware & IOC analysis (AbuseIPDB, Shodan, VirusTotal, MaxMind, URLscan, MISP)
IntelOwl	Threat Intel Search & Correlation across 80 analyzers at scale
SpiderFoot	Automated OSINT Reconnaissance — maps IPs to domains, infra, social profiles
VirusTotal	File, URL, IP analysis against 70+ AV engines and sandbox results
Shodan	Internet-Connected Asset Intelligence — open ports, services, vulnerabilities
MaxMind GeoIP	Geolocation & Network Intelligence — country, ASN, city for all IPs
URLscan.io	URL & Website Scanning — screenshot, DOM analysis, resource loading

Enrichment pipeline operations: Deduplicate • Correlate • Score • Tag

5.3 Stage 3 — Action & Response

Enriched, scored intelligence triggers automated defensive actions:

Action	Description
TheHive Cases	Create & update incident cases automatically with all enrichment data
FortiGate Block	Automated IP/Domain/URL blocking on FortiGate firewall via API
Pi-hole DNS Block	Block malicious domains at DNS level on Pi-hole (M1)
MISP Export	Share enriched intel with communities via MISP event export
Wazuh Alerts	Generate & correlate security alerts in the SIEM
SIEM/SOAR Integration	Send intel to the full security stack via Shuffle SOAR workflows
Reporting & Dashboards	Visibility, metrics & threat insights in Grafana/Kibana/Wazuh

Pipeline characteristics (from diagram footer): Automated Pipeline (end-to-end intelligence flow) • Real-time Updates (stay ahead of emerging threats) • High Fidelity Intel (reduce noise, increase accuracy) • Faster Response (act on threats in seconds).

6. Shuffle SOAR — Automated Playbook Workflows

Shuffle SOAR implements 4 automated playbook workflows that operate end-to-end without manual intervention. Each workflow is triggered by a specific event, performs enrichment, and executes a defensive response action.

6.1 Workflow 1 — Wazuh Critical Alert → FortiGate IP Block

- Trigger: Wazuh alert at Level 10 or above
- Webhook: Webhook_1 listening at http://192.168.35.134:3443/api/v1/hook[...] (onprem environment)
- Authentication: AUTH_HEADER=AUTH_VALUE1
- Action: HTTP integration node calls FortiGate REST API to block the source IP address
- Integration: Shuffle → FortiGate API (M1: 192.168.1.1)
- Response: Automated IP block on the network perimeter firewall

6.2 Workflow 2 — Critical Alert → TheHive Case Auto-Creation

- Trigger: Wazuh alert at Level 12 or above
- Action: Automatically creates a new case in TheHive with full alert context
- Enrichment: IntelOwl + MISP + OpenCTI provide context before case creation
- Case includes: Source IP, alert details, GeoIP data, IOC matches, Cortex analyzer results
- Integration: Wazuh → Kafka → Logstash → Shuffle → TheHive API

6.3 Workflow 3 — Honeypot Alert → Multi-Layer Block

- Trigger: Honeypot interaction events from M4 (T-Pot, Cowrie, OpenCanary, Dionaea)
- Kafka topics: tpot-logs, cowrie-logs, opencanary-alerts, dionaea-logs, canarytoken-alerts
- Action: Multi-layer block — (1) FortiGate IP block, (2) Pi-hole DNS block for associated domains
- Logic: Any interaction with a honeypot is treated as confirmed malicious intent
- Integration: Wazuh Agent (M4) → Kafka → Logstash (tagged "honeypot","deception","machine4") → Wazuh rules → Shuffle SOAR

6.4 Workflow 4 — MISP IOC → Pi-hole DNS Block

- Trigger: New IOC event ingested into MISP with domain/URL type indicators
- Action: Automatically pushes malicious domain to Pi-hole blocklist on M1
- Pi-hole endpoint: M1 (192.168.1.x) Pi-hole DNS server API
- Integration: MISP → Shuffle SOAR → Pi-hole API
- Result: Network-wide DNS blocking of confirmed malicious domains

6.5 Response Performance

Total automated response time from alert trigger to defensive action: under 2 seconds. This eliminates the human response latency for confirmed high-severity threats, ensuring that network-level blocking occurs faster than any manual intervention process.

7. M3 Integration with Other Machines

M3 serves as the integration hub for threat intelligence and automated response across the entire Zero Trust UTM cluster. It both receives data from and sends commands to all other machines.

7.1 Integration with M1 — Core Network & Security Plane

- FortiGate API (M1): Shuffle SOAR sends IP block commands to FortiGate REST API for automated firewall enforcement
- Pi-hole DNS (M1): MISP IOC workflow pushes malicious domain blocklist entries to Pi-hole via API
- Suricata Alerts (M1): Suricata IDS on M1 sends alerts to Kafka topic "suricata-alerts" for SIEM processing
- OPNsense Logs (M1): Firewall allow/deny logs sent to Kafka topic "firewall-logs"
- Zeek Connection Logs (M1): Network session data sent to Kafka topic "zeek-logs"

7.2 Integration with M2 — Identity & PKI Plane

- Keycloak Authentication Logs: Login events, token issuances, and failures sent to Wazuh via Kafka topic "keycloak-logs"
- HashiCorp Vault Audit Logs: Secret access events sent to Kafka topic "vault-logs"
- RADIUS Logs: Network access authentication events sent to Kafka topic "radius-logs"
- Certificate Events: PKI certificate issuance and revocation sent to Kafka topic "certificate-logs"

7.3 Integration with M4 — Deception & Honeypot Plane

- Wazuh Agents on M4: Agents 002 (tpot-m4, 100.102.218.16), 003 (opencanary-m4, 100.127.230.65), 004 (deception-m4, 100.105.107.37), 005 (tor-honeypot-m4, 100.112.32.96) all report via Tailscale VPN
- Honeypot Log Flow: M4 honeypot events → Wazuh agent → Kafka topics (cowrie-logs, tpot-logs, opencanary-alerts, dionaea-logs, canarytoken-alerts, honeypot-logs, honeyshare-logs) → Logstash (tagged "honeypot","deception","machine4") → OpenSearch
- SOAR Response: Any honeypot interaction triggers Workflow 3 (Multi-Layer Block)

7.4 Integration with M5 — Endpoint Protection & Hardening Plane

- Wazuh Agents: Endpoint Wazuh agents send all system logs, file integrity events, and security alerts
- Sysmon Events: Windows event logs sent to Kafka topic "sysmon-logs" for MITRE ATT&CK correlation
- Auditd Logs: Linux audit daemon events sent to Kafka topic "endpoint-logs"
- OSQuery Telemetry: Endpoint query results sent to Kafka topic "osquery-logs"
- Falco Alerts: Container runtime security alerts sent to Kafka topic "falco-alerts"

8. Wazuh Custom Rules & Decoders

All custom detection rules are stored in the file zerotrust-rules.xml on SIEM-M3. The following rules were extracted from screenshots of the Wazuh Rules management interface and API query output.

8.1 Custom Detection Rules

Rule ID	Description	Level	File	Group
100001	FortiGate: log received	3	zerotrust-rules.xml	syslog
100002	FortiGate: Traffic blocked	(visible in API output)	zerotrust-rules.xml	FortiGate
100003	FortiGate: Admin login failure	(visible in API output)	zerotrust-rules.xml	FortiGate
100100	Suricata: IDS alert	(visible in API output)	zerotrust-rules.xml	IDS/Suricata
100101	Suricata: Critical signature matched	(visible in API output)	zerotrust-rules.xml	IDS/Suricata
100200	Zeek: Connection log	(visible in API output)	zerotrust-rules.xml	Network/Zeek
100300	OPNsense: Firewall log	(visible in API output)	zerotrust-rules.xml	Firewall
100400	Cowrie: Honeypot interaction	(visible in API output)	zerotrust-rules.xml	Honeypot
100401	Cowrie: SSH login attempt on honeypot	(visible in API output)	zerotrust-rules.xml	Honeypot
100402	Cowrie: Command executed on honeypot	(visible in API output)	zerotrust-rules.xml	Honeypot
100500	Pi-hole: DNS log	(visible in API output)	zerotrust-rules.xml	DNS/Pi-hole
100501	Pi-hole: Malicious domain blocked	(visible in API output)	zerotrust-rules.xml	DNS/Pi-hole

Total custom rules: 25. Total custom decoders: 20. The rule file is accessible via Wazuh Manager Rules interface at SIEM-M3 (192.168.35.133).

9. Technology Stack Summary

Complete technology stack for Machine 3 — Intelligence & SOAR Plane:

9.1 VM 1 — SIEM-M3 (192.168.35.133)

Tool	Version	Port(s)	Function
Wazuh Manager	v4.14.5	1514, 1515, 55000	Security monitoring, HIDS, agent management, custom rules/decoders
Apache Kafka	Docker	9092	Log streaming broker, 48 topics, high-throughput ingestion
Logstash	Docker	5044 (Beats), 6514 (TCP/Syslog)	Log parsing, GeoIP enrichment, 3 pipelines, Kafka consumer
OpenSearch	Docker	9200, 9300	Full-text search, log indexing, SIEM data store

9.2 VM 2 — MONITOR-M3 (192.168.35.136)

Tool	Version	Function
Wazuh Dashboard	v4.14.5	Security visibility, alerts, integrity monitoring, compliance
Grafana	Docker	Metrics visualization, time-series dashboards, Prometheus integration
Kibana	Docker	Log exploration, custom visualizations, index management
Prometheus	Docker	Metrics collection, scraping from all cluster machines

9.3 VM 3 — CTI-M3 (192.168.35.134)

Tool	Version	Port(s)	Function
MISP	2.5.37	80/443	Threat intelligence sharing, IOC management, 19+ automated feeds
OpenCTI	Docker	8080	STIX2 knowledge graph, threat actor campaign visualization
TheHive	4.0.0-1	9001	Incident case management, MITRE ATT&CK tagging, MISP integration
Cortex	4.0.0-1	9001	Automated analysis engine, 6+ analyzers (AbuseIPDB, Shodan, VT, MaxMind, URLscan)
Shuffle SOAR	Open Source	3443	4 automated playbook workflows, webhook-triggered response
IntelOwl	v6.6.1	443/80	OSINT enrichment, 80 analyzers, 6 connectors (MISP, OpenCTI, Slack, YETI)
SpiderFoot	Docker	5009	Automated OSINT reconnaissance, target analysis, 4 scan modes
Dark Web CTI Tool	Custom	Local	LLM-powered dark web OSINT, Llama-3.3-70b-nvidia, 4 scraping threads

9.4 Cross-VM Networking

Connection	Protocol	Details
SIEM-M3 → CTI-M3	HTTP API	Wazuh alerts forwarded to TheHive and Shuffle SOAR
CTI-M3 → M1 FortiGate	HTTPS REST API	IP block commands from Shuffle SOAR
CTI-M3 → M1 Pi-hole	HTTP API	DNS blocklist updates from MISP workflow
M4 Honeypots → SIEM-M3	Tailscale VPN + Wazuh	Agents 002-005 reporting over 100.x.x.x Tailscale IPs
SIEM-M3 → MONITOR-M3	HTTP	OpenSearch data consumed by Wazuh Dashboard, Kibana
CTI-M3 IntelOwl → MISP	HTTP API	MISP connector creates events from IntelOwl analysis
CTI-M3 IntelOwl → OpenCTI	HTTP API	OpenCTI connector creates observables and reports

M4

Deception Plane

HoneyPots & Threat Detection

Machine-4

Architecture Overview

Deception is the sixth and often underestimated pillar of Zero Trust. While other machines enforce access controls and verify identity, M4 deliberately exposes tempting but fake attack surfaces. Any attacker who reaches M4 is already inside the perimeter—and every action they take is silently recorded, analyzed, and used to improve defenses.

Why Deception Matters

- Early Threat Detection — Attackers are detected at the very first probe, before they can reach real assets.
- Attacker Intelligence — TTPs, IOCs, tools, and behavioral patterns are captured in full detail.
- Risk Reduction — Every second an attacker spends on a honeypot is a second away from real infrastructure.
- Automated Response — Honeypot alerts immediately trigger SOAR workflows on M3 to block IPs at M1's FortiGate firewall.



Deceive-Detect-Delay-Defend

1. Executive Summary

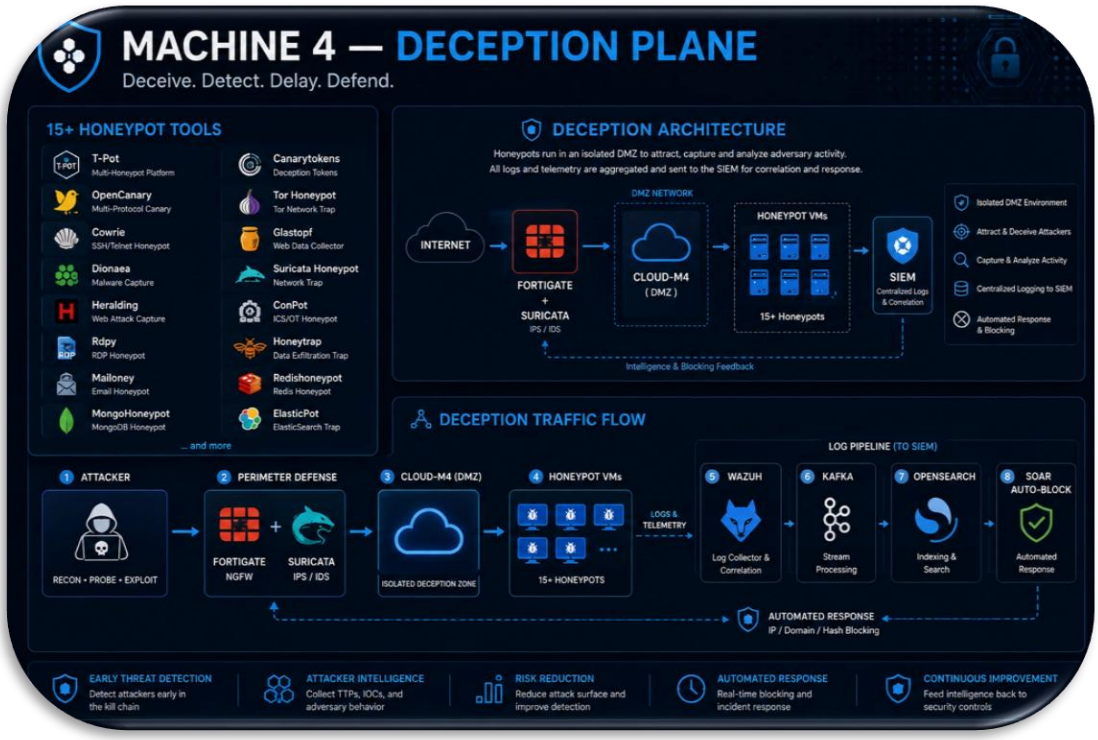
Machine 4 (M4) is the Deception and Honeypot Plane of the Zero Trust UTM lab. With 16 GB of RAM, M4 operates four honeypot virtual machines running over 15 honeypot tools inside an isolated DMZ (CLOUD-M4). Its purpose is to attract adversaries away from production assets, capture their tactics, techniques, and procedures (TTPs), and feed threat intelligence back into the centralized SIEM and automated response pipeline.

Integration with Other Machines

All honeypot telemetry flows from M4 via Wazuh agents to the M3 Wazuh SIEM, is streamed through Kafka, indexed in OpenSearch, and triggers Shuffle SOAR automated playbooks. Blocked indicators are pushed back to M1 FortiGate and OPNsense firewalls, and IOCs are shared with the MISP threat intelligence platform. M2 identity logs are cross-referenced with honeypot interactions to detect compromised credentials being used against fake services.

2. M4 Deception Plane Overview

The diagram below shows the complete M4 Deception Plane architecture, including the 15+ honeypot tools, the DMZ network layout, the deception traffic flow, and the log pipeline to SIEM.



M4 Deception Plane Architecture — showing 15+ honeypot tools, CLOUD-M4 DMZ layout, deception traffic flow pipeline, and key outcomes

Traffic Flow Explained

The deception traffic flow operates in eight distinct stages:

- Stage 1 — ATTACKER: External threat actor initiates Recon, Probe, or Exploit activity.
- Stage 2 — PERIMETER DEFENSE: Traffic passes through FortiGate NGFW and Suricata IPS/IDS for initial inspection. FortiGate allows traffic destined for the DMZ honeypots to reach M4.
- Stage 3 — CLOUD-M4 DMZ: The isolated deception zone. Traffic enters the dedicated DMZ network, completely separated from production infrastructure.
- Stage 4 — HONEYPOT VMs: Traffic reaches one of 15+ honeypot services. The attacker believes they have found a real target. All interactions are captured.
- Stage 5 — WAZUH: Wazuh agents on all four honeypot VMs collect logs and telemetry in real time for correlation.
- Stage 6 — KAFKA: Logs are streamed through Kafka topics for high-throughput processing and routing to multiple downstream consumers.
- Stage 7 — OPENSEARCH: Logs are indexed in OpenSearch for search, visualization, and historical analysis.
- Stage 8 — SOAR AUTO-BLOCK: Shuffle SOAR processes alerts and executes automated blocking workflows — IP/Domain/Hash blocking across FortiGate, OPNsense, MISP, and TheHive.

A feedback loop returns intelligence and blocking decisions back to FortiGate at Stage 2, enabling continuous hardening of perimeter defenses.

Key Architectural Properties

- Isolated DMZ Environment — Honeypots have no access to production networks.
- Attract & Deceive Attackers — Services mimic real vulnerable systems to maximize attacker engagement.
- Capture & Analyze Activity — Every command, credential attempt, file upload, and connection is recorded.
- Centralized Logging to SIEM — All 4 VMs report to a single Wazuh server on M3.
- Automated Response & Blocking — Zero manual intervention required for initial response.

3. Honeypot Tools Overview (15+ Tools)

M4 deploys more than 15 specialized honeypot tools, each targeting a different attack vector or protocol. The complete list is visible in the architecture diagram (Figure 1). Below is a detailed description of each tool and its purpose within the deception strategy.

T-Pot	Multi-Honeypot Platform — Runs multiple honeypot services in Docker containers. Provides a unified dashboard (Kibana/ELK) for visualizing attacks across all services simultaneously.
OpenCanary	Multi-Protocol Canary — Lightweight honeypot that emulates HTTP, FTP, SSH, Telnet, SMB, MySQL, and other services. Generates alerts on any connection attempt.
Cowrie	SSH/Telnet Honeypot — Medium-interaction honeypot that records all commands entered by attackers after login. Captures brute force credentials and post-exploitation behavior.
Dionaea	Malware Capture — Honeypot designed to trap malware payloads. Captures exploit attempts and malware binaries dropped by attackers via SMB, HTTP, FTP, TFTP, and SIP.
Heralding	Web Attack Capture — Credential-capturing honeypot that listens on HTTP, HTTPS, FTP, Telnet, and other protocols. Records all authentication attempts.
Rdpy	RDP Honeypot — Simulates Windows Remote Desktop Protocol (RDP) services. Captures RDP brute force and lateral movement attempts.
Mailoney	Email Honeypot — Simulates SMTP email server. Captures spam relay attempts, phishing delivery tests, and mail server exploitation attempts.
MongoHoneypot	MongoDB Honeypot — Simulates an exposed MongoDB database with no authentication. Captures database enumeration and data exfiltration attempts.
Canarytokens	Deception Tokens — Unique tokens (URLs, documents, DNS names) embedded across the environment. Any access to a canarytoken triggers an alert — high-confidence indicator of compromise.
Tor Honeypot	Tor Network Trap — Dark web honeypot accessible via the Tor network (.onion address). Captures threat actors operating on the dark web who attempt to interact with the fake hidden service.
Glastopf	Web Data Collector — Low-interaction web application honeypot. Emulates vulnerabilities including LFI, RFI, and SQL injection to capture web-based attack data.
Suricata Honeypot	Network Trap — Suricata IDS/IPS deployed in honeypot mode to detect and log network-level attack patterns targeting the DMZ network.
ConPot	ICS/OT Honeypot — Simulates industrial control systems (SCADA/ICS) including Modbus, S7comm, and SNMP protocols. Detects nation-state and APT-level attacks targeting critical infrastructure.
Honeytrap	Data Exfiltration Trap — Captures data exfiltration attempts. Listens on arbitrary ports and records all incoming connection data and payload content.
Redishoneypot	Redis Honeypot — Simulates an exposed Redis database server. Captures Redis enumeration, data theft, and unauthorized write/command execution attempts.
ElasticPot	ElasticSearch Trap — Simulates an exposed Elasticsearch cluster. Captures data enumeration and index theft attempts targeting misconfigured search infrastructure.

4. Virtual Machine Configurations

M4 hosts four virtual machines, all connected via Tailscale VPN and reporting to the M3 Wazuh SIEM via Wazuh agents. All agents run version 4.14.5 and belong to the machine4-honeypots group (with the exception of tpot-m4 which was enrolled under that group as Agent ID 002).

4.1 VM 1 — T-Pot (100.102.218.16)

T-Pot is the flagship honeypot platform on M4. It runs the T-Pot Community Edition, which bundles more than 20 honeypot services inside Docker containers, all managed from a unified Kibana-based web dashboard. T-Pot provides a comprehensive view of attacks across all its integrated services.

4.2 VM 2 — OpenCanary-M4 (100.127.230.65)

OpenCanary-M4 is a multi-protocol canary honeypot running Ubuntu 24.04.4 LTS. It simulates multiple network services to detect unauthorized access attempts across a wide range of protocols. Any connection to an OpenCanary service triggers an immediate alert.

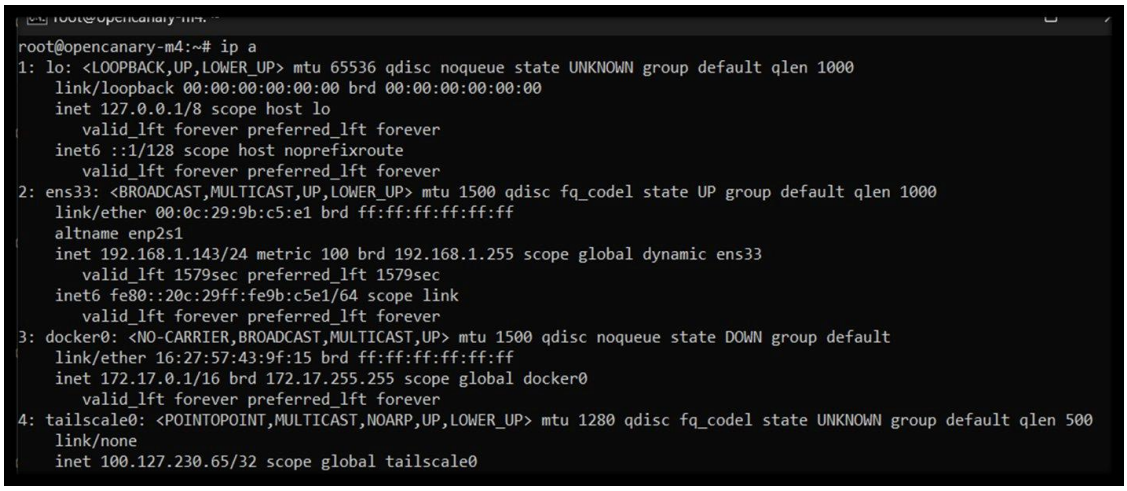
Role & Purpose

T-Pot serves as the primary multi-service deception hub. Its Docker-based architecture allows multiple honeypot services to run in parallel on a single VM, each listening on different ports and protocols. The integrated ELK stack (Elasticsearch, Logstash, Kibana) provides a live dashboard for visualizing worldwide attack data. All T-Pot log data is also forwarded to the centralized M3 Wazuh SIEM via the Wazuh agent (ID 002) for cross-correlation with logs from other machines.

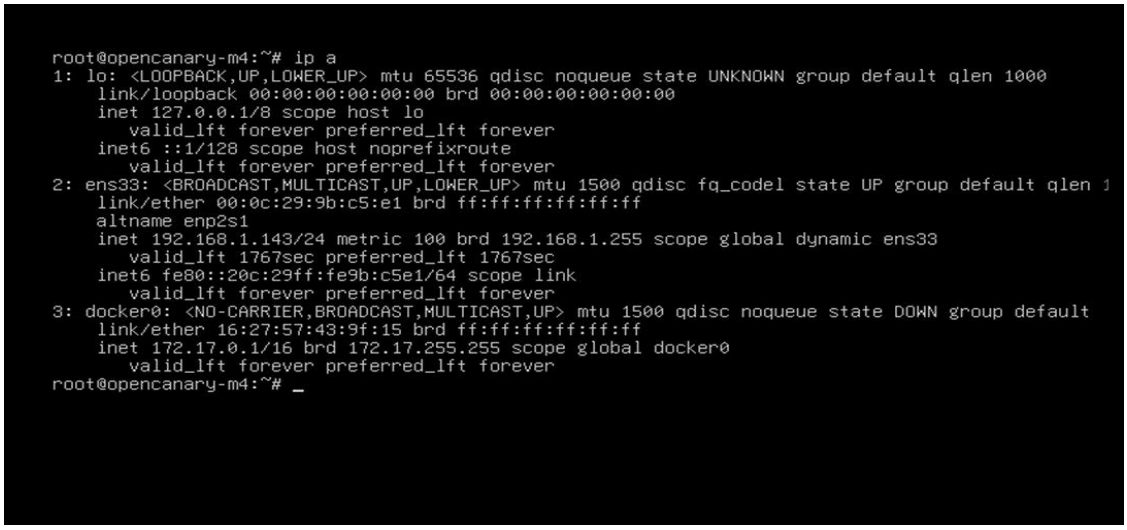
Note: No terminal screenshots were provided for the T-Pot VM in this documentation batch. The Wazuh dashboard screenshot (Figure 2) confirms the agent is active and connected. Full T-Pot dashboard screenshots would appear here in an expanded documentation set.

Network Interface Configuration — ip a Output

Two separate ip a captures were taken from the opencanary-m4 host. Figure 2 shows the full interface listing including the tailscale0 interface. Figure 3 shows a second capture showing three interfaces (no tailscale0 visible in that frame — the Tailscale interface appears in Figure 2).



OpenCanary-M4 (root@opencanary-m4) — ip a output showing lo, ens33 (192.168.1.143/24), docker0 (172.17.0.1/16), and tailscale0 (100.127.230.65/32)



OpenCanary-M4 — Second ip a capture confirming ens33 (192.168.1.143/24, metric 100, valid_lft 1767sec) and docker0 (172.17.0.1/16, state DOWN)

Interface Details Extracted

```
Interface 1: lo — LOOPBACK, UP, LOWER_UP — mtu 65536
  inet 127.0.0.1/8 scope host lo
  inet6 ::1/128 scope host noprefixroute

Interface 2: ens33 (altname: enp2s1) — BROADCAST,MULTICAST,UP,LOWER_UP — mtu 1500
  link/ether 00:0c:29:9b:c5:e1 brd ff:ff:ff:ff:ff:ff
  inet 192.168.1.143/24 metric 100 brd 192.168.1.255 scope global dynamic ens33
  valid_lft 1579sec (Fig2) / 1767sec (Fig3) preferred_lft same
  inet6 fe80::20c:29ff:fe9b:c5e1/64 scope link

Interface 3: docker0 — NO-CARRIER,BROADCAST,MULTICAST,UP — mtu 1500 — state DOWN
  link/ether 16:27:57:43:9f:15 brd ff:ff:ff:ff:ff:ff
  inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0

Interface 4: tailscale0 — POINTOPOINT,MULTICAST,NOARP,UP,LOWER_UP — mtu 1280 — state
UNKNOWN
  inet 100.127.230.65/32 scope global tailscale0
```

4.3 VM 3 — Deception-M4 (100.105.107.37)

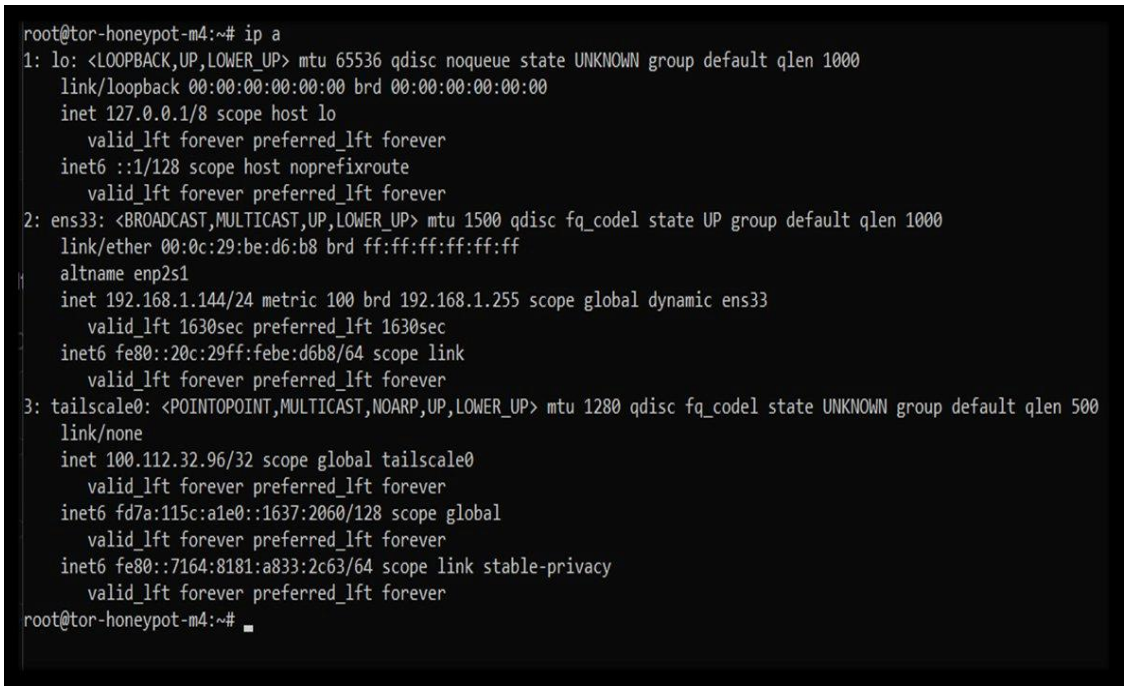
Deception-M4 is the main deception orchestration VM on M4, running Ubuntu 24.04.4 LTS. It serves as the primary host for deception frameworks and token deployment. It is registered as Wazuh Agent ID 004 in the machine4-honeypots group.

Note: No direct terminal screenshots were provided specifically for the Deception-M4 VM in this documentation batch. The Wazuh agent table (Figure 4) confirms its active status and configuration. Full configuration details including running services and deception tooling would be documented in an expanded session with additional screenshots.

4.4 VM 4 — Tor-Honeypot-M4 (100.112.32.96)

Tor-Honeypot-M4 is the most advanced VM on M4. It runs a dark web honeypot accessible via the Tor network, allowing the lab to attract and capture threat actors operating on the Tor anonymization network. The VM exposes a .onion hidden service that mimics a login portal, capturing all credential submission attempts.

Network Interface Configuration — ip a Output



Tor-Honeypot-M4 (root@tor-honeypot-m4) — ip a output showing lo, ens33 (192.168.1.144/24), and tailscale0 (100.112.32.96/32) with full IPv6 addresses

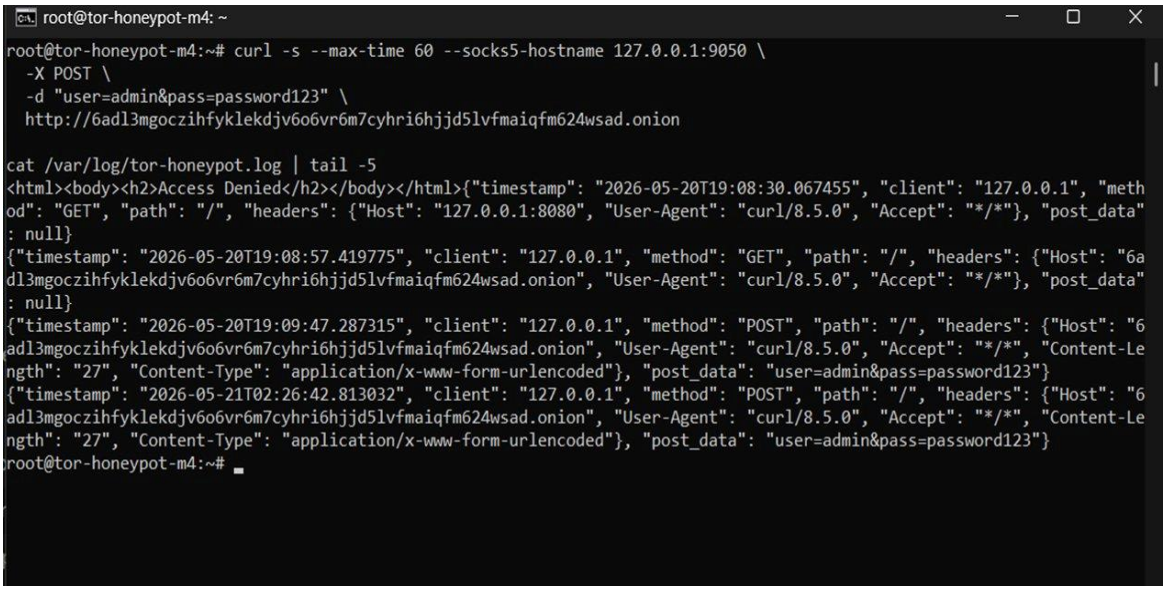
Interface 1: lo — LOOPBACK,UP,LOWER_UP — mtu 65536
inet 127.0.0.1/8 scope host lo
inet6 ::1/128 scope host noprefixroute

Interface 2: ens33 (altname: enp2s1) — BROADCAST,MULTICAST,UP,LOWER_UP — mtu 1500
link/ether 00:0c:29:be:d6:b8 brd ff:ff:ff:ff:ff:ff
inet 192.168.1.144/24 metric 100 brd 192.168.1.255 scope global dynamic ens33
valid_lft 1630sec preferred_lft 1630sec
inet6 fe80::20c:29ff:febe:d6b8/64 scope link

Interface 3: tailscale0 — POINTOPOINT,MULTICAST,NOARP,UP,LOWER_UP — mtu 1280 — state UNKNOWN
inet 100.112.32.96/32 scope global tailscale0
inet6 fd7a:115c:a1e0::1637:2060/128 scope global
inet6 fe80::7164:8181:a833:2c63/64 scope link stable-privacy

Tor Honeypot — Live Capture Demonstration

Showing a live test of the Tor honeypot. A curl command was executed through the Tor SOCKS5 proxy to post credentials to the .onion hidden service. The honeypot log file was then inspected to confirm that the POST request, including the submitted credentials, was captured.



Tor-Honeypot-M4 — curl command through Tor SOCKS5 proxy (127.0.0.1:9050) posting user=admin&pass=password123 to .onion address, with log tail showing captured POST requests with timestamps

Extracted Log Entries

```
Command executed:
curl -s --max-time 60 --socks5-hostname 127.0.0.1:9050 \
  -X POST \
  -d "user=admin&pass=password123" \
  http://6adl3mgoczihfyklekdjv6o6vr6m7cyhri6hjjd5lvfmaiqfm624wsad.onion

Log: cat /var/log/tor-honeypot.log | tail -5

Entry 1: {"timestamp": "2026-05-20T19:08:30.067455", "client": "127.0.0.1",
  "method": "GET", "path": "/", "headers": {"Host": "127.0.0.1:8080",
  "User-Agent": "curl/8.5.0", "Accept": "*/*"}, "post_data": null}

Entry 2: {"timestamp": "2026-05-20T19:08:57.419775", "client": "127.0.0.1",
  "method": "GET", "path": "/", "headers": {"Host": "6adl3mgoczi..wsad.onion",
  "User-Agent": "curl/8.5.0"}, "post_data": null}

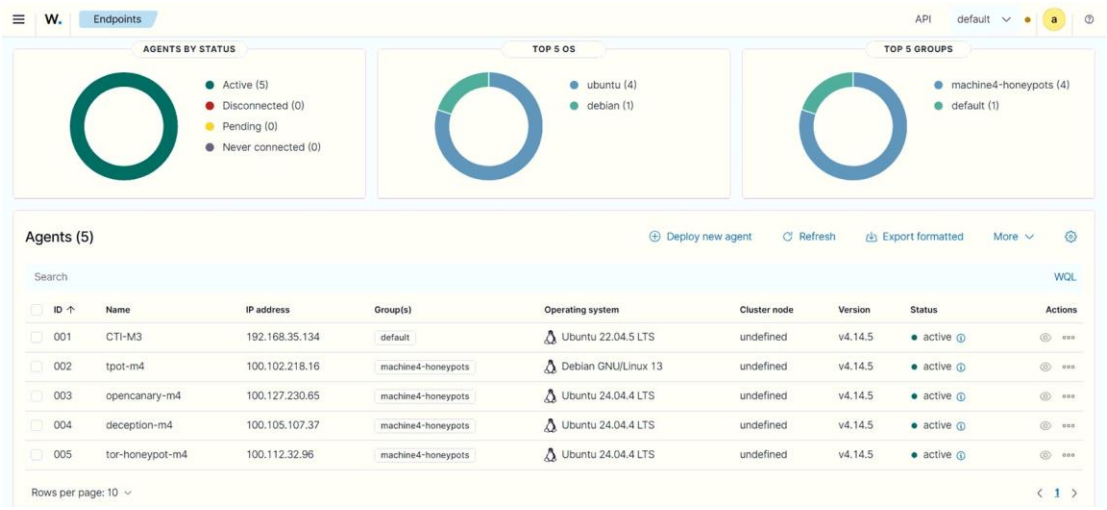
Entry 3: {"timestamp": "2026-05-20T19:09:47.287315", "client": "127.0.0.1",
  "method": "POST", "path": "/", "Content-Length": "27",
  "Content-Type": "application/x-www-form-urlencoded",
  "post_data": "user=admin&pass=password123"}

Entry 4: {"timestamp": "2026-05-21T02:26:42.813032", "client": "127.0.0.1",
  "method": "POST", "path": "/", "Content-Length": "27",
  "Content-Type": "application/x-www-form-urlencoded",
  "post_data": "user=admin&pass=password123"}
```

The log confirms that both GET and POST requests to the .onion address are captured with full timestamp, client IP, HTTP method, path, headers, and post_data. Submitted credentials (user=admin, pass=password123) are recorded in plaintext, demonstrating effective dark web threat intelligence collection.

5. Wazuh Integration — M4 Agents

All four M4 honeypot VMs are registered as Wazuh agents reporting to the central Wazuh SIEM on M3. The Wazuh dashboard below confirms all five agents visible from the M3 perspective — including CTI-M3 (Agent 001) which is a local M3 agent — are active and running version 4.14.5.



Wazuh Endpoint Management Dashboard — showing all 5 active agents: CTI-M3 (default group) and all 4 M4 honeypot agents (machine4-honeypots group). All agents v4.14.5, all Active.

Complete Agent Registry

ID	Name	IP Address	OS	Group	Version	Status
001	CTI-M3	192.168.35.134	Ubuntu 22.04.5 LTS	default	v4.14.5	Active
002	tpot-m4	100.102.218.16	Debian GNU/Linux 13	machine4-honeypots	v4.14.5	Active
003	opencanary-m4	100.127.230.65	Ubuntu 24.04.4 LTS	machine4-honeypots	v4.14.5	Active
004	deception-m4	100.105.107.37	Ubuntu 24.04.4 LTS	machine4-honeypots	v4.14.5	Active
005	tor-honeypot-m4	100.112.32.96	Ubuntu 24.04.4 LTS	machine4-honeypots	v4.14.5	Active

Dashboard Summary Statistics

- Total Agents: 5 — All Active (0 Disconnected, 0 Pending, 0 Never Connected)
- Top Operating Systems: Ubuntu (4 agents), Debian (1 agent)
- Top Groups: machine4-honeypots (4 agents), default (1 agent)

6. Honeypot Log Pipeline

Honeypot logs follow a multi-stage pipeline from capture to automated response. Each stage is designed for reliability, scalability, and real-time processing.

Kafka Topics for Honeypot Logs

honeypot-logs	General aggregation topic for all honeypot telemetry.
cowrie-logs	Dedicated topic for Cowrie SSH/Telnet honeypot interactions.
tpot-logs	T-Pot multi-honeypot platform event stream.
opencanary-alerts	OpenCanary alert notifications across all protocols.
dionaea-logs	Dionaea malware capture events and payload metadata.
canarytoken-alerts	Canarytoken trigger events — high-confidence IOC alerts.
honeyshare-logs	Shared honeypot data for cross-correlation.

Wazuh Custom Rules for Honeypot Detection

Rule 100400	Cowrie Honeypot interaction — any connection to Cowrie SSH/Telnet honeypot.
Rule 100401	Cowrie SSH login attempt — credential submission to Cowrie SSH service.
Rule 100402	Cowrie Command executed — attacker executed command in fake shell session.

7. Automated Response Integration

Shuffle SOAR Workflow — Honeypot Alert Triggered

Trigger	Wazuh alert generated from any M4 honeypot agent (IDs 002–005)
Action 1	Block source IP on FortiGate NGFW (M1) via FortiGate API
Action 2	Block source IP on OPNsense firewall (M1)
Action 3	Add IOC (IP/Domain/Hash) to MISP threat intelligence platform (M3)
Action 4	Create case in TheHive incident response platform (M3) for analyst review
Result	Multi-layer blocking + IOC sharing + case management — fully automated

8. M4 Integration with Other Machines

With M1 (Network)	FortiGate blocks IPs detected by honeypots via SOAR API integration. Intelligence feedback loop continuously updates firewall block lists.
With M2 (Identity)	Identity logs from Samba AD and FreeRADIUS on M2 are cross-referenced with honeypot interactions to detect compromised credentials being tested against fake services.
With M3 (Intelligence)	All honeypot logs flow: Honeypots → Wazuh Agent → M3 Wazuh SIEM → Kafka → OpenSearch → Shuffle SOAR automated response.
With M5 (Endpoint)	M5 endpoint agents detect lateral movement attempts toward honeypot addresses. If M5 endpoints interact with honeypot assets, those interactions are logged and trigger endpoint alerts.

9. Deception Strategy & Key Achievements

- Isolated DMZ Environment — All 15+ honeypots run in CLOUD-M4 DMZ, completely isolated from production infrastructure.
- Attract & Deceive Attackers — Multiple protocols and services maximize the probability of attacker engagement.
- Capture & Analyze Adversary TTPs — Full credential, command, and payload capture across all honeypot types.
- Dark Web Presence — Tor hidden service (.onion) expands the deception surface to the Tor network.
- Centralized Logging to SIEM — All 4 VMs report to M3 Wazuh via dedicated Wazuh agents in the machine4-honeypots group.
- Automated Response & Blocking — SOAR workflows triggered within seconds of honeypot alert generation.
- IOC Sharing — All captured indicators fed to MISP for threat intelligence sharing and historical correlation.
- Continuous Improvement — Intelligence feeds back to FortiGate and the threat platform to strengthen all other machines.

M5

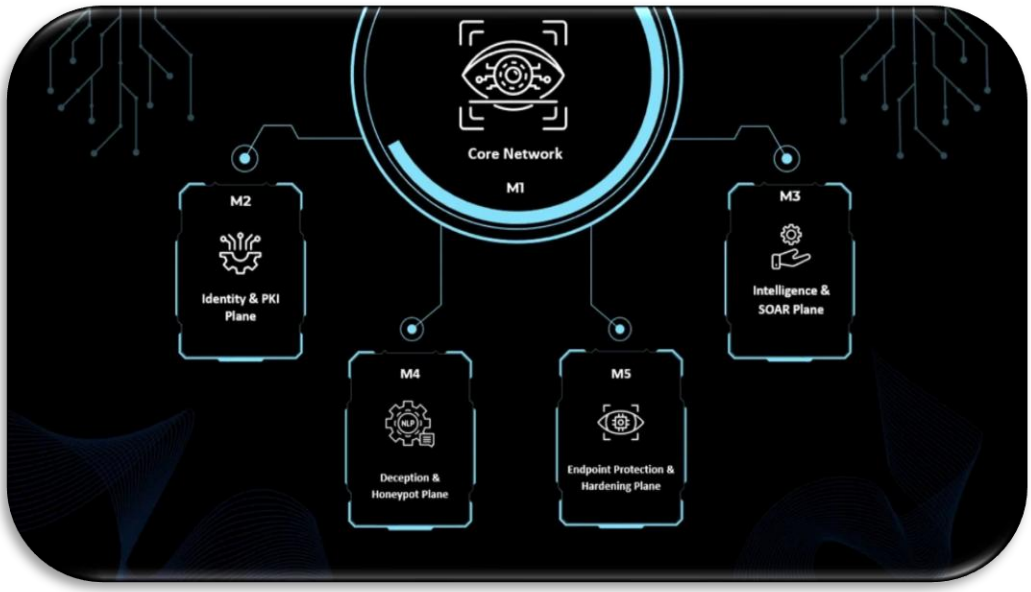
ENDPOINT PLANE

End Point Security & Protection

Machine-4

Architecture Overview

Machine 5 (M5) is the Endpoint Protection and Hardening Plane — the final and most dynamic layer of the Zero Trust UTM lab. With 16 GB of RAM, M5 serves a dual purpose: it houses a Kali Linux attack machine (Red Team) used to simulate real-world adversary activity, and it hosts victim endpoints (Blue Team) that must detect, log, and respond to every stage of the attack kill chain.



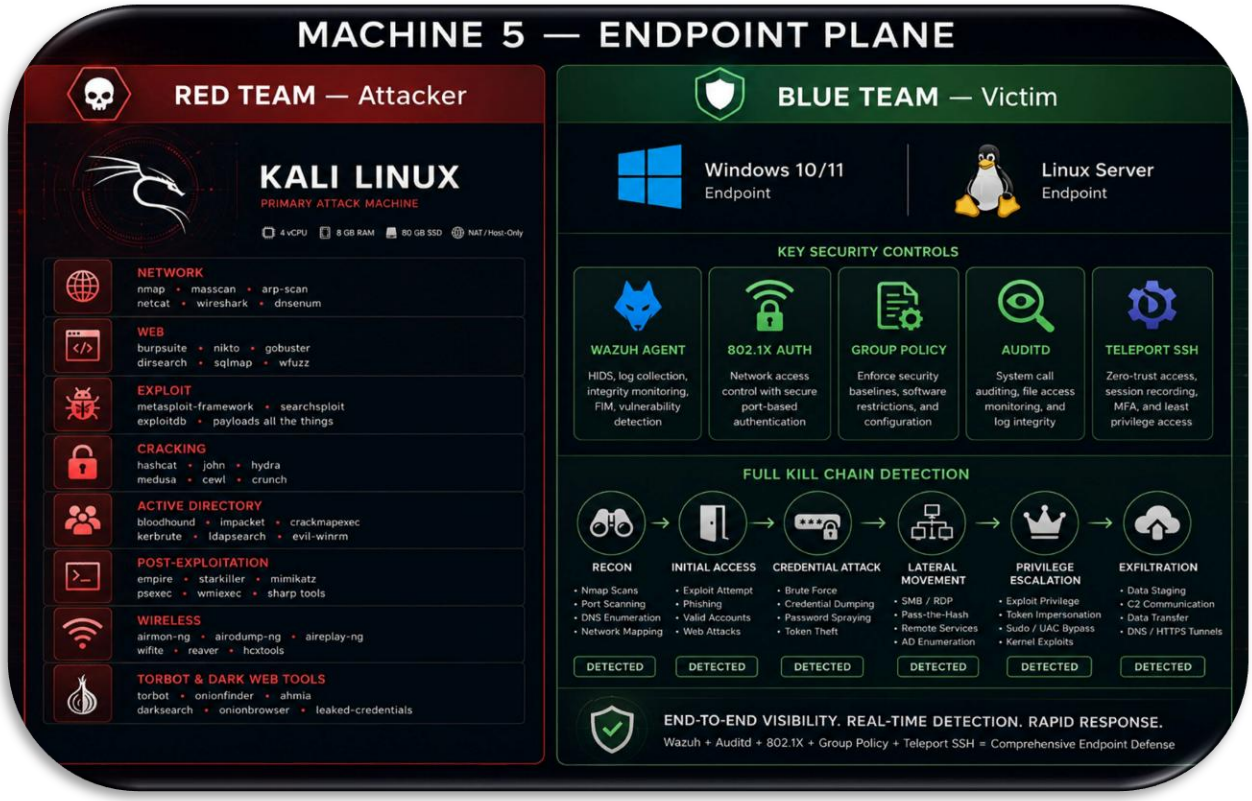
1. Executive Summary

Machine 5 (M5) is the Endpoint Protection and Hardening Plane — the final and most dynamic layer of the Zero Trust UTM lab. With 16 GB of RAM, M5 serves a dual purpose: it houses a Kali Linux attack machine (Red Team) used to simulate real-world adversary activity, and it hosts victim endpoints (Blue Team) that must detect, log, and respond to every stage of the attack kill chain.

The key achievement of M5 is FULL KILL CHAIN DETECTION: every stage of the cyber kill chain — from initial reconnaissance through to data exfiltration — was detected by the Blue Team security controls deployed on the victim endpoints.

2. M5 Architecture Overview

The M5 Endpoint Plane diagram below shows the complete dual-purpose architecture — the Red Team Kali Linux attack machine on the left and the Blue Team victim endpoints on the right, with all security controls and the full kill chain detection status.



Endpoint Plane Architecture showing Kali Linux (Red Team) attack tool categories, Blue Team victim endpoints (Windows 10/11 and Linux Server), key security controls, and Full Kill Chain Detection results — all 6 stages DETECTED

Dual-Purpose Design Philosophy

M5 embodies the Red Team / Blue Team paradigm within a single machine. Rather than simulating attacks theoretically, M5 runs real attack tools from a hardened Kali Linux VM against live victim endpoints protected by genuine enterprise security controls. This approach proves that the Zero Trust architecture is not merely configured — it actively detects and responds to real attacks.

The ultimate validation: Wazuh + Auditd + 802.1X + Group Policy + Teleport SSH = Comprehensive Endpoint Defense.

3. Red Team — Kali Linux Attack Machine

Attack Tool Categories

The Kali Linux machine is equipped with attack tools across eight categories, covering the full spectrum of adversary techniques from initial reconnaissance to post-exploitation and dark web operations.

NETWORK	nmap, masscan, arp-scan, netcat, wireshark, dnsenum
WEB	burpsuite, nikto, gobuster, dirsearch, sqlmap, wfuzz
EXPLOIT	metasploit-framework, searchsploit, exploitdb, payloads-all-the-things
CRACKING	hashcat, john, hydra, medusa, cewl, crunch
ACTIVE DIR.	bloodhound, impacket, crackmapexec, kerbrute, ldapsearch, evil-winrm
POST-EXPL.	empire, starkiller, mimikatz, psexec, wmiexec, sharp tools
WIRELESS	airmon-ng, airodump-ng, aireplay-ng, wifite, reaver, hcxtools
TOR / DARK WEB	torbot, onionfinder, ahmia, darksearch, onionbrowser, leaked-credentials

4. Blue Team — Victim Endpoint Configuration

The Blue Team side of M5 consists of two endpoint types: a Windows 10/11 Endpoint and a Linux Server Endpoint. Both are protected by five key security controls that form a comprehensive defense-in-depth stack. Each control feeds telemetry into the centralized M3 SIEM for correlation and alerting.

Key Security Controls Summary

Wazuh Agent	HIDS, log collection, integrity monitoring, FIM, vulnerability detection. Agent sends all endpoint telemetry to M3 Wazuh SIEM.
802.1X Auth	Network access control with secure port-based authentication. Integrates with M2 FreeRADIUS and M2 Step-CA for certificate-based EAP authentication.
Group Policy	Enforce security baselines, software restrictions, and configuration standards. Integrates with M2 Samba Active Directory.
Auditd	System call auditing, file access monitoring, and log integrity on Linux endpoints. Audit logs forwarded to M3 Wazuh SIEM via Kafka.
Teleport SSH	Zero-trust access, session recording, MFA, and least privilege access. Integrates with M2 Teleport server for centralized access management.

5. Full Kill Chain Detection — Proof of Concept

The Kill Chain Detection proof-of-concept is the central achievement of M5 and of the entire Zero Trust UTM project. The Red Team (Kali Linux) executed real attacks against Blue Team endpoints, and every stage was detected by the deployed security controls.

Stage 1 — Reconnaissance (DETECTED)

- Attack Techniques: Nmap port scans, masscan, arp-scan, DNS enumeration (dnsenum), network mapping.
- Detection Mechanism: Wazuh agent on victim endpoint detected the scan patterns. Suricata IDS on M1 flagged the scan signatures. Custom Wazuh rules triggered on high-frequency connection attempts.

Stage 2 — Initial Access (DETECTED)

- Attack Techniques: Exploit attempts (Metasploit), phishing simulation, valid account testing, web application attacks (nikto, gobuster, sqlmap).
- Detection Mechanism: Wazuh HIDS detected exploit attempts and web attack patterns. Authentication failure logs captured. FIM (File Integrity Monitoring) triggered on unauthorized file access.

Stage 3 — Credential Attack (DETECTED)

- Attack Techniques: Brute force (hydra, medusa), credential dumping (mimikatz), password spraying (crackmapexec), token theft.
- Detection Mechanism: Wazuh custom rules detected authentication failure patterns (multiple failures in short timeframes). Auditd captured credential dumping system calls. 802.1X rejected unauthorized network access.

Stage 4 — Lateral Movement (DETECTED)

- Attack Techniques: SMB and RDP lateral movement, Pass-the-Hash (impacket), remote service execution, Active Directory enumeration (bloodhound).
- Detection Mechanism: Wazuh agent detected lateral movement patterns. Auditd captured remote execution attempts. BloodHound enumeration triggered AD-related alerts. FortiGate micro-segmentation limited lateral movement paths.

Stage 5 — Privilege Escalation (DETECTED)

- Attack Techniques: Exploit privilege escalation vulnerabilities, token impersonation, Sudo/UAC bypass, kernel exploits.
- Detection Mechanism: Auditd captured privilege escalation system calls (setuid, sudo usage). Wazuh vulnerability detection flagged exploitable conditions. Group Policy restrictions blocked many escalation vectors.

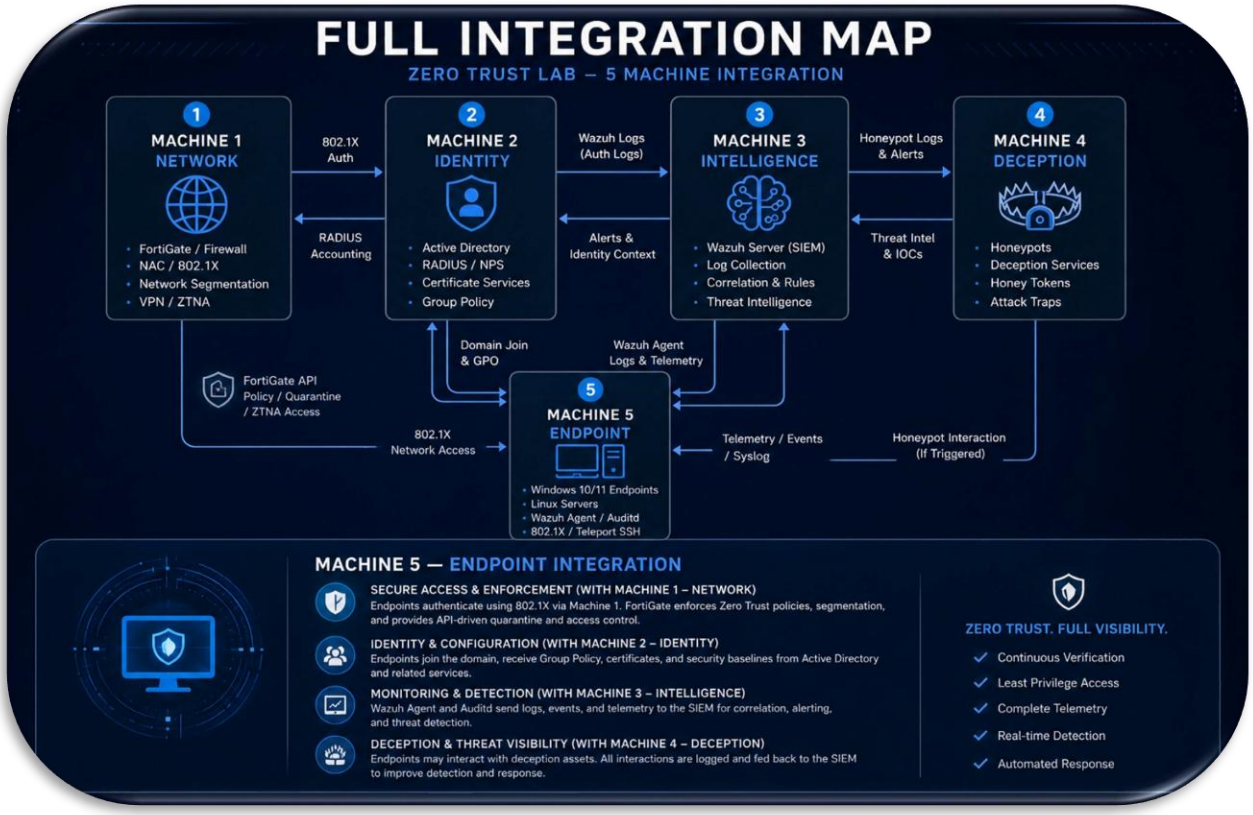
Stage 6 — Exfiltration (DETECTED)

- Attack Techniques: Data staging, C2 (Command and Control) communication, data transfer, DNS/HTTPS tunneling.
- Detection Mechanism: Zeek and Arkime (M1) detected anomalous outbound traffic patterns. Wazuh FIM detected staged file access. Suricata IDS on M1 flagged C2 communication signatures. Pi-hole (M1) blocked known malicious domains.

RESULT: End-to-End Visibility. Real-Time Detection. Rapid Response. The Zero Trust architecture proved effective against the complete kill chain.

6. M5 Full Integration Map

The Full Integration Map below shows how M5 connects to all other machines in the Zero Trust UTM lab, completing the five-machine integration.



Full Integration Map — Zero Trust Lab 5-Machine Integration showing data flows between all machines: M1 (Network), M2 (Identity), M3 (Intelligence), M4 (Deception), and M5 (Endpoint) with all integration pathways

M5 Integration Details

With M1 (Network)	Secure Access & Enforcement: Endpoints authenticate using 802.1X via Machine 1. FortiGate enforces Zero Trust policies, segmentation, and provides API-driven quarantine and access control.
With M2 (Identity)	Identity & Configuration: Endpoints join the domain (zerotrust.lab), receive Group Policy, certificates, and security baselines from Active Directory and related services. Teleport SSH managed via M2 Teleport server.
With M3 (Intelligence)	Monitoring & Detection: Wazuh Agent and Auditd send logs, events, and telemetry to the SIEM (M3) for correlation, alerting, and threat detection. Data flows via Wazuh Agent Logs & Telemetry path.
With M4 (Deception)	Deception & Threat Visibility: Endpoints may interact with deception assets on M4. All interactions are logged and fed back to the SIEM to improve detection and response. Honeypot Interaction (If Triggered) path.

7. Zero Trust Principles in Practice

The diagram below summarizes all six Zero Trust principles as implemented in this lab, along with the three implementation pillars.



Zero Trust Principles in Practice — six principles implemented across the lab: Never Trust Always Verify, Least Privilege Access, Micro-Segmentation, Continuous Monitoring, Automated Response, and Deception-Based Detection

The Six Zero Trust Principles

1. Never Trust, Always Verify	Every user, device, and request is verified before access is granted. Trust is never assumed. Implemented via 802.1X, MFA, Teleport SSH, and continuous identity verification through M2.
2. Least Privilege Access	Users and devices get only the minimum access needed to perform their task — nothing more. Enforced through Group Policy, Teleport SSH roles, and FortiGate ZTNA policies.
3. Micro-Segmentation	Network is segmented into isolated zones with strict access controls and Zero Trust policies. FortiGate and OPNsense enforce strict inter-zone policies. M4 DMZ is completely isolated.
4. Continuous Monitoring	Every activity is logged, analyzed, and correlated in real-time for anomalies and threats. M3 Wazuh SIEM, Zeek+Arkime, Kafka, and OpenSearch provide full-spectrum monitoring.
5. Automated Response	Security controls automatically block, contain, and remediate threats in seconds — no manual delay. Shuffle SOAR on M3 executes automated playbooks triggered by Wazuh alerts.
6. Deception-Based Detection	Honeypots and decoys lure attackers, expose intent early, and improve detection accuracy. M4 provides 15+ honeypots across all protocols, including dark web coverage via Tor.

Implementation Pillars

- Identity Verification — Strong authentication (802.1X, AD, MFA) ensures only verified identities connect.
- Continuous Inspection — All traffic, users, and devices are continuously inspected and validated.
- Automated Enforcement — Policies are enforced automatically across the entire environment.

Core tenets: Visibility Everywhere — No Implicit Trust — Assume Breach — Protect What Matters

8. Zero Trust Principles Applied to M5

Continuous Verification	Wazuh continuously monitors all endpoint activity. 802.1X re-authenticates on every connection. Teleport records all sessions.
Least Privilege Access	Group Policy restricts software execution. Teleport SSH enforces role-based access. FortiGate ZTNA policies limit network access.
Complete Telemetry	Wazuh Agent + Auditd generate comprehensive logs for every system call, file access, and network connection.
Real-time Detection	Full Kill Chain Detection proves the architecture detects threats at every stage without delay.
Automated Response	SOAR workflows respond to endpoint alerts automatically — quarantine, block, and case creation.
Never Trust, Always Verify	Every endpoint connection verified. No implicit trust regardless of network location. Lateral movement detected and blocked.

9. Final Zero Trust UTM Lab Summary

All five machines of the Zero Trust UTM lab are now fully documented and operational. Together they form a cohesive, end-to-end Zero Trust security architecture validated through real attack simulation.

Complete Technology Stack

NETWORK (M1)	FortiGate, pfSense/OPNsense, Suricata IPS/IDS, Zeek + Arkime, Pi-hole
IDENTITY (M2)	Samba AD, Vault, Keycloak, FreeRADIUS, OpenLDAP, Kerberos, Teleport, BloodHound, EJBCA + StepCA
INTELLIGENCE (M3)	Wazuh SIEM, Kafka, Logstash, OpenSearch, MISP, TheHive + Cortex, Shuffle SOAR, OpenCTI + IntelOwl, Prometheus + Grafana
DECEPTION (M4)	T-Pot, OpenCanary, Cowrie, Dionaea, Heralding, Rdpy, Mailoney, MongoHoneypot, Canarytokens, Tor Honeypot, Glastopf, Suricata Honeypot, ConPot, Honeytrap, Redishoneypot, ElasticPot
ENDPOINT (M5)	Kali Linux (Red Team), Windows 10/11 Endpoint, Linux Server, Wazuh Agent, Auditd, 802.1X + FreeRADIUS, Group Policy, Teleport SSH

Cluster Hardware Summary

Total Machines	5 laptops
Total RAM	104 GB (24+16+32+16+16 GB)
Total Physical Cores	60 (12 per machine)
Total Logical Processors	30 (6 per machine)
M1 — Network Plane	24 GB RAM — FortiGate, OPNsense, Suricata, Zeek+Arkime
M2 — Identity Plane	16 GB RAM — Samba AD, FreeRADIUS, Vault, Keycloak, Teleport
M3 — Intelligence Plane	32 GB RAM — Wazuh SIEM, Kafka, OpenSearch, SOAR, CTI
M4 — Deception Plane	16 GB RAM — 15+ Honeypots, 4 VMs, Tor Hidden Service
M5 — Endpoint Plane	16 GB RAM — Kali Linux + Windows 10/11 + Linux Endpoints

Never Trust · Always Verify · Always Monitor · Always Respond